



Corso Master Aziendale: Privacy, GDPR, NIS 2 e Cybersecurity

Il framework normativo europeo (GDPR) e
l'adeguamento tecnico IT

*Manuale Pratico Completo per l'Implementazione Aziendale
da Zero*

Con Template, Policy, Checklist e Documenti Operativi

Autore: **0THack1A**

Data: **Giugno 2026**

Edizione Aggiornata con Direttiva NIS 2 e AI Act

Indice

1	Capitolo 1: L'Evoluzione del Diritto alla Privacy. Dal "Let me alone" all'Habeas Data	6
1.1	1.1 Le Origini del Diritto alla Riservatezza	6
1.2	1.2 La Trasformazione Europea: il Diritto alla Protezione dei Dati	6
1.3	1.3 L'Architettura Normativa in Italia: dal Codice Privacy al GDPR	7
2	Capitolo 2: Il Cuore della Conformità: i Principi dell'Articolo 5	8
2.1	2.1 Principio di Liceità, Correttezza e Trasparenza	8
2.2	2.2 Principio di Limitazione della Finalità	9
2.3	2.3 Principio di Minimizzazione dei Dati	9
2.4	2.4 Principio di Esattezza	9
2.5	2.5 Principio di Limitazione della Conservazione (Data Retention)	9
2.6	2.6 Integrità e Riservatezza	10
2.7	2.7 L'Accountability (Responsabilizzazione): la Vera Rivoluzione	10
3	Capitolo 3: Le Basi Giuridiche (Art. 6) e le Deroghe per Dati Sensibili (Art. 9)	12
3.1	3.1 Flowchart per la Scelta della Base Giuridica	12
3.2	3.2 Il Consenso: Quando e Come Ottenerlo (Art. 7)	12
3.3	3.3 Il Legittimo Interesse: lo Strumento più Potente e Rischioso (Art. 6.1.f)	13
3.4	3.4 I Dati Particolari ("Sensibili") e l'Art. 9	13
4	Capitolo 4: Il Framework della Sicurezza IT e la Triade "CIA" (Art. 32)	15
4.1	4.1 La Triade CIA in Dettaglio	15
4.1.1	4.1.1 Confidenzialità: Cifratura dei Dati	15
4.1.2	4.1.2 Integrità: Hash e Logging	16
4.1.3	4.1.3 Disponibilità: La Strategia Backup 3-2-1 e il DRP	16
4.2	4.2 Hashing delle Password: l'Obbligo dello "Stato dell'Arte"	17
4.3	4.3 Checklist delle Misure Tecniche Minime Art. 32	17
5	Capitolo 5: L'Incubo delle 72 Ore – La Gestione dei Data Breach (Art. 33 e 34)	19
5.1	5.1 Definizione di Violazione dei Dati Personali	19
5.2	5.2 Il Processo in 3 Fasi	19
5.2.1	5.2.1 Fase 1 – Rilevamento e Valutazione Interna (sempre obbligatoria)	19
5.2.2	5.2.2 Fase 2 – Notifica al Garante entro 72 Ore (Art. 33)	19
5.2.3	5.2.3 Fase 3 – Comunicazione agli Interessati (Art. 34)	20
6	Capitolo 6: Documentazione Operativa – Il Registro Data Breach	21
6.1	6.1 Il Registro Data Breach Interno (Ex Art. 33, comma 5)	21
7	Capitolo 7: La Roadmap di Adeguamento Aziendale – Dal "Giorno Zero" alla Compliance	23
7.1	7.1 Fase 0 – Assessment Iniziale ("Fotografia As Is")	23

7.2	7.2 Fase 1 – Nomina del Titolare e Verifica Obbligo DPO	23
7.3	7.3 Fase 2 – Produzione Documentale (i 7 Documenti Fondamentali)	24
7.4	7.4 Fase 3 – Adeguamento Tecnico (Art. 32)	24
7.5	7.5 Fase 4 – Formazione del Personale	25
8	Capitolo 8: I Documenti Obbligatoriosi in Dettaglio – con Template Completi	26
8.1	8.1 Il Registro delle Attività di Trattamento (Art. 30)	26
8.2	8.2 Le Informative Privacy (Art. 13 e 14)	27
8.3	8.3 Le Nomine dei Soggetti Autorizzati al Trattamento (Art. 29)	28
9	Capitolo 9: Il DPA (Data Processing Agreement) – Contratto con i Fornitori Esterni (Art. 28)	29
9.1	9.1 Quando è Obbligatorio il DPA	29
9.2	9.2 Le 8 Clausole Obbligatorie del DPA (Art. 28.3)	29
10	Capitolo 10: Le Policy Operative Aziendali – con Template Completi	32
10.1	10.1 Policy Utilizzo dei Dispositivi Mobili Aziendali e BYOD	32
10.2	10.2 Policy Utilizzo Stampanti e Dispositivi Multifunzione (MFP)	33
10.3	10.3 Policy Videosorveglianza Aziendale	34
10.4	10.4 Policy Email Aziendale e Monitoraggio delle Comunicazioni	35
10.5	10.5 Policy Password e Sicurezza degli Accessi	36
10.6	10.6 Policy Clean Desk (Scrivania Pulita)	36
11	Capitolo 11: La Valutazione d’Impatto (DPIA) – Art. 35	38
11.1	11.1 Cos’è la DPIA e Quando è Obbligatoria	38
11.2	11.2 La Struttura di una DPIA	38
12	Capitolo 12: I Diritti degli Interessati – Come Gestirli Operativamente	40
13	Capitolo 13: L’Evoluzione Normativa – Dalla NIS alla Direttiva NIS 2	42
13.1	13.1 Perché la NIS 2 Riguarda le Aziende	42
13.2	13.2 Chi Rientra nel Perimetro NIS 2	42
13.3	13.3 Confronto GDPR vs NIS 2	43
13.4	13.4 Gli Obblighi Pratici NIS 2 (Art. 21)	43
13.5	13.5 La Novità delle Sanzioni NIS 2: Responsabilità Personale dei Dirigenti	44
14	Capitolo 14: Formazione e Cultura della Privacy in Azienda	45
14.1	14.1 Perché la Formazione è una Misura di Sicurezza	45
14.2	14.2 Piano Formativo Minimo Annuale	45
15	Capitolo 15: Test Avanzato di Verifica (20 Domande a Risposta Multipla)	46
16	Capitolo 16: Soluzioni del Test (Per il Docente)	51
17	Capitolo 17: Glossario Normativo e Riferimenti Ufficiali	53
17.1	17.1 Glossario Tecnico-Legale	53

17.2	17.2 Riferimenti Ufficiali e Webgrafia	55
18	Capitolo 18: Cybersecurity Avanzata per Ambienti IT Aziendali	56
18.1	18.1 Architettura di Rete Sicura: la Segmentazione VLAN	56
18.2	18.2 Gestione degli Accessi Privilegiati (PAM)	56
18.3	18.3 Vulnerability Management e Patch Management	57
18.4	18.4 Incident Response: Gestire un Attacco in Modo Strutturato	57
18.5	18.5 Phishing e Social Engineering: il Principale Vettore di Attacco	59
19	Capitolo 19: Il Trattamento dei Dati del Personale – Approfondimento	60
19.1	19.1 Il Ciclo di Vita del Dato Dipendente	60
19.2	19.2 Il Medico Competente e la Sorveglianza Sanitaria	60
19.3	19.3 Il Controllo a Distanza dei Lavoratori: i Limiti dell’Art. 4 Statuto	61
20	Capitolo 20: Il Sito Web Aziendale – Compliance Digitale Completa	62
20.1	20.1 La Privacy Policy del Sito Web	62
20.2	20.2 La Cookie Policy e il Banner Cookie	62
20.3	20.3 Google Analytics e il Trasferimento Extra-UE	63
21	Capitolo 21: Casi Pratici – Sanzioni e Sentenze Reali, con Fonti Verificate	64
21.1	21.1 Caso 1 – Marketing via SMS ed Email Dopo l’Opposizione dell’Interessato (Verisure Italia, 2025)	64
21.2	21.2 Caso 2 – Videosorveglianza in Assenza di Accordo Sindacale (H&M Hennes & Mauritz S.r.l., 2023)	64
21.3	21.3 Caso 3 – Valutazione Errata del Rischio e Mancata Notifica (Humanitas Mirasole S.p.A., 2025)	65
21.4	21.4 Caso 4 – Password in Chiaro e Hashing Obsoleto (The European House – Ambrosetti S.p.A., 2026)	65
21.5	21.5 Caso 5 – App di Monitoraggio Imposte su Dispositivi Personali (Ares Capital S.A., AEPD Spagna)	66
21.6	21.6 Caso 6 – Cookie e Dark Pattern (Google LLC, CNIL Francia, 2021/2022)	67
21.7	21.7 Caso 7 – Una Vera Sentenza Giudiziarica: “Schrems II” (Corte di Giustizia dell’Unione Europea, 2020)	67
21.8	21.8 Caso 8 – Quando la Sola Violazione del GDPR Non Basta per il Risarcimento (“Österreichische Post”, CGUE 2023)	68
21.9	21.9 Caso 9 – La Sentenza Fondativa del Diritto all’Oblio (“Google Spain”, CGUE 2014)	69
22	Capitolo 22: Il Piano d’Implementazione GDPR in 12 Mesi – Roadmap Pratica	71
22.1	22.1 Le Attività di Mantenimento Annuale	72
22.2	22.2 Il Costo del Non-Adeguamento	72
23	Capitolo 23: Privacy e Intelligenza Artificiale – Il Futuro della Compliance	74
23.1	23.1 L’AI Act e la sua Interazione con il GDPR	74

23.2	23.2 L'Uso di AI Generativa in Azienda: i Rischi Privacy	74
23.3	23.3 I Provider AI come Responsabili del Trattamento	75
24	Capitolo 24: Il Trattamento dei Dati dei Clienti B2B e B2C	76
24.1	24.1 Dati B2C (Business to Consumer) – Il Regime più Stringente	76
24.2	24.2 Dati B2B (Business to Business) – Regime Differenziato	76
24.3	24.3 Il CRM e la Governance dei Dati Commerciali	77
25	Capitolo 25: Trasferimenti di Dati Fuori dall'UE – Le Garanzie Necessarie	78
25.1	25.1 Framework delle Garanzie per i Trasferimenti Extra-UE	78
25.2	25.2 Il Data Privacy Framework USA-UE (2023)	78
25.3	25.3 WhatsApp, Google Drive e i Trasferimenti "Invisibili"	79
26	Capitolo 26: Il DPO – Ruolo, Requisiti e Modalità Operative	80
26.1	26.1 Chi è il DPO e Cosa Fa	80
26.2	26.2 Requisiti e Incompatibilità	80
26.3	26.3 Come Segnalare il DPO al Garante	80
27	Capitolo 27: Privacy in Settori Specifici	82
27.1	27.1 Privacy nel Settore Sanitario	82
27.2	27.2 Privacy nel Settore Scolastico	82
27.3	27.3 Privacy nelle Risorse Umane (HR)	83
28	Capitolo 28: Domande Frequenti (FAQ) sul GDPR per le PMI	84
29	Capitolo 29: Come Affrontare un'Ispezione del Garante o della Guardia di Finanza	86
29.1	29.1 Come si Svolge un'Ispezione Privacy	86
29.2	29.2 Cosa Viene Richiesto Durante l'Ispezione	86
29.3	29.3 Cosa Fare e Cosa Non Fare Durante l'Ispezione	86
29.4	29.4 Dopo l'Ispezione: il Verbale e le Conseguenze	87
30	Capitolo 30: Videosorveglianza Intelligente, Riconoscimento Facciale e Smart City	88
30.1	30.1 La Differenza tra Videosorveglianza Tradizionale e Videosorveglianza "Intelligente"	88
30.2	30.2 Il Divieto (con Eccezioni) del Riconoscimento Facciale in Tempo Reale	88
30.3	30.3 Smart City e Sensori Urbani: il Bilanciamento con la Privacy	89
31	Capitolo 31: Esercitazioni Pratiche Guidate	90
31.1	31.1 Esercitazione 1 – Compilare il Registro delle Attività di Trattamento .	90
31.2	31.2 Esercitazione 2 – Classificare un Data Breach e Decidere se Notificare	91
31.3	31.3 Esercitazione 3 – Correggere una Policy Aziendale Scritta Male	92
31.4	31.4 Esercitazione 4 – Valutare il Perimetro NIS 2 e Rispondere a un Incidente	93
32	Capitolo 32: Il Procedimento Sanzionatorio del Garante e il Diritto di Opposizione	96

32.1	32.1 Le Due Fasi del Procedimento: Istruttoria e Sanzionatoria	96
32.2	32.2 La Contestazione e i Diritti di Difesa: i 30 Giorni	96
32.3	32.3 Il Provvedimento Finale e l'Opposizione al Tribunale Ordinario	97
32.4	32.4 La Giurisprudenza Recente sui Termini Perentori: i Casi RAI ed Enel Energia	98
32.5	32.5 Strumenti Alternativi al Contenzioso: Ravvedimento e Riduzione della Sanzione	99
33	Capitolo 33: Secondo Test di Verifica – Capitoli 17–32 (30 Domande)	100
34	Capitolo 34: Soluzioni del Secondo Test (Per il Docente)	107
35	Capitolo 35: Checklist Finale – Concetti Chiave per l'Esame	109
	Appendice A: Schema Riassuntivo Art. 5	112
	Appendice B: Tabella Decisionale Basi Giuridiche	113
	Appendice C: Contatti Utili	113
	Appendice D: Fonti e Riferimenti Consultati	114
	Appendice E: Glossario per lo Studente	119
	Indice Analitico	122

1 Capitolo 1: L'Evoluzione del Diritto alla Privacy. Dal "Let me alone" all'Habeas Data

1.1 1.1 Le Origini del Diritto alla Riservatezza

Per comprendere l'impianto sanzionatorio e le rigidità del GDPR, è imperativo comprendere l'evoluzione filosofica e giuridica del diritto alla privacy. L'origine formale del concetto è universalmente riconosciuta nel celebre saggio *"The Right to Privacy"* scritto dagli avvocati americani Samuel Warren e Louis Brandeis, pubblicato nel 1890 sulla Harvard Law Review.

Testo di Legge

"The intensity and complexity of life, attendant upon advancing civilization, have rendered necessary some retreat from the world... The right to life has come to mean the right to enjoy life, — the right to be let alone." (Warren & Brandeis, 1890)

In quel periodo la minaccia percepita proveniva dalla neonata stampa scandalistica e dalle prime macchine fotografiche Kodak portatili. La privacy era intesa come un diritto **passivo**: la pretesa che Stato e terzi si astenessero dall'invadere la sfera privata. Non era necessario "fare" nulla; bastava che gli altri si fermassero.

1.2 1.2 La Trasformazione Europea: il Diritto alla Protezione dei Dati

Il Novecento europeo ha trasformato radicalmente questa visione. L'utilizzo dei censimenti demografici e delle macchine meccanografiche Hollerith (schede perforate) da parte dei regimi totalitari nazista e sovietico per identificare, profilare e perseguire minoranze etniche, religiose e politiche ha lasciato un segno indelebile sulla coscienza giuridica europea.

Per questo l'Europa non si è accontentata del semplice "diritto alla riservatezza" ma ha sviluppato il concetto di **diritto attivo alla protezione dei dati personali**, noto nel mondo ispanico come **Habeas Data**.

Il termine richiama il medievale *Habeas Corpus* ("hai il corpo"), istituto posto a tutela della libertà fisica dall'arresto arbitrario. L'**Habeas Data** sancisce che il *corpo digitale* di un individuo — l'insieme delle sue informazioni — appartiene all'individuo stesso, non a chi le raccoglie.

Nota Pratica

Cosa implica in pratica l'Habeas Data? Ogni cittadino deve poter: sapere *chi* detiene i suoi dati e *perché*; sapere *come* vengono usati e *a chi* vengono ceduti; esigere la *rettifica* in caso di errori; esigere la *cancellazione* quando non ci sono più ragioni per trattarli. Questi diritti non sono una cortesia: sono pretese legalmente azionabili davanti al Garante e ai Tribunali.

1.3 L'Architettura Normativa in Italia: dal Codice Privacy al GDPR

L'Italia è stata tra i paesi europei più precoci nell'adottare una normativa organica sulla privacy.

Anno / Norma	Contenuto chiave
1996 – Legge 675	Prima legge strutturale italiana. Recepisce la Direttiva 95/46/CE. Istituisce l'Autorità Garante (primo Presidente: Prof. Stefano Rodotà).
2003 – D.Lgs. 196	“Codice Privacy”: testo unico. Fissa misure minime di sicurezza, obblighi documentali, reati penali per trattamento illecito.
2016 – GDPR	Regolamento (UE) 2016/679. Applicazione diretta in tutti i 27 Paesi UE senza legge di recepimento. Fine del “forum shopping”.
2018 – D.Lgs. 101	“Taglia e cucì” del Codice del 2003. Allineamento al GDPR. Mantiene specificità nazionali (età consenso digitale: 14 anni; giornalismo; fascicoli sanitari).
2022 – Direttiva NIS 2	Direttiva UE 2022/2555 sulla cybersicurezza delle infrastrutture critiche. Recepimento in Italia entro ottobre 2024.
2024 – AI Act	Regolamento UE sull'intelligenza artificiale: classificazione per livelli di rischio; DPIA obbligatoria per sistemi ad alto rischio.

La distinzione fondamentale tra **Direttiva** e **Regolamento** è cruciale:

- La **Direttiva** stabilisce obiettivi ma lascia ai parlamenti nazionali la scelta di come raggiungerli. Il risultato è frammentazione e ritardi (anni di recepimento).
- Il **Regolamento** (come il GDPR) è direttamente vincolante e applicabile in tutti i 27 Paesi dal giorno della pubblicazione in Gazzetta Ufficiale dell'UE. Non serve alcuna legge nazionale.

Attenzione – Violazione Comune

Errore comune nelle PMI: “Il GDPR non ci riguarda, siamo una piccola azienda.” FALSO. Il GDPR si applica a qualsiasi soggetto che tratti dati personali di persone fisiche residenti nell'UE, *indipendentemente* dalla dimensione. Non esiste una soglia di dipendenti o fatturato sotto la quale si è esenti.

2 Capitolo 2: Il Cuore della Conformità: i Principi dell'Articolo 5

L'Articolo 5 del GDPR è la norma madre dell'intero impianto. Violarla attiva il regime sanzionatorio più severo: **fino al 4% del fatturato globale annuo** o 20 milioni di euro (il valore più alto tra i due).

Testo di Legge

Art. 5 GDPR – Principi applicabili al trattamento: “I dati personali sono: a) trattati in modo lecito, corretto e trasparente nei confronti dell’interessato (*liceità, correttezza e trasparenza*); b) raccolti per finalità determinate, esplicite e legittime (*limitazione della finalità*); c) adeguati, pertinenti e limitati a quanto necessario (*minimizzazione dei dati*); d) esatti e, se necessario, aggiornati (*esattezza*); e) conservati in una forma che consenta l’identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità (*limitazione della conservazione*); f) trattati in maniera da garantire un’adeguata sicurezza (*integrità e riservatezza*). Il titolare del trattamento è competente per il rispetto di tali principi ed è in grado di provarlo (*responsabilizzazione*).”

2.1 Principio di Liceità, Correttezza e Trasparenza

Liceità: Ogni trattamento deve fondarsi su una delle sei basi giuridiche dell’Art. 6 (vedi Capitolo 3). Senza base giuridica il trattamento è *illegale ab origine*. Se c’è dolo e fine di lucro, si configura il reato penale dell’Art. 167 del Codice Privacy nazionale.

Correttezza: Il trattamento deve avvenire *senza inganni*. I **Dark Pattern** violano questo principio. Esempi sanzionati:

- Il tasto “Rifiuta tutto” nascosto in fondo a tre menu, mentre “Accetta tutto” è in evidenza.
- Il pre-tick (spunta preimpostata) per l’iscrizione alla newsletter.
- Il “Cookie Wall” (il sito è inaccessibile se non si accettano tutti i cookie di profilazione).

Trasparenza: Le informazioni devono essere *facilmente accessibili, comprensibili, in linguaggio semplice*. Le informative in corpo 8 scritte in legalese su 40 pagine violano questo principio.

Attenzione – Violazione Comune

Sanzione reale: la CNIL (Garante francese) ha multato Google per 150 milioni di euro e Facebook/Meta per 60 milioni per aver reso il rifiuto dei cookie più difficile dell’accettazione (Dark Pattern). Il caso completo, con data esatta e fonte verificata, è approfondito nel Cap. 21.6.

2.2 2.2 Principio di Limitazione della Finalità

I dati si raccolgono per uno scopo **preciso e comunicato** all'interessato prima della raccolta. Non possono essere riutilizzati per scopi nuovi e incompatibili con quello originario, salvo consenso nuovo o altra base giuridica.

Esempio pratico – Comune e Telecamere ZTL:

- **Finalità originaria (lecita):** Rilevare le targhe non autorizzate nella ZTL per comminare sanzioni amministrative.
- **Nuovo utilizzo (illecito):** Alimentare un sistema di IA per analizzare i flussi pedonali a fini di marketing turistico, senza informare i cittadini di questo secondo scopo.

2.3 2.3 Principio di Minimizzazione dei Dati

Regola storica IT (VIETA-TA)	Regola GDPR (OBBLIGATORIA)
“Raccogliere più dati possibile: potrebbero servire in futuro.”	“Raccogliere <i>solo</i> l'informazione strettamente indispensabile per lo scopo dichiarato.”

Esempio – Piattaforma e-learning: Il servizio eroga corsi a pagamento. Ha bisogno di: Nome, Email, Codice Fiscale/P.IVA, Password, Indirizzo di fatturazione. *Non ha bisogno di:* genere, data di nascita (salvo verifica età), numero di telefono, profilo LinkedIn, orientamento politico. Raccogliere queste informazioni viola la minimizzazione.

2.4 2.4 Principio di Esattezza

I dati devono essere corretti e aggiornati. Il titolare deve predisporre **procedure di aggiornamento** e permettere agli interessati di rettificare i propri dati (diritto ex Art. 16 GDPR).

Esempio pratico – Database pazienti: Se l'indirizzo di un paziente è errato e il referto istologico viene consegnato al vicino, si configura un *data breach* per violazione di confidenzialità di dati sanitari (Art. 9) con obbligo di notifica al Garante entro 72 ore.

2.5 2.5 Principio di Limitazione della Conservazione (Data Retention)

Nessun dato può essere conservato *ad infinitum*. Il Titolare deve definire un **Retention Period** per ogni tipologia di dato.

Tipologia di dato	Periodo massimo consigliato	Riferimento
Fatture e documenti fiscali	10 anni	Art. 2220 Codice Civile
Dati candidati a lavoro (CV ricevuti)	12 mesi (senza rapporto)	Linee Guida Garante
Dati clienti attivi	Durata del contratto + 10 anni fiscali	Codice Civile
Dati marketing (newsletter)	24 mesi dall'ultima interazione	Garante italiano
Log di accesso IT	6 mesi (o 1 anno per infrastrutture critiche)	Prov. Garante 2007
Videosorveglianza	24-72 ore (massimo 7 giorni in casi speciali)	Linee Guida EDPB
Dati sanitari	10 anni (variabile per tipo di prestazione)	D.M. Salute

Nota Pratica

Cosa fare alla scadenza? Il dato deve essere **distrutto fisicamente** (hard disk: degaussing o shredding fisico certificato; documenti cartacei: triturazione con certificato) oppure sottoposto ad **anonimizzazione irreversibile** (l'anonimizzazione non è la pseudonimizzazione: il dato anonimizzato esce dalla giurisdizione del GDPR).

2.6 Integrità e Riservatezza

Questo principio è il ponte diretto tra la legge e la Cybersecurity. Il Titolare deve implementare misure tecniche e organizzative (la Triade CIA, vedi Capitolo 4) per proteggere i dati da:

- **Accesso non autorizzato** (riservatezza)
- **Alterazione o corruzione** (integrità)
- **Distruzione o perdita accidentale** (disponibilità)

2.7 L'Accountability (Responsabilizzazione): la Vera Rivoluzione

Il paragrafo 2 dell'Art. 5 contiene la rivoluzione più silenziosa ma più potente del GDPR: il principio di **Accountability**. Non basta *fare* le cose giuste: il Titolare deve essere in

grado di *dimostrare proattivamente* di averle fatte, in qualsiasi momento, senza preavviso. Questo significa che, *prima* di un'ispezione della Guardia di Finanza, l'azienda deve già avere:

- Il Registro delle Attività di Trattamento (Art. 30)
- Le Informative privacy firmate o inviate
- Le Nomine degli autorizzati al trattamento
- I Contratti DPA con i fornitori esterni
- I Log degli accessi ai sistemi
- La documentazione delle DPIA effettuate
- Il Registro dei Data Breach (anche se vuoto)

Attenzione – Violazione Comune

Nella prassi ispettiva la Guardia di Finanza chiede **sul posto** di vedere questi documenti. Un'azienda che inizia a compilarli il giorno dell'ispezione rischia la multa non per il contenuto, ma per l'evidenza che l'accountability non era mai stata reale.

3 Capitolo 3: Le Basi Giuridiche (Art. 6) e le Dero- ghe per Dati Sensibili (Art. 9)

Senza una delle sei basi giuridiche elencate nell'Art. 6, il trattamento è **abusivo e sanzionabile**. È il Titolare che deve scegliere la base giuridica *prima* di avviare il trattamento, e deve documentarla nel Registro delle Attività (Art. 30).

3.1 3.1 Flowchart per la Scelta della Base Giuridica

Base Giuridica	Quando si usa	Esempio concreto
Consenso (6.1.a)	Quando nessun'altra base è applicabile, spec. marketing	Newsletter promozionale a nuovi contatti
Contratto (6.1.b)	Dati necessari per eseguire il contratto con l'interessato	Indirizzo di spedizione per un e-commerce
Obbligo di legge (6.1.c)	Legge impone di raccogliere/conservare	Fatture per 10 anni (obbligo fiscale)
Interessi vitali (6.1.d)	Pericolo di vita senza alternativa	Trattamento medico urgente su paziente incosciente
Interesse pubblico (6.1.e)	Autorità pubblica nell'esercizio di funzioni istituzionali	Anagrafe comunale; Registri delle imprese
Legittimo interesse (6.1.f)	Finalità legittime che non prevaricano i diritti dell'interessato	Videosorveglianza anti-furto; sicurezza IT

3.2 3.2 Il Consenso: Quando e Come Ottenerlo (Art. 7)

Il consenso è la base giuridica più *nota* ma anche la più *fragile*: può essere revocato in qualsiasi momento dall'interessato e non è necessario se un'altra base giuridica è applicabile.

Per essere valido il consenso deve avere **4 caratteristiche cumulative**:

1. **Libero**: Non deve esserci un condizionamento o una penalizzazione per chi rifiuta. Non si può bloccare un servizio essenziale se l'utente rifiuta il marketing.
2. **Specifico**: Un consenso per finalità diversa non vale. Se si chiede il consenso per la newsletter, non può essere usato per cedere i dati a terzi.
3. **Informato**: L'utente ha ricevuto e può aver letto l'Informativa Privacy *prima* di esprimere il consenso.

4. **Inequivocabile:** Serve un'azione positiva inconfutabile (check-box vuoto da spuntare). Le caselle pre-spuntate, i pop-up “continuando a navigare accetti”, i banner senza tasto di rifiuto sono *illegali*.

Testo per richiesta consenso newsletter – Esempio conforme

[] Ho letto l'Informativa Privacy e acconsento al trattamento dei miei dati personali (nome e indirizzo e-mail) per ricevere la newsletter commerciale con offerte e novità sui prodotti di [Nome Azienda]. Posso revocare il consenso in qualsiasi momento cliccando su "Disiscriviti" in fondo ad ogni email.
(La casella deve essere vuota. La firma non sostituisce il check-box.)

3.3 Il Legittimo Interesse: lo Strumento più Potente e Rischioso (Art. 6.1.f)

Il legittimo interesse consente di trattare dati *senza consenso*, ma richiede una **LIA (Legitimate Interest Assessment)**: un documento interno di bilanciamento tra l'interesse del Titolare e i diritti dell'interessato.

Casi in cui il Garante italiano ha riconosciuto la legittimità:

- Videosorveglianza per tutela del patrimonio aziendale (con cartelli visibili e informativa).
- Blocco preventivo di traffico anomalo per sicurezza informatica (log di rete).
- Invio di offerte commerciali su *prodotti analoghi* a clienti *attivi* (soft-spam).

Casi in cui il Garante ha escluso il legittimo interesse:

- Profilazione comportamentale massiva a fini pubblicitari (Big Data Analytics).
- Monitoraggio continuo delle email dei dipendenti.
- Ricontattare clienti “silenti” da oltre 24 mesi.

3.4 I Dati Particolari (“Sensibili”) e l’Art. 9

I seguenti dati sono soggetti a un regime di protezione rafforzata e, in linea di principio, è **vietato trattarli**:

Categorie di Dati Particolari – Art. 9 GDPR

Origine razziale o etnica	Convinzioni religiose o filosofiche
Opinioni politiche	Appartenenza sindacale
Dati genetici	Dati biometrici (impronte, riconoscimento facciale)
Dati relativi alla salute	Vita sessuale o orientamento sessuale

Il trattamento è consentito *solo* in presenza di una delle deroghe tassative dell'Art. 9, tra cui:

- **Consenso esplicito** (non basta quello generico: deve riguardare specificamente questi dati).
- **Adempimenti di diritto del lavoro** (es. gestione certificati medici, permessi L. 104).
- **Tutela degli interessi vitali** (pronto soccorso).
- **Fini di medicina preventiva o del lavoro** (medico competente).

Attenzione – Violazione Comune

Caso pratico a rischio: Un'azienda raccoglie le assenze per malattia dei dipendenti (dato sanitario) e le conserva in un foglio Excel non protetto da password condiviso con tutta la direzione. Questa è una violazione dell'Art. 9 combinata con il Principio di Integrità e Riservatezza dell'Art. 5.

4 Capitolo 4: Il Framework della Sicurezza IT e la Triade “CIA” (Art. 32)

Se i Principi dell’Art. 5 sono la filosofia, l’Art. 32 è l’**ingegneria** del GDPR.

Testo di Legge

Art. 32 GDPR – Sicurezza del trattamento: “Tenendo conto dello stato dell’arte e dei costi di attuazione, nonché della natura, dell’oggetto, del contesto e delle finalità del trattamento, come anche del rischio di varia probabilità e gravità per i diritti e le libertà delle persone fisiche, il titolare del trattamento e il responsabile del trattamento mettono in atto misure tecniche e organizzative adeguate per garantire un livello di sicurezza adeguato al rischio, che comprendono, se del caso: a) la pseudonimizzazione e la cifratura dei dati personali; b) la capacità di assicurare su base permanente la riservatezza, l’integrità, la disponibilità e la resilienza dei sistemi e dei servizi di trattamento; c) la capacità di ripristinare tempestivamente la disponibilità e l’accesso dei dati personali in caso di incidente fisico o tecnico; d) una procedura per testare, verificare e valutare regolarmente l’efficacia delle misure tecniche e organizzative al fine di garantire la sicurezza del trattamento.”

4.1 La Triade CIA in Dettaglio

Proprietà CIA	Significato	Strumenti chiave
Confidentiality (Riservatezza)	Le informazioni non sono accessibili a soggetti non autorizzati	Crittografia AES-256, TLS 1.3, VPN, MFA, RBAC
Integrity (Integrità)	I dati non possono essere modificati senza rilevamento	Hash SHA-256, Logging WORM, Versioning
Availability (Disponibilità)	I dati sono accessibili quando servono	Backup 3-2-1, BCP, DRP, Anti-DDoS

4.1.1 Confidenzialità: Cifratura dei Dati

Data at Rest (dati a riposo):

- Database cifrato con **AES-256** (Advanced Encryption Standard a 256 bit). Attualmente inviolabile con la potenza computazionale disponibile.
- Dischi rigidi dei laptop aziendali cifrati con BitLocker (Windows) o FileVault (macOS).

Data in Transit (dati in transito):

- Protocollo **TLS 1.3** per siti web e API (certificato SSL/TLS — l’HTTPS).

- **VPN IPsec** o **WireGuard** per accessi remoti dei dipendenti.
- Email cifrate con **S/MIME** o **PGP** per comunicazioni riservate.

Controllo Accessi:

- **MFA (Multi-Factor Authentication):** Obbligatoria per VPN, email aziendali, pannelli di amministrazione. Un secondo fattore (app OTP, SMS, token hardware) rende inutile la sola password rubata.
- **RBAC (Role-Based Access Control):** Ogni dipendente accede solo ai dati necessari per il suo ruolo. Il principio del “*minimo privilegio*” (PoLP – Principle of Least Privilege).

4.1.2 4.1.2 Integrità: Hash e Logging

- **Funzioni di Hash crittografiche:** SHA-256 o SHA-3 per verificare l'integrità di file e comunicazioni. Se anche un solo bit cambia, l'hash è completamente diverso (proprietà di avalanche effect).
- **Log centralizzato e inalterabile (SIEM):** I log di sistema devono essere raccolti su server separato con scrittura WORM (Write Once Read Many) per impedire manomissioni.
- **Code versioning:** Tutti i cambiamenti al software applicativo devono essere tracciati (Git).

4.1.3 4.1.3 Disponibilità: La Strategia Backup 3-2-1 e il DRP

La strategia **3-2-1** è lo standard minimo richiesto dall'Art. 32:

N°	Regola	Significato
3	Tre copie totali	Dato originale + 2 backup distinti
2	Due supporti diversi	Es. NAS in rete + nastro LTO
1	Una copia off-site	Cloud o sede remota, NON collegata alla rete aziendale (Air-gap)

Attenzione – Violazione Comune

Errore fatale – NAS mappato come unità Z:\: Il backup su un NAS *collegato* alla rete aziendale non è un Air-gap. In caso di attacco Ransomware il virus cifra in tempo reale anche l'unità di rete, distruggendo l'unico backup. Il **ripristino** diventa impossibile.

Glossario essenziale per il DRP:

- **RPO (Recovery Point Objective):** Quanti dati si può accettare di perdere? (es. “Non più di 4 ore di lavoro”)
- **RTO (Recovery Time Objective):** In quanto tempo bisogna tornare operativi? (es. “Entro 8 ore dall'incidente”)

- **BCP (Business Continuity Plan):** Come si continua a lavorare durante l'incidente?
- **DRP (Disaster Recovery Plan):** Come si ripristinano i sistemi dopo l'incidente?

4.2 Hashing delle Password: l'Obbligo dello “Stato dell'Arte”

Conservare password in chiaro nel database equivale a scriverle su un foglio appeso alla porta. In caso di ispezione, la multa è *immediata* anche senza data breach avvenuto.

Algoritmo	Stato attuale	Motivazione
MD5	VIETATO	Bucabile in pochi secondi con Rainbow Tables e GPU moderne
SHA-1	VIETATO	Collisioni dimostrate (SHattered, 2017, Google)
SHA-256 senza salt	INSUFFICIENTE	Vulnerabile a Rainbow Tables pre-calcolate
Bcrypt	CONSENTITO	Lento per design; salt integrato; ancora sicuro
PBKDF2	CONSENTITO	Standard NIST; usato in WPA2 e passkit iOS
Argon2id	RACCOMANDATO	Vincitore Password Hashing Competition 2015; resistente ad attacchi GPU e ASIC

Nota Pratica

Il Salt: Prima di calcolare l'hash, si aggiunge al valore della password un *salt* — una stringa casuale univoca per ogni utente generata al momento della registrazione. Il salt viene salvato in chiaro accanto all'hash nel database. Questo rende inutili le Rainbow Tables pre-calcolate perché ogni hash è unico anche per password uguali.
Esempio: Password “pizza123” + Salt “xQ7\$kL2m” → Argon2id(“pizza123xQ7\$kL2m”) = [hash univoco]

4.3 Checklist delle Misure Tecniche Minime Art. 32

Checklist Operativa

- ☐ Antivirus aggiornato su tutti i dispositivi (endpoint protection)
- ☐ Firewall perimetrale configurato con regole whitelisting in ingresso
- ☐ TLS 1.3 attivo su tutti i servizi web e API
- ☐ MFA attiva su VPN, email admin, pannelli cloud

- ☐ Policy password: lunghezza minima 12 caratteri, nessuna scadenza automatica (NIST 2024) salvo compromissione sospettata
- ☐ Backup 3-2-1 con almeno una copia Air-gap; test di ripristino trimestrale
- ☐ Log centralizzato SIEM con retention minima 6 mesi
- ☐ Crittografia dei laptop aziendali (BitLocker/FileVault)
- ☐ Segmentazione di rete (VLAN separate per uffici / produzione / guest Wi-Fi)
- ☐ Patch management: aggiornamenti OS critici entro 30 giorni dal rilascio
- ☐ Piano DRP documentato e testato almeno annualmente

5 Capitolo 5: L'Incubo delle 72 Ore – La Gestione dei Data Breach (Art. 33 e 34)

5.1 5.1 Definizione di Violazione dei Dati Personali

L'Art. 4 GDPR definisce il Data Breach come “*la violazione di sicurezza che comporta accidentalmente o in modo illecito la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati personali.*”

Questa definizione copre le **tre aree della Triade CIA**:

Tipo di violazione	Descrizione	Esempio concreto
Violazione di Riservatezza	Accesso o esfiltrazione non autorizzata	Hacker ruba il database clienti
Violazione di Disponibilità	Perdita di accesso ai dati	Ransomware cifra i file aziendali; incendio del server room
Violazione di Integrità	Alterazione dei dati	Bug scambia gli IBAN dei dipendenti in busta paga

Nota Pratica

Caso spesso ignorato: Lo smarrimento di una chiavetta USB non cifrata con i dati anagrafici dei dipendenti è un **Data Breach**, anche se nessun hacker è coinvolto. Se la chiavetta era cifrata, il rischio per gli interessati è minimo e l'obbligo di notifica al Garante potrebbe non scattare.

5.2 5.2 Il Processo in 3 Fasi

5.2.1 Fase 1 – Rilevamento e Valutazione Interna (sempre obbligatoria)

Qualsiasi incidente deve essere valutato e registrato nel **Registro Data Breach interno**. La domanda chiave è: *c'è un rischio per i diritti e le libertà delle persone fisiche?*

Se la risposta è **NO** (es. email di lavoro inviata per errore a un collega senza dati sensibili): si registra internamente e ci si ferma.

Se la risposta è **SÌ** (es. database clienti esfiltrato): si procede alla Fase 2.

5.2.2 Fase 2 – Notifica al Garante entro 72 Ore (Art. 33)

Testo di Legge

“In caso di violazione dei dati personali, il titolare del trattamento notifica la violazione all'autorità di controllo competente senza ingiustificato ritardo e, ove possibile, **entro 72 ore** dal momento in cui ne è venuto a conoscenza, a meno che sia impro-

babile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche.”

Punti critici sul conteggio delle 72 ore:

- Il countdown parte dal momento in cui il Titolare acquisisce *ragionevole certezza* dell'incidente (non dal momento dell'attacco).
- Include sabati, domeniche e festività nazionali (non ci sono pause).
- Se non si hanno ancora tutti i dettagli, si può inviare una notifica “preliminare” al Garante, integrando successivamente le informazioni mancanti.
- La notifica si effettua tramite il portale telematico del Garante Privacy italiano (garanteprivacy.it).

5.2.3 Fase 3 – Comunicazione agli Interessati (Art. 34)

Se il rischio per gli interessati è **ELEVATO**, bisogna comunicare l'incidente direttamente agli individui coinvolti. La comunicazione deve contenere:

- Natura della violazione.
- Dati di contatto del DPO (se nominato).
- Probabili conseguenze.
- Misure adottate per rimediare.
- Consigli pratici per autotutela (es. “Cambiate subito la password e controllate gli estratti conto”).

Scenario	Obbligo
Database di email pseudonimizzate rubate (chiavi non rubate)	Solo log interno. Rischio nullo/minimo.
Database clienti con nomi e indirizzi in chiaro rubato	Notifica al Garante entro 72h.
Database medico o password in chiaro rubato	Notifica al Garante + comunicazione diretta a ogni interessato coinvolto.
Laptop cifrato smarrito	Solo log interno (i dati sono inaccessibili senza chiave).
Laptop non cifrato smarrito con dati personali	Notifica al Garante entro 72h; probabile comunicazione agli interessati.

6 Capitolo 6: Documentazione Operativa – Il Registro Data Breach

6.1 6.1 Il Registro Data Breach Interno (Ex Art. 33, comma 5)

Modello Registro Data Breach – Scheda Evento DB-2026-001

A. INFORMAZIONI GENERALI

ID Segnalazione: DB-2026-001

Data Rilevamento: 05 Marzo 2026, ore 09:15 (allerta SIEM)

Segnalante: Anna Bianchi (IT Security)

Natura: Smarrimento chiavetta USB non cifrata contenente file Excel con anagrafica 120 dipendenti (nome, cognome, IBAN, livello contrattuale).

B. CATEGORIE DEI DATI E DEGLI INTERESSATI

Interessati: 120 dipendenti – Tipologia: Dati comuni + IBAN (dato bancario).

C. VALUTAZIONE DEL RISCHIO

Rischio per i diritti: ☒ Sì – Rischio: uso fraudolento degli IBAN (rischio economico medio)

Gravità (1-5): 3

D. AZIONI DI MITIGAZIONE

Immediata: Denunciato lo smarrimento alle forze dell'ordine. Avvisato il responsabile HR.

Medio termine: Procedura di cambio IBAN per tutti i dipendenti interessati se la chiavetta non viene ritrovata entro 48h.

E. OBBLIGHI DI NOTIFICA

Notifica Garante (Art. 33): ☒ Sì – Inviata il 07/03/2026 tramite portale telematico (n° pratica 20260307-XYZ)

Comunicazione interessati (Art. 34): ☐ Sì ☒ No (rischio valutato non elevato)

Firma Titolare: Firma DPO:

Modello Registro Data Breach – Scheda Evento DB-2026-004 (Ransomware)

A. INFORMAZIONI GENERALI

ID: DB-2026-004 – Data: 12 Giugno 2026, ore 08:30

Segnalante: Mario Rossi (SOC Analyst)

Natura: Attacco Ransomware “LockBit 4.0”. Movimento laterale fino a cifratura dei file server HR (personale) e contabilità. Active Directory compromessa.

B. CATEGORIE DEI DATI

Interessati: ~450 dipendenti – Dati coinvolti: Anagrafiche, CF, IBAN, permessi L.104 (dato sanitario – Art. 9).

C. VALUTAZIONE DEL RISCHIO

Rischio: ☒ Sì – Gravità: 4 – Motivazione: blocco erogazione stipendi (rischio economico); nessuna evidenza di esfiltrazione dai log del firewall.

D. AZIONI DI MITIGAZIONE

Immediata: Staccati gli switch core per isolamento fisico di rete.

Medio termine: Ripristino bare-metal da backup LTO-9 off-site. Reset globale password via AzureAD con MFA. Revisione PoLP su tutti gli account HR.

E. OBBLIGHI DI NOTIFICA

Notifica Garante: ☒ Sì – Pratica n° XYYZ22 aperta 14/06/2026

Comunicazione interessati: ☒ Sì – Comunicato sindacale in bacheca + email individuale 15/06/2026

Firma Titolare: Firma DPO:

7 Capitolo 7: La Roadmap di Adeguamento Aziendale – Dal “Giorno Zero” alla Compliance

Questo capitolo è dedicato al consulente, al Legal, o all’IT Manager incaricato di portare un’azienda *da zero alla compliance GDPR*. Non si tratta di scaricare template generici: è un percorso strutturato in fasi, con responsabilità precise.

7.1 7.1 Fase 0 – Assessment Iniziale (“Fotografia As Is”)

Prima di produrre qualsiasi documento, bisogna capire la situazione attuale. Si conducono interviste con i referenti di:

Area	Chi intervistare	Domande chiave
HR	Responsabile HR	Quali dati raccogliete sui dipendenti? Dove li archiviate? Chi vi accede?
Marketing	Resp. Marketing	Avete database contatti? Come avete raccolto i consensi? Usate CRM di terze parti?
Vendite	Resp. Commerciale	Quali dati raccogliete dai clienti? Avete agenti esterni che gestiscono anagrafiche?
IT	Sysadmin / CTO	Dove girano i server (in sede o cloud)? Avete log? Avete backup? Avete firewall?
Amministrazione	CFO / Contabilità	Gestite IBAN, buste paga, dati fiscali? Usate software terzi (es. Zucchetti, TeamSystem)?

Le 4 domande fondamentali dell’Assessment:

1. **Che dati abbiamo?** (anagrafiche, dati sanitari, IBAN, log di accesso)
2. **Dove sono?** (server in sede, cloud AWS/Azure, archivi cartacei in cantina, laptop dei commerciali)
3. **Perché li abbiamo?** (finalità del trattamento)
4. **Chi vi accede?** (dipendenti interni, fornitori esterni, partner extra-UE)

7.2 7.2 Fase 1 – Nomina del Titolare e Verifica Obbligo DPO

Il **Titolare del Trattamento** è la persona fisica o giuridica che determina le finalità e i mezzi del trattamento. In una PMI coincide con il legale rappresentante (l’Amministratore Delegato o il Titolare dell’impresa individuale).

Il **DPO (Data Protection Officer)** è obbligatorio per:

- Autorità pubbliche e organismi pubblici.
- Organizzazioni che trattano su larga scala categorie particolari di dati (sanitari, genetici).
- Organizzazioni che effettuano monitoraggio sistematico su larga scala di interessati (es. piattaforme web con milioni di utenti).

Per le PMI non rientranti in queste categorie il DPO *non è obbligatorio*, ma è fortemente consigliato come garanzia di competenza.

7.3 7.3 Fase 2 – Produzione Documentale (i 7 Documenti Fondamentali)

#	Documento	Cosa è e perché è obbligatorio
1	Registro delle Attività di Trattamento (Art. 30)	La “carta d’identità privacy” dell’azienda. Obbligatorio per tutte le organizzazioni con > 250 dipendenti o che trattano dati sensibili o a rischio elevato.
2	Informative Privacy (Art. 13 e 14)	Da fornire prima di raccogliere i dati. Obbligatoria sempre.
3	Nomine Soggetti Autorizzati (Art. 29)	Lettere di nomina per ogni dipendente che tratta dati. Obbligatoria sempre.
4	Nomine Responsabili Esterni / DPA (Art. 28)	Contratto scritto con ogni fornitore esterno. Obbligatoria sempre.
5	Privacy Policy Sito Web	Informativa per gli utenti del sito. Obbligatoria se il sito raccoglie dati.
6	Cookie Policy e Banner Cookie	Obbligatoria se il sito usa cookie tecnici non essenziali.
7	Registro Data Breach (Art. 33.5)	Anche se vuoto: deve esistere. Obbligatorio sempre.

7.4 7.4 Fase 3 – Adeguamento Tecnico (Art. 32)

Vedi Capitolo 4 per il dettaglio tecnico. In sintesi:

- Implementare le misure della Checklist del paragrafo 4.3.
- Attivare MFA su tutti gli accessi critici.
- Implementare backup 3-2-1 con Air-gap.

- Crittografare i laptop aziendali e i database contenenti dati sensibili.

7.5 Fase 4 – Formazione del Personale

La norma più tecnica del mondo è inutile se il dipendente apre il link di phishing. La formazione è **misura organizzativa** richiesta dall'Art. 32 e deve essere:

- Documentata (registro presenze con firme).
- Periodica (almeno annuale, con aggiornamento in caso di incidenti).
- Pratica (non solo slide: simulazioni di phishing, esercitazioni di risposta a incidenti).

8 Capitolo 8: I Documenti Obbligatori in Dettaglio – con Template Completi

8.1 8.1 Il Registro delle Attività di Trattamento (Art. 30)

Il Registro è il documento più importante. Deve essere aggiornato ogni volta che si avvia un nuovo trattamento o cambia una modalità di trattamento esistente.

Contenuto obbligatorio del Registro (per il Titolare):

1. Nome e dati di contatto del Titolare (e del DPO, se nominato).
2. Finalità del trattamento.
3. Categorie di interessati e di dati personali trattati.
4. Eventuali destinatari (incluse le categorie di destinatari in Paesi terzi).
5. Termini di cancellazione (Retention Period).
6. Descrizione delle misure di sicurezza adottate (Art. 32).

Esempio – Estratto Registro Attività di Trattamento

Finalità	Categorie Interessati	Tipo Dati	Base Giuridica	Destinatari	Retention
Gestione rapporto di lavoro	Dipendenti	Comuni + Sanitari (L.104, malattia)	Obbligo di legge (Art. 6.1.c)	Studio paghe (DPA); INPS; Fisco	10 anni (fiscali)
Gestione clienti	Clienti B2B/B2C	Comuni (nome, CF, email, IBAN)	Contratto (Art. 6.1.b)	Fornitore CRM Salesforce (DPA); Commercialista (DPA)	10 anni post contratto
Newsletter marketing	Contatti iscritti	Email, nome	Consenso (Art. 6.1.a)	Piattaforma Mailchimp (DPA)	24 mesi dall'ultima apertura
Videosorveglianza	Dipendenti, visitatori	Immagini (dati biometrici)	Legittimo interesse (LIA allegata)	Fornitore manutenzione (DPA)	72 ore (7 giorni in aree particolari)
Candidature lavoro (CV spontanei)	Candidati	Comuni + CV	Consenso (Art. 6.1.a)	Solo interno HR	12 mesi

8.2 8.2 Le Informative Privacy (Art. 13 e 14)

L'informativa è il documento con cui il Titolare comunica all'interessato come tratterà i suoi dati, *prima* di raccogliarli (Art. 13) o nel momento in cui li ottiene da terzi (Art. 14).

Contenuto obbligatorio (Art. 13):

1. Identità e dati di contatto del Titolare.
2. Dati di contatto del DPO (se nominato).
3. Finalità e base giuridica del trattamento.
4. Eventuali destinatari o categorie di destinatari.
5. Intenzione di trasferire dati fuori dall'UE (e garanzie adottate).
6. Periodo di conservazione (o criteri per determinarlo).
7. Diritti dell'interessato (accesso, rettifica, cancellazione, opposizione, portabilità, limitazione).
8. Diritto di revocare il consenso in qualsiasi momento.
9. Diritto di proporre reclamo all'Autorità di controllo.
10. Se la comunicazione è un obbligo contrattuale o legale.

Esempio – Informativa Privacy Dipendenti (Art. 13)

INFORMATIVA SUL TRATTAMENTO DEI DATI PERSONALI

Ai sensi dell'art. 13 del Regolamento (UE) 2016/679 (GDPR)

Titolare del trattamento: [Nome Azienda S.r.l.], con sede in [indirizzo], P.IVA [XXXXXXXXXX], email privacy: [privacy@azienda.it]

Finalità e basi giuridiche: I Suoi dati (nome, cognome, codice fiscale, IBAN, dati relativi alla salute per gestione assenze) sono trattati per le seguenti finalità:

- Gestione del rapporto di lavoro e obblighi retributivi e contributivi – Base: Obbligo di legge (Art. 6.1.c).
- Sicurezza aziendale tramite sistema di videosorveglianza – Base: Legittimo interesse (Art. 6.1.f, LIA disponibile su richiesta).

Destinatari: Studio di elaborazione buste paga [Nome Studio] (Responsabile ex Art. 28); INPS; Agenzia delle Entrate.

Trasferimenti extra-UE: Nessuno.

Conservazione: I dati del rapporto di lavoro sono conservati per 10 anni dalla cessazione del rapporto per obblighi fiscali. I filmati di videosorveglianza per 72 ore, salvo esigenze investigative.

Diritti: Ha diritto di accedere ai Suoi dati, rettificarli, cancellarli (nei limiti di legge), opporsi al trattamento, richiederne la limitazione e la portabilità. Può revocare il consenso dove applicabile. Può proporre reclamo al Garante Privacy (www.garanteprivacy.it).

Come esercitare i diritti: Scrivere a [privacy@azienda.it].

8.3 8.3 Le Nomine dei Soggetti Autorizzati al Trattamento (Art. 29)

Ogni dipendente che maneggia dati personali deve ricevere una **lettera di nomina** con istruzioni precise su cosa può e non può fare.

Lettera di Nomina a Soggetto Autorizzato al Trattamento

NOMINA A SOGGETTO AUTORIZZATO AL TRATTAMENTO DEI DATI PERSONALI

Ai sensi dell'Art. 29 e Considerando 38 del Regolamento (UE) 2016/679

Il Titolare del Trattamento [Nome Azienda S.r.l.], nella persona del legale rappresentante Sig. [Nome], con la presente

NOMINA Sig./Sig.ra [Nome Cognome Dipendente], in forza dal [data] con ruolo di [es. Addetto HR], quale **Soggetto Autorizzato al Trattamento dei Dati Personali**, limitatamente alle seguenti categorie di dati e finalità:

- Dati anagrafici dei dipendenti per la gestione delle buste paga.
- Dati relativi alle presenze e assenze dei dipendenti.
- Dati di clienti e fornitori per la gestione contrattuale.

Il soggetto autorizzato è tenuto a:

1. Trattare i dati solo per le finalità indicate.
2. Non comunicare i dati a soggetti terzi non autorizzati.
3. Non copiare i dati su dispositivi personali o chiavette USB non cifrate.
4. Segnalare immediatamente al responsabile IT qualsiasi anomalia o possibile violazione.
5. Bloccare lo schermo del computer ogni volta che si allontana dalla postazione.

Data: Firma Titolare: Firma per accettazione:

9 Capitolo 9: Il DPA (Data Processing Agreement) – Contratto con i Fornitori Esterni (Art. 28)

9.1 9.1 Quando è Obbligatorio il DPA

Il DPA è obbligatorio ogni volta che un fornitore esterno tratta dati personali *per conto* del Titolare. Non basta il contratto commerciale standard: serve un atto scritto separato o una clausola specifica.

Fornitori che RICHIEDONO sempre il DPA:

- Studio di elaborazione buste paga (gestisce CF, IBAN, dati sanitari dei dipendenti).
- Piattaforma CRM cloud (Salesforce, HubSpot, Zoho – gestisce dati clienti).
- Piattaforma email marketing (Mailchimp, Brevo, ActiveCampaign – invia newsletter a nome del Titolare).
- Fornitore di hosting/cloud (AWS, Azure, Google Cloud – ospita i database).
- Fornitore software gestionale (Zucchetti, TeamSystem, SAP – elabora dati aziendali).
- Call center esterno (gestisce dati dei clienti per conto dell'azienda).
- Società di sorveglianza/vigilanza (accede alle riprese delle telecamere).

Fornitori che NON richiedono il DPA:

- Il corriere che consegna i pacchi (non tratta dati per conto del Titolare, ma agisce come Titolare autonomo del trattamento logistico).
- Il tecnico della macchina del caffè (non tratta dati personali).

9.2 9.2 Le 8 Clausole Obbligatorie del DPA (Art. 28.3)

Il GDPR impone che il contratto contenga almeno queste clausole (lettere a–h):

Lettera	Contenuto	Esempio di clausola
a	Istruzioni documentate	“Il Responsabile tratta i dati solo su documentata istruzione del Titolare”
b	Riservatezza	“Il Responsabile garantisce che le persone autorizzate si siano impegnate alla riservatezza”
c	Misure di sicurezza	“Il Responsabile adotta le misure di sicurezza di cui all’Art. 32”
d	Sub-responsabili	“Il Responsabile non ricorre a un altro responsabile senza autorizzazione scritta del Titolare”
e	Assistenza ai diritti	“Il Responsabile assiste il Titolare nel rispondere alle richieste degli interessati”
f	Assistenza agli obblighi	“Il Responsabile assiste il Titolare nell’adempimento degli obblighi di cui agli Artt. 32–36”
g	Cancellazione a fine rapporto	“A scelta del Titolare, il Responsabile cancella o restituisce tutti i dati personali al termine del contratto”
h	Diritto di audit	“Il Responsabile mette a disposizione del Titolare tutte le informazioni necessarie per dimostrare il rispetto del presente articolo”

Estratto DPA – Clausole Chiave per Fornitore Cloud (Art. 28)

ACCORDO SUL TRATTAMENTO DEI DATI (DATA PROCESSING AGREEMENT)

Ai sensi dell’Art. 28 del Regolamento (UE) 2016/679

Tra: [Nome Azienda S.r.l.] – di seguito “Titolare” – e [Nome Fornitore Cloud S.p.A.] – di seguito “Responsabile”

Art. 1 – Oggetto e durata: Il Responsabile è incaricato di ospitare e rendere disponibili i database del Titolare contenenti dati personali di clienti e dipendenti. Il presente accordo ha durata pari al contratto di fornitura del servizio.

Art. 2 – Istruzioni del Titolare: Il Responsabile tratterà i dati personali esclusivamente su istruzione documentata del Titolare. Qualora ritenga un’istruzione contraria al GDPR, ne informa immediatamente il Titolare senza darle esecuzione.

Art. 3 – Misure di Sicurezza: Il Responsabile si impegna ad adottare e mantenere le misure tecniche e organizzative di cui all’Art. 32 GDPR, incluse: crittografia AES-256 dei dati a riposo; TLS 1.3 per i dati in transito; MFA per l’accesso ai pannelli di controllo; backup ridondanti con test di ripristino mensile.

Art. 4 – Sub-Responsabili: Il Responsabile non può ricorrere ad ulteriori responsabili (sub-processor) senza previa autorizzazione scritta del Titolare. Lista dei sub-processor autorizzati allegata al presente accordo.

Art. 5 – Cancellazione a fine contratto: Entro 30 giorni dalla cessazione del contratto, il Responsabile cancella definitivamente tutti i dati del Titolare e fornisce attestato scritto di avvenuta cancellazione.

Art. 6 – Audit: Il Titolare (o un revisore da esso designato) ha il diritto di effettuare audit annuali. Il Responsabile fornisce tutta la documentazione richiesta entro 15 giorni lavorativi.

Luogo e data: ... Titolare: Responsabile:

10 Capitolo 10: Le Policy Operative Aziendali – con Template Completi

Le policy operative sono documenti interni che traducono le norme GDPR in regole comprensibili e vincolanti per i dipendenti. Sono **misure organizzative** ai sensi dell'Art. 32.

10.1 10.1 Policy Utilizzo dei Dispositivi Mobili Aziendali e BYOD

Il tema BYOD (Bring Your Own Device) è uno dei più critici per le PMI italiane.

Rischi del BYOD non gestito:

- Il dipendente scarica un'app malware che accede alla posta aziendale.
- Il telefono viene smarrito con le email aziendali in chiaro.
- Il dipendente licenziato conserva nel suo telefono personale i dati dei clienti aziendali.
- Il dipendente usa WhatsApp (server USA) per inviare dati personali di clienti (trasferimento extra-UE non autorizzato).

Policy BYOD e Dispositivi Mobili Aziendali – v1.0

POLICY UTILIZZO DISPOSITIVI MOBILI E BYOD

Data: Giugno 2026 – Versione: 1.0 – Approvata da: [Nome Titolare]

1. Scopo: Disciplinare l'uso dei dispositivi mobili (smartphone e tablet) aziendali e personali per attività lavorative, in conformità al GDPR e allo Statuto dei Lavoratori.

2. Dispositivi Aziendali (MDM):

- Tutti i dispositivi aziendali sono iscritti nel sistema MDM [es. Microsoft Intune].
- Il dispositivo è cifrato nativamente (BitLocker/FileVault). PIN/biometria obbligatoria.
- L'azienda può effettuare un *wipe remoto* (cancellazione da remoto) in caso di furto, smarrimento o cessazione del rapporto di lavoro.
- Il wipe eliminerà tutti i dati aziendali. I dati personali del dipendente nel profilo privato non verranno toccati (containerizzazione).
- È **vietato** installare app non approvate dalla lista whitelist IT.
- È **vietato** inviare dati aziendali via WhatsApp, Telegram, o altri servizi di messaggistica personale.

3. Dispositivi Personali (BYOD):

- Il dipendente che desidera accedere alla posta aziendale dal proprio dispositivo personale deve: (a) installare l'app Microsoft Outlook o Teams **separata** dal client personale; (b) installare il profilo MDM aziendale per il container di lavoro; (c) attivare il PIN/biometria per lo sblocco del dispositivo.

- L'accesso BYOD è consentito solo alla posta elettronica e al calendario. **Non** ai database clienti, ai sistemi gestionali, ai file server.
- In caso di cessazione del rapporto di lavoro, il dipendente deve consentire la cancellazione del container aziendale dal proprio dispositivo entro 48 ore.
- È **vietato** fare screenshot di documenti aziendali riservati dal dispositivo personale.

4. Sanzioni: La violazione delle presenti regole comporta procedimento disciplinare ai sensi del CCNL applicabile, con sanzioni fino al licenziamento per giusta causa nei casi più gravi.

Firma Titolare: Firma dipendente per presa visione e accettazione:

Data:

10.2 10.2 Policy Utilizzo Stampanti e Dispositivi Multifunzione (MFP)

Le stampanti multifunzione sono un vettore di rischio sottovalutato: contengono hard disk interni con copie delle ultime centinaia di stampe, possono essere accedute in rete e spesso non vengono aggiornate.

Policy Gestione Stampanti e Dispositivi MFP – v1.0

POLICY UTILIZZO STAMPANTI E DISPOSITIVI MULTIFUNZIONE

1. Scopo: Prevenire data breach derivanti dall'uso improprio delle stampanti, dalla stampa di documenti riservati e dallo smaltimento dei dispositivi.

2. Stampa di Documenti Riservati:

- I documenti classificati come “Riservati” o “Personali” devono essere stampati con la funzione *Pull Printing* (stampa con codice PIN o badge): il documento non viene fisicamente stampato fino a quando il dipendente non si identifica di fronte alla stampante.
- È **vietato** lasciare documenti contenenti dati personali nel vassoio di uscita della stampante.
- I documenti stampati non più necessari devono essere distrutti con il tritatore certificato DIN 66399, livello P-4 (cross-cut, particelle < 160 mm²) o superiore.

3. Sicurezza del Dispositivo MFP:

- Il pannello di controllo della stampante deve essere protetto da PIN per le funzioni di amministrazione.
- Il firmware del dispositivo MFP deve essere aggiornato entro 30 giorni dal rilascio di patch di sicurezza.
- L'accesso alla funzione di scansione verso email esterne è limitato ai soli indirizzi approvati dalla lista IT.
- La funzione Fax (se presente) è disabilitata per impostazione predefinita.

4. Smaltimento del Dispositivo MFP:

- Prima di restituire o rottamare una stampante/fotocopiatrice, il responsabile IT deve eseguire la procedura di **cancellazione sicura dell'hard disk interno** (factory reset sicuro o rimozione fisica del disco).
- Ottenere e conservare il *Certificato di Cancellazione Sicura* fornito dal fornitore del servizio di smaltimento.

Approvata da: [Titolare] Data:

10.3 10.3 Policy Videosorveglianza Aziendale

La videosorveglianza in ambito lavorativo è regolata sia dal GDPR sia dallo **Statuto dei Lavoratori (Art. 4, L. 300/1970)**, che vieta in linea di principio il controllo a distanza dei lavoratori.

Quando è lecita la videosorveglianza in azienda:

- Per esigenze **organizzative e produttive** (es. monitoraggio macchinari).
- Per la **sicurezza del lavoro** (es. aree a rischio chimico senza personale).
- Per la **tutela del patrimonio aziendale** (es. magazzini, casse, aree server).

Procedura obbligatoria:

1. **Accordo sindacale preventivo** (RSU/RSA) o, in assenza, autorizzazione dell'Ispettorato Territoriale del Lavoro (ITL).
2. **Informativa art. 13** affissa con il cartello "Area videosorvegliata" (conforme alle Linee Guida EDPB 3/2019) prima di ogni zona monitorata. Il cartello deve riportare: chi è il Titolare, finalità, periodo di conservazione, dove trovare l'informativa completa.
3. **LIA (Legitimate Interest Assessment)** documentata nel Registro.
4. Retention massima: **24–72 ore** (massimo 7 giorni per situazioni motivate; per banche e gioiellerie il Garante ha autorizzato fino a 30 giorni).

Informativa Videosorveglianza – Testo per Cartello (Art. 13)

AREA VIDEOSORVEGLIATA

Ai sensi del Regolamento (UE) 2016/679 (GDPR) e dell'Art. 4 L. 300/1970

Titolare del trattamento: [Nome Azienda S.r.l.], [Indirizzo] – email: privacy@azienda.it

Finalità: Tutela del patrimonio aziendale e sicurezza delle persone.

Base giuridica: Legittimo interesse (Art. 6.1.f GDPR) previo accordo sindacale del [data].

Conservazione: Le immagini vengono conservate per **72 ore** e successivamente cancellate automaticamente.

Accesso: Solo il responsabile IT e il Titolare hanno accesso ai filmati.

Informativa completa disponibile in portineria e su www.azienda.it/privacy

10.4 10.4 Policy Email Aziendale e Monitoraggio delle Comunicazioni

Il monitoring delle email dei dipendenti è un terreno minato: il Garante italiano ha emesso provvedimenti severe contro le aziende che lo fanno in modo sistematico.

Policy Email Aziendale – v1.0

POLICY UTILIZZO EMAIL AZIENDALE

1. Scopo: Disciplinare l'uso dell'email aziendale e chiarire le modalità di accesso da parte dell'azienda.

2. Uso corretto:

- L'account email aziendale è uno strumento di lavoro. È consentito un uso personale occasionale e non contrario alla legge.
- È **vietato** usare l'email aziendale per: attività commerciali personali; iscrizione a servizi non lavorativi; invio di comunicazioni che possano ledere l'immagine aziendale; trasmissione di dati personali di clienti a destinatari non autorizzati.
- È **vietato** aprire allegati da mittenti sconosciuti senza prima verificarne la legittimità con l'IT.

3. Monitoraggio (conforme al Provvedimento Garante 01/03/2007):

- L'azienda può effettuare **controlli statistici e aggregati** sul traffico email (volume, dimensione degli allegati) per finalità di sicurezza informatica.
- L'azienda **NON legge** sistematicamente il contenuto delle email dei dipendenti.
- L'accesso al contenuto delle email è consentito **solo** in caso di: accertata violazione di norme di legge; indagini aziendali su illeciti gravi; accesso tecnico per manutenzione con preavviso.
- In caso di assenza prolungata del dipendente, l'azienda può attivare un *auto-reply* automatico con indicazione del sostituto, ma non può reindirizzare la casella senza consenso del dipendente o accordo sindacale.

4. Cessazione del rapporto di lavoro:

Alla cessazione del rapporto, l'account è disattivato entro 24 ore. Per 30 giorni viene attivato un auto-reply che informa i mittenti del nuovo contatto aziendale. Dopo 30 giorni la casella è cancellata.

Approvata da: [Titolare] Data:

10.5 10.5 Policy Password e Sicurezza degli Accessi

Policy Password Management – v1.0

POLICY GESTIONE PASSWORD E ACCESSI

Conforme a NIST SP 800-63B (2024 revision) e linee guida ENISA

1. Requisiti delle password:

- Lunghezza minima: **12 caratteri**.
- Nessun requisito di complessità obbligatoria (maiuscola + numero + simbolo): il NIST 2024 raccomanda invece frasi lunghe e memorabili (passphrase).
- **Nessuna scadenza automatica periodica** (il NIST 2024 ha eliminato questa regola perché porta a password deboli prevedibili). La password si cambia solo in caso di sospetta compromissione.

2. Divieti assoluti:

- È **vietato** condividere la propria password con colleghi, anche per delega temporanea.
- È **vietato** usare la stessa password per account aziendali e personali.
- È **vietato** annotare le password su post-it o fogli di carta visibili.
- È **vietato** inserire credenziali aziendali su siti non aziendali (phishing).

3. MFA obbligatoria per:

- Accesso VPN aziendale.
- Pannelli di amministrazione cloud (AWS, Azure, Google Cloud).
- Email amministrativa / account con privilegi elevati (admin).
- Accesso ai sistemi di contabilità e buste paga.

4. Password Manager aziendale:

L'azienda fornisce un Password Manager aziendale [es. Bitwarden Enterprise, 1Password Teams] per la memorizzazione sicura delle credenziali di servizio condivise. L'uso di fogli Excel o documenti Word per conservare password è **vietato**.

Approvata da: [Titolare] Data:

10.6 10.6 Policy Clean Desk (Scrivania Pulita)

Policy Clean Desk – v1.0

POLICY CLEAN DESK E CLEAR SCREEN

1. Principio: Nessun documento contenente dati personali deve essere lasciato incustodito sulla scrivania o visibile sullo schermo quando il dipendente non è alla postazione.

2. Regole operative:

- Prima di lasciare la postazione (anche temporaneamente): **bloccare lo schermo** (Windows: Win+L; macOS: Ctrl+Cmd+Q).
- A fine giornata: **riporre tutti i documenti cartacei** in cassettera chiusa a chiave.
- I documenti riservati non più necessari vanno inseriti nel **distruttore documenti** (non nel cestino della carta).
- Le **chiavette USB** non devono essere lasciate inserite nei PC incustoditi.
- I badge aziendali non devono essere lasciati sulla scrivania in assenza del titolare.

Approvata da: [Titolare] Data:

11 Capitolo 11: La Valutazione d’Impatto (DPIA) – Art. 35

11.1 11.1 Cos’è la DPIA e Quando è Obbligatoria

La **DPIA (Data Protection Impact Assessment)** è un’analisi preventiva dei rischi che un nuovo trattamento potrebbe comportare per i diritti e le libertà degli interessati. Non è una burocrazia: è un processo di ingegneria del rischio applicato alla privacy.

La DPIA è obbligatoria quando il trattamento comporta due o più dei seguenti criteri (Linee Guida WP248):

1. **Valutazione e scoring** (es. credit scoring, profilazione comportamentale).
2. **Decisione automatizzata con effetti significativi** (es. recruiting con AI).
3. **Monitoraggio sistematico** (es. videosorveglianza continua, tracking GPS).
4. **Dati sensibili o di natura altamente personale** (sanitari, genetici, biometrici).
5. **Trattamenti su larga scala.**
6. **Dataset combinati** (incrociare dati da fonti diverse).
7. **Dati di soggetti vulnerabili** (minori, anziani, pazienti).
8. **Uso innovativo di tecnologie** (riconoscimento facciale, IoT, AI generativa).
9. **Trasferimento extra-UE.**
10. **Impedire l’accesso a un servizio** basandosi sul trattamento.

Il Garante italiano ha pubblicato un elenco di 12 tipologie che richiedono sempre la DPIA: tra cui: trattamenti di dati genetici o biometrici; trattamenti di dati sanitari su larga scala; scoring su dati comportamentali; videosorveglianza con AI; geolocalizzazione dei lavoratori.

11.2 11.2 La Struttura di una DPIA

Struttura Standard di una DPIA

VALUTAZIONE D’IMPATTO SULLA PROTEZIONE DEI DATI (DPIA)

Ai sensi dell’Art. 35 Regolamento (UE) 2016/679

1. Descrizione del trattamento:

Tecnologia/sistema: [es. Sistema di riconoscimento del badge biometrico per accesso in azienda]

Finalità: Controllo accessi fisici per sicurezza aziendale.

Interessati: ~200 dipendenti.

Dati trattati: Impronta digitale (dato biometrico – Art. 9 GDPR).

Sub-processor: [Nome fornitore sistema badge] (DPA allegato).

2. Necessità e proporzionalità:

Il trattamento è necessario per la finalità? [X] Sì

Esistono alternative meno invasive? Tessera con PIN numerico.

Motivazione per la scelta biometrica: [Specificare perché la tessera non è sufficiente]

Il dato è ridotto al minimo? [X] Sì – si conserva solo il template matematico dell'impronta, non l'immagine.

3. Identificazione e valutazione dei rischi:

Rischio	Probabilità (1-3)	Gravità (1-3)	Livello Rischio
Furto del database biometrico	2	3	ALTO
Accesso non autorizzato ai template	1	3	MEDIO
Mancato funzionamento del sistema	2	1	BASSO

4. Misure di mitigazione adottate:

- I template biometrici sono conservati cifrati con AES-256 nel dispositivo (on-device), non nel cloud.
- In caso di malfunzionamento, il PIN numerico è disponibile come backup.
- Consenso esplicito dei dipendenti (ex Art. 9.2.a).

5. Rischio residuo e decisione:

Rischio residuo dopo le misure: BASSO – Si procede con il trattamento.

[Se rischio residuo ALTO: consultazione preventiva del Garante obbligatoria (Art. 36)]

Data DPIA: ... Approvata da Titolare: ... Parere DPO: ...

12 Capitolo 12: I Diritti degli Interessati – Come Gestirli Operativamente

Il GDPR attribuisce agli interessati (persone fisiche i cui dati sono trattati) una serie di diritti che il Titolare deve essere in grado di soddisfare **entro 30 giorni** dalla richiesta (proroga a 90 giorni nei casi complessi, con comunicazione scritta).

Diritto (Articolo)	Contenuto	Come gestirlo operativamente
Accesso (Art. 15)	Sapere se i propri dati sono trattati e riceverne copia	Predisporre modulo interno per l'estrazione dei dati dall'IT
Rettifica (Art. 16)	Correggere dati inesatti	Procedura di aggiornamento in tutti i sistemi (CRM, gestionale, ecc.)
Cancellazione (Art. 17)	“Diritto all’Oblio”: eliminare i dati quando non servono più	Verifica degli obblighi legali che possono impedire la cancellazione (fatture 10 anni, contenzioso in corso)
Limitazione (Art. 18)	Bloccare il trattamento in attesa di una verifica	“Congelare” il record nel sistema: non cancellare, non usare
Portabilità (Art. 20)	Ricevere i propri dati in formato machine-readable	Esportare in CSV/JSON dal CRM o gestionale
Opposizione (Art. 21)	Opporsi al trattamento per legittimo interesse	Valutare se esistono ragioni imperative per continuare; bloccare il marketing immediatamente
Non decisione automatizzata (Art. 22)	Non essere soggetto a decisioni solo algoritmiche con effetti significativi	Garantire l'intervento umano (human-in-the-loop)

Procedura Interna per la Gestione delle Richieste degli Interessati

PROCEDURA – GESTIONE DIRITTI INTERESSATI (ARTT. 15-22 GDPR)

1. Ricezione della richiesta:

- Canale ufficiale: email a [privacy@azienda.it].

- Verificare l'identità del richiedente (es. documento d'identità se la richiesta riguarda dati particolari).
- Protocollare la richiesta con numero progressivo e data di ricezione.

2. Valutazione (entro 5 giorni lavorativi):

- Il responsabile privacy verifica se la richiesta è soddisfacibile e se esistono eccezioni (es. obbligo legale di conservazione che impedisce la cancellazione).
- Se esistono dubbi, consulta il DPO (se presente) o un consulente legale.

3. Risposta (entro 30 giorni dalla ricezione):

- Risposta affermativa: eseguire quanto richiesto e inviare conferma scritta.
- Risposta negativa (motivata): comunicare per iscritto le ragioni e il diritto di proporre reclamo al Garante.
- Proroga a 90 giorni: comunicare entro 30 giorni le motivazioni della proroga.

4. Registrazione:

Ogni richiesta e il relativo esito vengono archiviati nel Registro Diritti Interessati per almeno 3 anni.

13 Capitolo 13: L'Evoluzione Normativa – Dalla NIS alla Direttiva NIS 2

13.1 13.1 Perché la NIS 2 Riguarda le Aziende

Mentre il GDPR protegge il dato personale come bene individuale, la **Direttiva NIS 2 (Direttiva UE 2022/2555)** protegge le **infrastrutture critiche** come bene collettivo. Le due normative sono complementari e, per molte aziende, si applicano entrambe.

La NIS 2 introduce una logica nuova: la **cybersicurezza come responsabilità strategica del Consiglio di Amministrazione**, non più solo dell'IT.

13.2 13.2 Chi Rientra nel Perimetro NIS 2

Soggetti Essenziali: Energia, trasporti, bancario, infrastrutture mercati finanziari, sanità, acqua potabile, acque reflue, infrastrutture digitali (IXP, DNS, cloud), pubblica amministrazione, spazio.

Soggetti Importanti: Servizi postali, gestione rifiuti, industria chimica, alimentare, dispositivi medici, computer e prodotti elettronici, fornitori servizi digitali (motori di ricerca, marketplace, social).

La bomba della Supply Chain: Le aziende in perimetro **devono imporre contrattualmente** requisiti di sicurezza ai propri fornitori, anche se questi sono PMI al di sotto delle soglie dimensionali NIS 2. Un piccolo studio software che fa manutenzione del gestionale di un ospedale deve rispettare i requisiti cyber imposti dall'ospedale.

13.3 13.3 Confronto GDPR vs NIS 2

Aspetto	GDPR	NIS 2
Tipo di norma	Regolamento UE (diretto)	Direttiva UE (recepimento nazionale)
Oggetto di protezione	Dati personali delle persone fisiche	Infrastrutture e servizi critici nazionali
Chi si applica	Chiunque tratti dati personali di persone UE	Medie e grandi imprese in settori critici
Responsabilità personale	Titolare e DPO	CEO e CDA (responsabilità personale)
Notifica incidenti	72 ore al Garante	24 ore (Early Warning) + 72 ore (notifica) + 1 mese (relazione finale)
Sanzione massima	20 Mln EUR o 4% fatturato globale	10 Mln EUR o 2% fatturato globale (Soggetti Essenziali)

13.4 13.4 Gli Obblighi Pratici NIS 2 (Art. 21)

1. **Politiche di analisi dei rischi e sicurezza dei sistemi informativi.**
2. **Gestione degli incidenti:** prevenzione, rilevamento, risposta e ripristino.
3. **Business Continuity:** backup, gestione delle crisi, ripristino in caso di disastro.
4. **Sicurezza della catena di approvvigionamento** (audit sui fornitori terzi).
5. **Sicurezza nell'acquisizione, sviluppo e manutenzione** dei sistemi informativi (incluse le vulnerabilità software).
6. **Politiche e procedure di valutazione dell'efficacia delle misure** (test, audit, penetration test).
7. **Igiene informatica di base e formazione** (corsi obbligatori per i dipendenti).
8. **Crittografia e sicurezza delle comunicazioni.**
9. **Sicurezza delle risorse umane:** vetting, procedure di revoca accessi, gestione delle separazioni.
10. **Uso di autenticazione multifattore (MFA)** e comunicazioni sicure.

13.5 13.5 La Novità delle Sanzioni NIS 2: Responsabilità Personale dei Dirigenti

La NIS 2 introduce la possibilità che gli organi di gestione (**CEO, CDA**) siano ritenuti **personalmente responsabili** e soggetti a **sospensione temporanea dall'incarico** se hanno trascurato o deliberatamente sottofinanziato la cybersicurezza. Non è più una responsabilità aziendale astratta: è una responsabilità personale dell'amministratore.

14 Capitolo 14: Formazione e Cultura della Privacy in Azienda

14.1 14.1 Perché la Formazione è una Misura di Sicurezza

Il 95% dei data breach ha un elemento di errore umano (fonte: Verizon DBIR 2024). La tecnologia da sola non è sufficiente. L'Art. 32 GDPR cita esplicitamente le **misure organizzative**, e la formazione del personale è la misura organizzativa per eccellenza.

14.2 14.2 Piano Formativo Minimo Annuale

Modulo	Contenuto	Target	Durata
Modulo 1 – Base GDPR	Principi Art. 5, diritti degli interessati, cosa NON fare	Tutti i dipendenti	2h
Modulo 2 – Sicurezza IT	Password, phishing, BYOD, gestione USB	Tutti i dipendenti	2h
Modulo 3 – Data Breach	Come riconoscere un incidente e a chi segnalarlo	Tutti i dipendenti	1h
Modulo 4 – Avanzato	DPIA, Art. 32, DPA, NIS 2	Managers, IT, HR, Legal	4h
Simulazione Phishing	Email di phishing simulata; analisi dei click	Tutti i dipendenti	Mensile

Registro Presenze Corso Privacy – Modulo 1

REGISTRO PRESENZE FORMAZIONE PRIVACY

Data: Docente: Durata: 2 ore

Modulo: **Introduzione al GDPR per tutti i dipendenti**

N.	Nome e Cognome	Ruolo	Firma
1			
2			
3			
...			

Firma responsabile della formazione: Timbro aziendale:

15 Capitolo 15: Test Avanzato di Verifica (20 Domande a Risposta Multipla)

Questo modulo valuta le competenze giuridiche e IT apprese. Soltanto UNA delle quattro opzioni è corretta e legalmente inattaccabile. Non fare affidamento al semplice buon senso: la norma richiede conformità tecnica e letterale. Le soluzioni si trovano nel Capitolo 16.

Domanda 1. Un hacker buca il perimetro di un e-commerce. Esfiltra un database di 10.000 clienti contenente esclusivamente stringhe casuali di token di Pseudonimizzazione, senza sottrarre la tabella delle chiavi. Come classifica questa violazione l'Art. 34 del GDPR?

- A Va notificato ogni utente entro 72 ore via mail.
- B Rischio elevato; scatta la denuncia penale all'ENISA.
- C I dati esfiltrati sono inintelligibili. L'evento va registrato internamente ma non scatta l'obbligo di notifica agli utenti (rischio nullo/minimo).
- D La pseudonimizzazione annulla ogni giurisdizione del GDPR.

Domanda 2. Il Responsabile Marketing desidera proporre sconti ai clienti "silenti" da oltre tre anni usando il "Legittimo Interesse". È corretto?

- A Sì, purché ci sia il tasto "Unsubscribe".
- B No. Il soft-spam vale per clienti attivi. Tre anni di inattività supera il limite di data retention raccomandato dal Garante (max 24 mesi). Il dato andava già cancellato.
- C Sì, le aziende godono sempre del legittimo interesse per il marketing.
- D No, il legittimo interesse si usa solo per cybersecurity.

Domanda 3. Un'applicazione gestionale usa MD5 per il salvataggio delle password dei dipendenti. Come si definisce questa scelta?

- A Obsoleto e insicuro ("broken"): costituisce violazione delle misure tecniche dell'Art. 32.
- B Standard americano raccomandato ma superato in Europa.
- C Cifrario simmetrico a 256 bit, pienamente conforme.
- D Conforme se abbinato a certificato SSL.

Domanda 4. Da quale momento decorre il termine di 72 ore per la notifica al Garante (Art. 33)?

- A Dal momento dell'attacco ai server.
- B Dalla chiusura degli uffici del venerdì.
- C Dal momento in cui il Titolare acquisisce "ragionevole certezza" dell'avvenuta violazione.
- D Dalle ore 08:00 del lunedì lavorativo successivo.

Domanda 5. È lecito usare GPS sui veicoli aziendali per tracciare la velocità dei dipendenti e inviare lettere disciplinari?

- A Sì, la proprietà del mezzo è aziendale.
- B No; configura “controllo a distanza” vietato dallo Statuto dei Lavoratori senza accordo sindacale preventivo o autorizzazione ITL.
- C Sì, a patto che ci sia consenso scritto libero del dipendente.
- D Sì, il GDPR non norma i veicoli; basta la LIA.

Domanda 6. Diritto all’Oblio (Art. 17) in presenza di causa legale pendente contro l’utente:

- A Cancellazione istantanea entro 24 ore.
- B Il Titolare ignora l’email dell’utente.
- C Il diritto alla cancellazione cede quando i dati sono necessari all’azienda per “accertare o difendere un diritto in sede giudiziaria”: i dati vengono congelati in limitazione.
- D Si procede con crittografia escludendo avvocati e tribunale.

Domanda 7. Quale pratica di “Cookie Wall” è esplicitamente sanzionata dal Garante?

- A Banner con “Accetta Tutto” grande e “Prosegui Senza Accettare” chiaro e accessibile.
- B Obbligare l’utente ad accettare la profilazione di 300 vendor per leggere un articolo, senza reale alternativa di accesso.
- C Testo in font sans-serif leggibile.
- D Consenso separato per ogni voce tramite opt-in con caselle vuote.

Domanda 8. Un algoritmo AI per lo screening automatico dei CV per assunzioni dirigenziali: in quale classe di rischio rientra?

- A Basso rischio: i candidati hanno pubblicato i CV online.
- B Nessun rischio: la matematica è obiettiva.
- C Alto rischio inaccettabile: vietato categoricamente.
- D Alto rischio: impatti occupazionali elevati. Richiede DPIA, human-in-the-loop e auditing anti-bias.

Domanda 9. Quali soggetti esterni richiedono obbligatoriamente la nomina come Responsabile del Trattamento ex Art. 28?

- A Il corriere UPS.
- B Il fornitore cloud (AWS/Azure) e l’agenzia di email marketing che gestisce la piattaforma.
- C Il tecnico riparatore della macchina del caffè.

D I dipendenti interni di segreteria.

Domanda 10. Un backup differenziale su NAS mappato come unità Z: (sempre online) è adeguato ai sensi dell'Art. 32?

A Sì; facilita i ripristini rapidi.

B No. Viola la logica Air-gap: un Ransomware cifra in simultanea anche l'unità online, vanificando la disponibilità.

C Sì, se il NAS è di marchio enterprise certificato.

D Irrilevante se la mappa non è in Active Directory.

Domanda 11. In quale formato deve essere esportata la portabilità dei dati (Art. 20)?

A Solo PDF ad alta risoluzione.

B Formato proprietario cifrato.

C Formato SVG vettoriale.

D Formato strutturato, di uso comune e machine-readable (CSV, JSON, XML).

Domanda 12. Quale delle seguenti attività il DPO NON può svolgere senza configurare un conflitto di interessi?

A Decidere autonomamente dove posizionare i server, gestire il budget IT e assumere/licenziare il personale IT.

B Cooperare con il Garante durante le ispezioni.

C Effettuare audit interni di conformità privacy.

D Rilasciare pareri scritti sulle DPIA.

Domanda 13. Qual è la differenza fondamentale tra Direttiva UE e Regolamento UE?

A Le direttive sono retroattive e depenalizzanti.

B Le direttive richiedono leggi nazionali di recepimento; i regolamenti (GDPR, AI Act) sono direttamente vincolanti in tutti i 27 Paesi UE senza leggi-ponte.

C Le direttive abrogano il codice penale statale.

D Sono identici a parità di rango.

Domanda 14. Cosa significa Privacy By Design (Art. 25)?

A Progettazione grafica delle interfacce web con colori accessibili (WCAG).

B Il dovere degli ingegneri e sviluppatori di integrare tutele privacy nel codice sorgente e nell'architettura fin dalla fase di progettazione, prima di scrivere la prima riga di codice.

C Il logo di certificazione GDPR da inserire nel footer del sito.

D L'informativa privacy in dropdown obbligatoria sui form.

Domanda 15. Riguardo al BYOD (Bring Your Own Device) aziendale, quale affermazione è corretta?

- A È privo di restrizioni perché l'hardware appartiene al dipendente.
- B Il Titolare non ha responsabilità per i data breach su dispositivi personali.
- C Implica rischi operativi elevati e richiede containerizzazione MDM (es. Intune) per separare i dati aziendali da quelli personali.
- D Il dipendente deve consegnare le credenziali al DPO in base alla clausola ispettiva.

Domanda 16. Se la Polizia Postale richiede i log di navigazione a un provider tramite mandato dell'Autorità Giudiziaria, cosa fa il Titolare?

- A Richiede il consenso scritto dell'indagato.
- B Si oppone invocando l'Habeas Data europeo.
- C Invia tutto all'AGCOM prima di procedere.
- D Applica la deroga dell'Art. 6.1.c (obbligo di legge) e fornisce i log alla PG; se l'autorità impone il segreto istruttorio, il Titolare è vincolato a non informare l'interessato, non per scelta propria ma per obbligo di legge.

Domanda 17. Qual è il massimale sanzionatorio del GDPR per violazioni delle norme fondamentali (Art. 83.5)?

- A Massimo 20.000 euro o sequestro dei server.
- B 500.000 euro forfettario e arresti domiciliari.
- C Massimo 2% del fatturato globale.
- D Fino a 20 milioni di euro oppure, per le multinazionali, al 4% del fatturato mondiale annuo (il valore più alto tra i due).

Domanda 18. La Direttiva NIS 2 introduce una novità importante riguardo ai dirigenti aziendali:

- A Gli amministratori non rischiano sanzioni personali: l'IT è responsabilità dei sistemi.
- B Gli organi di gestione (CEO, CDA) possono essere ritenuti personalmente responsabili e sospesi dall'incarico se hanno omesso o sottofinanziato le misure di cybersecurity obbligatorie.
- C Riguarda solo ospedali e banche.
- D Obbliga i dirigenti a frequentare corsi di programmazione Python.

Domanda 19. La NIS 2 impone per la segnalazione degli incidenti:

- A Solo 72 ore, come il GDPR. Nessun doppio binario.
- B Un "Early Warning" entro 24 ore dalla conoscenza dell'incidente, seguito da notifica completa entro 72 ore e relazione finale entro 1 mese.

C Solo in caso di furto d'identità dei dirigenti.

D Fermo impianti entro 5 ore pena arresti.

Domanda 20. Come incide la NIS 2 sulle PMI fornitrici di aziende in perimetro NIS 2 (es. un piccolo studio IT che fornisce software a un ospedale)?

A Le PMI sono esonerate per favorire la startup economy.

B Le aziende essenziali e importanti imporranno contrattualmente a cascata requisiti cyber stringenti ai propri fornitori PMI, pena l'esclusione dalle gare. L'impatto NIS 2 si estende di fatto all'intero ecosistema della supply chain.

C Il rischio è delegato al fornitore indiano con clausola liberatoria.

D Le PMI devono stipulare assicurazioni Lloyd's e sono esentate dai patch di sicurezza.

16 Capitolo 16: Soluzioni del Test (Per il Docente)

- **D1:** [C] – La pseudonimizzazione con chiavi separate azzerà il rischio per gli interessati. Log obbligatorio; notifica agli utenti non obbligatoria (Art. 34.3.a).
- **D2:** [B] – 3 anni supera il limite di retention per il marketing. Il dato andava già cancellato. Il legittimo interesse non può “resuscitare” dati scaduti.
- **D3:** [A] – MD5 è “broken” dal 2004. La sua applicazione alle password viola l’Art. 32 (stato dell’arte).
- **D4:** [C] – Le 72 ore partono dalla “ragionevole certezza”, non dall’attacco (che potrebbe essere rimasto latente mesi).
- **D5:** [B] – GPS per controllo disciplinare = controllo a distanza vietato dall’Art. 4 Statuto Lavoratori. Serve accordo sindacale o autorizzazione ITL.
- **D6:** [C] – Il diritto all’oblio (Art. 17) cede al diritto di difesa in giudizio (eccezione letterale dell’Art. 17.3.e).
- **D7:** [B] – Il Cookie Wall che blocca l’accesso senza consenso è Dark Pattern sanzionato. Il consenso non è libero (Art. 7.4).
- **D8:** [D] – L’AI per l’assunzione è alto rischio DPIA (Art. 35 + lista Garante), richiede human-in-the-loop (Art. 22), audit anti-bias.
- **D9:** [B] – Il fornitore cloud e l’agenzia email trattano dati per conto del Titolare: sono Data Processor ex Art. 28 e il DPA è obbligatorio.
- **D10:** [B] – NAS online mappato = nessun Air-gap = Ransomware infetta anche il backup. Viola Art. 32 (disponibilità/resilienza).
- **D11:** [D] – Portabilità (Art. 20): formato strutturato, machine-readable (CSV, JSON, XML) per garantire interoperabilità.
- **D12:** [A] – Il DPO non può decidere mezzi e finalità del trattamento né gestire budget IT: conflitto di interessi (Art. 38.6).
- **D13:** [B] – I Regolamenti (GDPR, AI Act, NIS 2) sono direttamente applicabili senza legge nazionale. Le Direttive richiedono recepimento.
- **D14:** [B] – Privacy By Design (Art. 25): tutele privacy integrate nel codice sorgente e nell’architettura IT fin dalla progettazione.
- **D15:** [C] – BYOD richiede containerizzazione MDM (Intune/Knox) per separare il perimetro aziendale da quello personale.
- **D16:** [D] – Mandato giudiziario: si applica l’Art. 6.1.c (obbligo di legge), si forniscono i log senza preavviso all’indagato se richiesto.
- **D17:** [D] – Massimale Art. 83.5: 20 Mln EUR o 4% fatturato mondiale annuo (il valore più alto).

- **D18:** [B] – NIS 2: responsabilità personale del CDA/CEO per omissioni di cybersecurity. Possibile sospensione dall'incarico.
- **D19:** [B] – NIS 2: Early Warning 24h + notifica completa 72h + relazione finale 1 mese. Più stringente del GDPR.
- **D20:** [B] – NIS 2 a cascata: le grandi aziende in perimetro impongono contrattualmente requisiti cyber ai fornitori PMI.

17 Capitolo 17: Glossario Normativo e Riferimenti Ufficiali

17.1 17.1 Glossario Tecnico-Legale

Accountability	Responsabilizzazione. Obbligo di dimostrare proattivamente, con documenti e log, la conformità al GDPR <i>prima</i> delle ispezioni.
AI Act	Regolamento (UE) 2024/1689. Classifica i sistemi AI per livelli di rischio (inaccettabile, alto, limitato, minimo). Sistemi ad alto rischio richiedono DPIA e registrazione in un database europeo.
Air-gap	Isolamento fisico di un sistema dalla rete. Un backup air-gap non è collegato alla rete aziendale e non può essere cifrato da un Ransomware.
Anonimizzazione	Processo <i>irreversibile</i> di rimozione di tutti gli elementi identificativi. Il dato anonimizzato esce dalla giurisdizione del GDPR. Diversa dalla pseudonimizzazione.
BCP	Business Continuity Plan. Piano che descrive come l'azienda continua a operare durante un disastro (es. lavorare su carta durante un blocco IT).
BYOD	Bring Your Own Device. Policy che consente ai dipendenti di usare dispositivi personali per il lavoro. Richiede containerizzazione MDM per isolare i dati aziendali.
CIA	Triade Confidentiality–Integrity–Availability: il modello di riferimento della sicurezza delle informazioni, richiamato dall'Art. 32 GDPR.
CSIRT	Computer Security Incident Response Team. Ente governativo nazionale a cui le aziende in perimetro NIS 2 devono segnalare gli incidenti significativi entro 24 ore.
Dark Pattern	Interfaccia di design creata per ingannare l'utente (es. rendere il rifiuto dei cookie più difficile dell'accettazione). Viola il principio di correttezza dell'Art. 5.
Data Breach	Violazione di sicurezza che comporta la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso non autorizzato ai dati personali.
DPIA	Data Protection Impact Assessment. Analisi preventiva dei rischi privacy richiesta dall'Art. 35 per trattamenti ad alto rischio.
DPA	Data Processing Agreement. Contratto obbligatorio tra Titolare e Responsabile esterno del trattamento (Art. 28). Contiene le 8 clausole obbligatorie.

DPO	Data Protection Officer. Figura professionale indipendente con compiti di supervisione e consulenza privacy. Obbligatoria per enti pubblici e chi tratta dati sanitari su larga scala.
DRP	Disaster Recovery Plan. Piano di ripristino dei sistemi IT dopo un incidente.
EDPB	European Data Protection Board. Organismo europeo che riunisce i Garanti nazionali e emette linee guida vincolanti.
Habeas Data	Principio secondo cui ogni individuo ha il diritto di controllare le informazioni che lo riguardano (analogo all'Habeas Corpus per la libertà fisica).
LIA	Legitimate Interest Assessment. Documento interno di bilanciamento richiesto prima di usare il legittimo interesse come base giuridica (Art. 6.1.f).
MDM	Mobile Device Management. Sistema software centralizzato per la gestione e il controllo dei dispositivi mobili aziendali (es. Microsoft Intune, VMware Workspace ONE).
MFA	Multi-Factor Authentication. Autenticazione a più fattori (password + OTP/token/biometria). Standard minimo per accessi critici.
NIS 2	Direttiva UE 2022/2555 sulla sicurezza delle reti e dei sistemi informativi. Estende gli obblighi di cybersicurezza a settori critici con responsabilità personale dei dirigenti.
PoLP	Principle of Least Privilege. Ogni utente accede solo alle risorse strettamente necessarie per il proprio ruolo.
Pseudonimizzazione	Sostituzione degli identificativi diretti (nome, CF) con token. I dati rimangono personali (art. 4) ma il rischio di data breach è ridotto.
RBAC	Role-Based Access Control. Sistema di controllo degli accessi basato sui ruoli aziendali. Implementa il PoLP.
RPO	Recovery Point Objective. Quantità massima di dati che si può accettare di perdere in caso di incidente (es. "non più di 4 ore").
RTO	Recovery Time Objective. Tempo massimo accettabile di interruzione del servizio prima del ripristino (es. "entro 8 ore").
Salt	Stringa casuale univoca aggiunta alla password prima del calcolo dell'hash. Rende inefficaci le Rainbow Tables.
SIEM	Security Information and Event Management. Sistema centralizzato di raccolta e analisi dei log di sicurezza.

TLS	Transport Layer Security. Protocollo di cifratura per le comunicazioni in rete (HTTPS, email sicura). Versione minima consigliata: TLS 1.3.
WORM	Write Once Read Many. Tecnologia di storage che impedisce la modifica o cancellazione dei dati scritti. Usata per i log legali.

17.2 17.2 Riferimenti Ufficiali e Webgrafia

- Testo ufficiale GDPR (Eur-Lex): <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- Direttiva NIS 2 integrale: <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32022L2555>
- AI Act (Regolamento UE 2024/1689): <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32024R1689>
- Garante Privacy italiano: <https://www.garanteprivacy.it>
- ACN – Agenzia per la Cybersicurezza Nazionale: <https://www.acn.gov.it>
- EDPB – Linee Guida e Giurisprudenza: <https://edpb.europa.eu>
- ENISA – Agenzia UE per la Cybersicurezza: <https://www.enisa.europa.eu>
- Portale Notifica Data Breach Garante: <https://www.garanteprivacy.it/web/guest/home/docweb/-/docweb-display/docweb/9126694>
- NIST SP 800-63B (Linee Guida Password): <https://pages.nist.gov/800-63-4/>
- EDPB Linee Guida 3/2019 (Videosorveglianza): https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-32019-processing-personal-data-through-video_it
- Linee Guida WP248 (DPIA): https://edpb.europa.eu/our-work-tools/our-documents/wp29-guidelines/guidelines-privacy-impact-assessment_it
- Elenco DPIA obbligatorie – Garante italiano: <https://www.garanteprivacy.it/documents/10160/0/Provvedimento+n.+467+dell%2711+ottobre+2018.pdf>

18 Capitolo 18: Cybersecurity Avanzata per Ambienti IT Aziendali

18.1 18.1 Architettura di Rete Sicura: la Segmentazione VLAN

Una rete aziendale piatta (flat) è come un open space senza porte: se un dipendente apre un'email di phishing, il malware si propaga all'intera rete in pochi secondi. La **segmentazione di rete tramite VLAN** è la misura tecnica più efficace e relativamente economica per contenere i danni di una compromissione.

VLAN	Dispositivi	Regole di accesso
VLAN 10 – Uffici	PC dipendenti, stampanti	Accesso internet + server interni. Nessun accesso a VLAN Produzione.
VLAN 20 – Server	File server, Active Directory, DB	Solo da VLAN Uffici e VLAN Gestione IT.
VLAN 30 – Produzione/OT	PLC, robot, SCADA, HMI	ISOLATA. Nessun accesso internet. Solo traffico autorizzato da/verso VLAN Server.
VLAN 40 – Guest Wi-Fi	Smartphone personali, PC visitatori	Solo internet. Nessuna risorsa interna.
VLAN 50 – Gestione IT	PC sysadmin, jump server	Accesso a tutte le VLAN solo per manutenzione, con MFA obbligatoria.
VLAN 60 – IoT	Telecamere IP, badge reader	Isolata. Solo verso server videosorveglianza.

Nota Pratica

Nota per ambienti OT/industriali: La VLAN Produzione (PLC, robot, SCADA) deve essere completamente separata dalla rete uffici. Un Ransomware che cifra l'Active Directory non deve raggiungere i controlli dei macchinari. Questa separazione è requisito NIS 2 per gli impianti di produzione in settori critici.

18.2 18.2 Gestione degli Accessi Privilegiati (PAM)

Gli account amministratori (“admin”, “root”, “Administrator”) sono il bersaglio preferito dagli attaccanti. Una compromissione di un account privilegiato equivale a consegnare le chiavi dell'intera infrastruttura.

Principi del Privileged Access Management:

1. **Doppio account per i sysadmin:** Uno standard (per email, navigazione) e uno privilegiato (solo per attività di amministrazione).
2. **Just-in-Time Access:** I privilegi sono concessi solo quando servono e solo per il tempo necessario.
3. **Audit completo:** Ogni accesso con account admin è loggato con timestamp, IP sorgente e comandi eseguiti.
4. **Password vault:** Le credenziali degli account di servizio sono conservate in un Password Manager centralizzato (es. HashiCorp Vault, CyberArk) e ruotate automaticamente.

18.3 18.3 Vulnerability Management e Patch Management

Le vulnerabilità software non patchate sono la principale via di ingresso dei criminali informatici. L'attacco WannaCry del 2017 che paralizzò ospedali e fabbriche in tutto il mondo sfruttava una vulnerabilità di Windows per cui Microsoft aveva rilasciato la patch *due mesi prima*. Chi non aveva aggiornato era esposto.

Step	Attività	Note
1	Inventario asset	Elenco aggiornato di tutti i dispositivi hardware e software.
2	Monitoraggio CVE	Iscrizione ai bollettini di sicurezza dei vendor (Microsoft MSRC, Cisco PSIRT, ecc.).
3	Classificazione patch	CVSS ≥ 9.0 (Critica): 48 ore. Alta (7-9): 7 giorni. Media/Bassa: 30 giorni.
4	Test in staging	Applicare la patch in ambiente di test prima della produzione.
5	Deploy e verifica	Applicazione in produzione (fuori orario); verifica del funzionamento.

18.4 18.4 Incident Response: Gestire un Attacco in Modo Strutturato

Le 6 fasi del framework NIST SP 800-61:

Fase	Nome	Attività
1	Preparation	Redigere e testare l'IR Plan. Formare il team. Avere i contatti pronti: DPO, legale, CSIRT, assicurazione.
2	Identification	Rilevare e confermare l'incidente. Chi ha segnalato? Quando? Quali sistemi sono coinvolti?
3	Containment	Isolare i sistemi compromessi. NON spegnere i server (si perdono le prove in memoria volatile).
4	Eradication	Rimuovere la causa (malware, backdoor, account compromesso). Identificare il vettore di ingresso.
5	Recovery	Ripristinare da backup puliti. Verificare l'integrità. Monitorare intensivamente.
6	Lessons Learned	Report post-incidente entro 2 settimane. Aggiornare le procedure per prevenire il ripetersi.

Checklist Risposta Ransomware – Fasi 2 e 3

CHECKLIST RISPOSTA IMMEDIATA A RANSOMWARE

Entro i primi 30 minuti:

- ☐ Identificare i sistemi con file cifrati (estensione insolita, wallpaper cambiato).
- ☐ **NON riavviare** i sistemi compromessi (si perdono prove in RAM).
- ☐ Staccare fisicamente gli switch di accesso per isolare la rete.
- ☐ Avvisare immediatamente il responsabile IT e il Titolare.
- ☐ Avvisare il DPO per valutare l'obbligo di notifica al Garante (72 ore).
- ☐ **NON pagare il riscatto** senza aver consultato le forze dell'ordine.

Entro le prime 4 ore:

- ☐ Verificare lo stato dei backup (integri? Quando risale l'ultimo?).
- ☐ Copia forense delle macchine compromesse (immagine del disco).
- ☐ Denuncia alle forze dell'ordine (Polizia Postale).
- ☐ Se in perimetro NIS 2: Early Warning al CSIRT nazionale entro 24 ore.
- ☐ Preparare la notifica al Garante (deve partire entro 72 ore se c'è rischio per i dati personali).

18.5 18.5 Phishing e Social Engineering: il Principale Vettore di Attacco

Il 95% degli attacchi informatici include un elemento di errore umano. Il phishing è la tecnica più comune.

Tipologie di phishing:

- **Phishing generico:** Email di massa con mittente falsificato. Facilmente riconoscibile.
- **Spear Phishing:** Email personalizzata. Il criminale ha studiato la vittima sui social e conosce nome del capo, colleghi, progetti in corso.
- **Whaling:** Spear phishing mirato ai vertici (CEO, CFO). Simula comunicazioni urgenti tra dirigenti (Business Email Compromise – BEC).
- **Smishing:** Phishing via SMS.
- **Vishing:** Phishing via telefonata.

7 segnali di riconoscimento di un'email di phishing:

1. Il mittente usa un dominio simile ma non identico (es. `amazon-servizi.com` invece di `amazon.it`).
2. Il testo crea urgenza artificiale (“Il tuo account sarà chiuso entro 24 ore!”).
3. Il link visibile è diverso dalla destinazione reale (passa il mouse sopra senza cliccare).
4. Presenza di allegati non richiesti (ZIP, .xlsm, .docm con macro).
5. Saluto generico (“Gentile Cliente” invece del tuo nome).
6. Richiesta di credenziali o dati bancari via email.
7. Errori grammaticali o ortografici (sempre meno frequenti con l’AI generativa).

19 Capitolo 19: Il Trattamento dei Dati del Personale – Approfondimento

Il rapporto di lavoro genera un flusso continuo di dati personali, inclusi dati particolari (sanitari, sindacali). Il Titolare-datore di lavoro si trova in una posizione di asimmetria contrattuale rispetto al dipendente, il che impone regole più rigide.

19.1 19.1 Il Ciclo di Vita del Dato Dipendente

Fase	Dati trattati	Note compliance
Selezione (CV)	Nome, recapiti, esperienze, foto (se allegata)	Informativa candidato obbligatoria. Retention massima: 12 mesi. Vietato chiedere stato di salute o gravidanza preventivamente.
Assunzione	Documenti identità, CF, residenza, IBAN, titolo di studio	Informativa Art. 13 firmata prima dell'avvio del rapporto.
In forza	Presenze, buste paga, valutazioni performance, certificati medici	Dati sanitari (Art. 9): accesso limitato a HR strettamente necessario.
Formazione	Partecipazione corsi, attestati, valutazioni	Conservazione per tutta la durata del rapporto + 5 anni.
Disciplinare	Contestazioni, sanzioni, procedimenti	Solo chi ne ha necessità operativa. Conservazione: 5 anni post-procedimento.
Cessazione	Data fine rapporto, causale, TFR erogato, referenze	Dati fiscali: 10 anni. Dati TFR: fino a prescrizione previdenziale.

19.2 19.2 Il Medico Competente e la Sorveglianza Sanitaria

Il Medico Competente è il Titolare autonomo del trattamento dei dati sanitari dei lavoratori ai fini della sorveglianza sanitaria (D.Lgs. 81/2008). Il datore di lavoro riceve solo il **giudizio di idoneità** (idoneo / idoneo con limitazioni / non idoneo), non la diagnosi.

Attenzione – Violazione Comune

Violazione frequente: Il responsabile HR che chiede al medico competente la diagnosi (“Perché Tizio è non idoneo?”) commette una violazione del divieto di trattare dati sanitari senza base giuridica. L’HR conosce solo il *giudizio*, non la *patologia*.

19.3 19.3 Il Controllo a Distanza dei Lavoratori: i Limiti dell’Art. 4 Statuto

Cosa è consentito SENZA accordo sindacale:

- Log di utilizzo degli strumenti aziendali (PC, badge, software gestionale) per finalità di sicurezza IT e tutela del patrimonio, con informativa precisa.
- Videosorveglianza di aree senza presenza stabile dei lavoratori (magazzini automatizzati, ingressi).

Cosa richiede SEMPRE accordo sindacale o autorizzazione ITL:

- Geolocalizzazione GPS dei dipendenti (inclusi i veicoli per controllo disciplinare).
- Screenshot automatici, keylogger, monitoraggio permanente dello schermo.
- Controllo del traffico internet dei singoli dipendenti (log di navigazione individuali dettagliati).
- Badge di prossimità che tracciano i movimenti in tempo reale all’interno dell’edificio.

Lettera Informativa Strumenti Informatici ex Art. 4 Statuto

INFORMATIVA SULL’USO DEGLI STRUMENTI INFORMATICI AZIENDALI

Ai sensi dell’Art. 4, L. 300/1970 e Art. 13 GDPR

Con la presente, [Nome Azienda] La informa che gli strumenti informatici aziendali (PC, smartphone, account email, VPN) producono dati di funzionamento (log di accesso, log di rete, log applicativi) che vengono conservati per le seguenti finalità:

- Sicurezza informatica: rilevamento di intrusioni, anomalie e utilizzi non autorizzati.
- Tutela del patrimonio aziendale: prevenzione di furti, danneggiamenti o usi impropri.
- Adempimenti di legge: conservazione dei log richiesta da normative (es. NIS 2).

I log conservati non includono il contenuto delle comunicazioni personali. L’accesso ai dati di dettaglio avviene solo in caso di sospetto illecito, con autorizzazione del Titolare, nel rispetto del Provvedimento Garante del 01/03/2007.

Conservazione: I log sono conservati per 6 mesi e poi cancellati automaticamente.

Firma per presa visione: Data:

20 Capitolo 20: Il Sito Web Aziendale – Compliance Digitale Completa

20.1 20.1 La Privacy Policy del Sito Web

La Privacy Policy deve essere accessibile da ogni pagina del sito (tipicamente nel footer) e aggiornata ogni volta che cambiano gli strumenti usati (nuovo plugin, nuovo servizio di analytics, chatbot).

Contenuto minimo della Privacy Policy:

- Chi è il Titolare e come contattarlo.
- Quali dati raccoglie il sito (dati di navigazione, form contatto, newsletter).
- Finalità e basi giuridiche.
- Cookie e servizi terze parti (Google Analytics, chatbot, ecc.) con eventuale trasferimento extra-UE.
- Periodo di conservazione.
- Diritti degli utenti e come esercitarli.
- Data dell'ultimo aggiornamento.

20.2 20.2 La Cookie Policy e il Banner Cookie

Il Garante italiano ha emanato le Linee Guida Cookie nel 2021 (aggiornate nel 2022) con requisiti precisi.

Classificazione dei cookie:

Tipo		Consenso necessario	Esempi
Tecnici (navigazione)		NO	Cookie di sessione, carrello, preferenze lingua
Analytics parte anonimizzati	prima	NO (con misure)	GA4 con IP anonimizzato; Plausible Analytics
Analytics parte	terza	SÌ	Google Analytics con User-ID; Adobe Analytics
Profilazione pubblicitaria	pub-	SÌ	Facebook Pixel; Google Ads; cookie retargeting
Social plugin		SÌ	Pulsanti “Like” Facebook; widget Twitter incorporati

Requisiti del banner cookie (Linee Guida Garante 2021):

1. Il banner deve contenere un pulsante “**Accetta tutti**” e un pulsante “**Rifiuta tutti**” (o “Continua senza accettare”) di *uguale evidenza grafica*.
2. Il pulsante di rifiuto non può essere nascosto in menu secondari.
3. Prima del consenso, nessun cookie non tecnico deve essere depositato.
4. La scelta deve essere registrata e resistere alla navigazione (il banner non riappare ad ogni visita).
5. L’utente deve poter modificare le scelte in qualsiasi momento (link “Impostazioni cookie” nel footer).

20.3 20.3 Google Analytics e il Trasferimento Extra-UE

Google Analytics (in tutte le versioni) trasferisce dati negli USA. Con il Data Privacy Framework del 2023, i trasferimenti verso USA con fornitori certificati (Google lo è) sono di nuovo leciti. Per una compliance ancora più solida: considerare soluzioni di analytics ospitate in UE come **Matomo** (self-hosted) o **Plausible Analytics** (senza cookie, nessun consenso richiesto).

21 Capitolo 21: Casi Pratici – Sanzioni e Sentenze Reali, con Fonti Verificate

Nota Pratica

Nota per lo studente: A differenza della prima edizione di questo materiale, ogni caso qui riportato è stato verificato contro il provvedimento o la sentenza originale, con numero identificativo e link alla fonte. Dove un dettaglio non era reperibile con certezza, è stato omesso piuttosto che stimato. Si raccomanda comunque di consultare il testo integrale del provvedimento citato prima di usarlo come riferimento in un contesto professionale, poiché i provvedimenti possono essere oggetto di ricorso e revisione.

21.1 21.1 Caso 1 – Marketing via SMS ed Email Dopo l’Opposizione dell’Interessato (Verisure Italia, 2025)

Fatto: Il Garante ha avviato un’istruttoria a seguito del reclamo di un ex cliente che continuava a ricevere SMS promozionali nonostante avesse esercitato il diritto di opposizione, e della segnalazione di un potenziale cliente che, dopo aver richiesto un preventivo online, aveva iniziato a ricevere telefonate, email e SMS pubblicitari. Gli accertamenti hanno rilevato che la società gestiva le richieste di opposizione con ritardo, oltre i termini previsti dal Regolamento, e che il consenso per il marketing diretto raccolto tramite il form del sito era di fatto accorpato alla richiesta di preventivo, senza un’informativa adeguata.

Decisione: Il Garante ha sanzionato Verisure Italia per **400.000 euro**, vietando l’ulteriore trattamento dei dati acquisiti illecitamente.

Lezione: Il consenso per finalità di marketing deve essere distinto e separato dalla richiesta del servizio principale (qui, il preventivo). Le richieste di opposizione al trattamento vanno gestite entro i termini di legge: il ritardo nella gestione, da solo, è già una violazione autonoma.

Fonte: Newsletter del Garante per la Protezione dei Dati Personali, 17 dicembre 2025 – <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/10202719>

21.2 21.2 Caso 2 – Videosorveglianza in Assenza di Accordo Sindacale (H&M Hennes & Mauritz S.r.l., 2023)

Fatto: A seguito della segnalazione di un sindacato, il Garante ha accertato che la catena di abbigliamento aveva installato sistemi di videosorveglianza in numerosi punti vendita, con almeno tre telecamere attive 24 ore su 24, 7 giorni su 7, in aree riservate ai lavoratori e ai fornitori. Le immagini venivano conservate per oltre 24 ore, contrariamente a quanto previsto dal regolamento interno e dall’informativa disponibile al personale. L’installazione non era stata preceduta da un accordo con le rappresentanze sindacali né da un’autorizzazione dell’Ispettorato del Lavoro, come richiesto dall’Art. 4 dello Statuto dei Lavoratori.

Decisione: Provvedimento del 2 marzo 2023 (doc. web n. 9880398): sanzione di **50.000 euro**, tenuto conto del numero rilevante di dipendenti coinvolti (oltre 500) e della pluralità di punti vendita interessati.

Lezione: L'affissione di cartelli informativi non è sufficiente a rendere lecita la videosorveglianza sul luogo di lavoro: l'accordo sindacale (o, in mancanza, l'autorizzazione dell'Ispettorato del Lavoro) è una condizione di liceità autonoma e non sostituibile con la sola trasparenza informativa.

Fonte: Garante Privacy, Provvedimento n. 9880398 del 2 marzo 2023; Federprivacy, “Videosorveglianza nei luoghi di lavoro” – <https://www.federprivacy.org/informazione/primo-piano/videosorveglianza-nei-luoghi-di-lavoro-l-accordo-sindacale-o-l-autorizzazione-dell-ispettorato-sono-imprescindibili-condizioni-di-legittimita-del-trattamento>

21.3 21.3 Caso 3 – Valutazione Errata del Rischio e Mancata Notifica (Humanitas Mirasole S.p.A., 2025)

Fatto: A seguito della distruzione accidentale di un campione di tessuto associato all'identità di una paziente, la struttura sanitaria ha classificato l'incidente come “basso rischio” per i diritti e le libertà dell'interessata, decidendo di non notificarlo al Garante. L'Autorità ha ritenuto errata questa valutazione, sottolineando che la perdita di un dato sanitario riferibile a una persona identificata comporta di per sé un rischio non trascurabile, anche in assenza di esfiltrazione verso terzi.

Decisione: Provvedimento n. 587 del 9 ottobre 2025: sanzione complessiva di **70.000 euro**, di cui 20.000 euro specificamente riferiti alla mancata notifica ex Art. 33.

Lezione: La valutazione del rischio che precede la decisione di notificare (o non notificare) un data breach non è discrezionale: deve essere documentata e deve tenere conto della natura dei dati coinvolti. Una valutazione errata costituisce una violazione autonoma e separata, sanzionabile anche se l'incidente di per sé non comporta esfiltrazione verso l'esterno.

Fonte: Avvocati Tech, “Data breach GDPR: cosa fare (e cosa non fare) nelle prime 72 ore”, con riferimento al Provvedimento del Garante n. 587 del 9 ottobre 2025 – <https://www.avvocatitech.com/data-breach-gdpr-cosa-fare-e-cosa-non-fare-nelle-prime-72-ore/>

21.4 21.4 Caso 4 – Password in Chiaro e Hashing Obsoleto (The European House – Ambrosetti S.p.A., 2026)

Fatto: A seguito di una violazione di dati personali notificata dalla società nell'aprile 2024 (originata da una vulnerabilità di tipo SQL injection), l'istruttoria del Garante ha accertato che, su un totale di 61.670 interessati coinvolti, circa 36.000 password risultavano conservate *interamente in chiaro*, senza alcuna protezione crittografica, mentre circa 98.000 erano protette con hashing MD5 – algoritmo che l'Autorità ha definito non più adeguato allo stato dell'arte. La società conservava inoltre credenziali relative a sistemi

dismissi tra il 2020 e il 2022, in violazione del principio di limitazione della conservazione. È inoltre emerso un ritardo ingiustificato nella comunicazione della violazione agli interessati, motivato (secondo quanto rilevato dall'Autorità) anche da preoccupazioni di natura reputazionale.

Decisione: Provvedimento n. 280/2026: sanzione di **85.000 euro** per violazione degli Artt. 5, 32 e 34 del GDPR.

Lezione: Il Garante ha esplicitamente chiarito che le esigenze reputazionali di un'organizzazione non possono prevalere sui diritti delle persone coinvolte nella decisione di comunicare (o meno) una violazione. Inoltre, la responsabilità per misure di sicurezza inadeguate resta in capo al Titolare anche quando i sistemi erano gestiti da fornitori terzi.

Fonte: Federprivacy, "Il Garante Privacy sanziona The European House Ambrosetti per 85mila euro" – <https://www.federprivacy.org/informazione/garante-privacy/il-garante-privacy-sanziona-the-european-house-ambrosetti-per-85mila-euro-a-seguito-di-un-data-breach-che-aveva-coinvolto-61-670-persone>; Altalex, analisi del Provvedimento n. 280/2026 – <https://www.altalex.com/documents/news/2026/05/29/privacy-reputazione-strategia-silenzio-data-breach-costa-85000-euro-ambrosetti>

21.5 21.5 Caso 5 – App di Monitoraggio Imposte su Dispositivi Personali (Ares Capital S.A., AEPD Spagna)

Fatto: L'Autorità spagnola per la Protezione dei Dati (AEPD) ha accertato che una società di trasporto privato con conducente obbligava i propri dipendenti-autisti a installare fino a quattro applicazioni di monitoraggio sui rispettivi dispositivi mobili personali. Le applicazioni consentivano la raccolta sistematica e continua di geolocalizzazione in tempo reale, messaggi, chiamate, fotografie, registrazioni audio e video, e dati relativi allo stato fisico e di salute dei conducenti. Ai dipendenti era inoltre vietato modificare qualsiasi impostazione o permesso delle applicazioni installate.

Decisione: L'AEPD ha sanzionato Ares Capital S.A. per **200.000 euro**, per violazione del principio di minimizzazione, assenza di una valida base giuridica e carenza di trasparenza informativa verso i lavoratori.

Lezione: In un contesto BYOD, l'azienda non può imporre strumenti di sorveglianza che raccolgono dati ben oltre quanto necessario per la finalità lavorativa dichiarata, specialmente quando incidono sulla sfera privata del dipendente (geolocalizzazione continua, dati sulla salute) e gli viene impedito qualsiasi controllo sulle impostazioni di privacy del proprio dispositivo.

Fonte: Federprivacy, "BYOD e app di monitoraggio in azienda: rischi e misure organizzative" – <https://www.federprivacy.org/informazione/primo-piano/byod-e-app-di-monitoraggio-in-azienda-rischi-e-misure-organizzative>

21.6 21.6 Caso 6 – Cookie e Dark Pattern (Google LLC, CNIL Francia, 2021/2022)

Fatto: La CNIL (l'Autorità francese di protezione dei dati) ha accertato che sui siti `google.fr` e `youtube.com` il processo per rifiutare i cookie non tecnici era significativamente più complesso di quello per accettarli: l'utente poteva accettare tutti i cookie con un solo clic, mentre il rifiuto richiedeva di navigare attraverso più finestre di dialogo e diversi clic aggiuntivi.

Decisione: Con deliberazione del 31 dicembre 2021 (resa nota il 6 gennaio 2022), la CNIL ha sanzionato Google LLC e Google Ireland Limited per **150 milioni di euro**, con un provvedimento gemello che ha sanzionato Facebook Ireland Limited (oggi Meta) per **60 milioni di euro** per la medesima condotta sui propri siti. Entrambe le società hanno ricevuto 3 mesi di tempo per correggere i propri banner, pena una sanzione aggiuntiva di 100.000 euro per ogni giorno di ritardo.

Lezione: Il principio di parità (“simmetria”) tra accettazione e rifiuto dei cookie non è una linea guida informale: è un requisito di legge la cui violazione è sanzionabile anche per le aziende più grandi al mondo, e l'importo della sanzione viene calibrato anche sulla scala del trattamento e sui ricavi pubblicitari generati indirettamente dal meccanismo contestato.

Nota Pratica

Aggiornamento: Il tema dei cookie e della pubblicità mirata resta sotto stretto controllo della CNIL: nel 2025 l'Autorità francese ha sanzionato nuovamente Google per 325 milioni di euro (per pubblicità mostrata in Gmail e cookie installati senza consenso adeguato durante la creazione dell'account) e Shein per 150 milioni di euro per analoghe violazioni sui cookie di profilazione. Il principio giuridico è lo stesso del 2021: cambiano gli importi, non la regola.

Fonte: Federprivacy, “Sanzioni record per violazione della privacy con i cookie” – <https://www.federprivacy.org/informazione/mondo/sanzioni-record-per-violazione-della-privacy-con-i-cookie-150-milioni-di-euro-a-google-e-100-milioni-a-facebook>; Cyber Security 360, “Cookie e dark pattern, sanzione privacy milionaria per Google e Facebook in Francia” – <https://www.cybersecurity360.it/legal/privacy-dati-personali/cookie-e-dark-pattern-sanzione-privacy-milionaria-per-google-e-facebook-in-francia-quale-lezione/>

21.7 21.7 Caso 7 – Una Vera Sentenza Giudiziaria: “Schrems II” (Corte di Giustizia dell’Unione Europea, 2020)

A differenza dei sei casi precedenti, che sono provvedimenti amministrativi delle Autorità di controllo, questo è un vero atto giudiziario: una sentenza della Corte di Giustizia dell’Unione Europea (CGUE), l'organo giudicante di ultima istanza per il diritto UE.

Il caso: Maximillian Schrems, attivista austriaco per la privacy, ha contestato la liceità del trasferimento dei suoi dati personali da Facebook Ireland a Facebook Inc. (USA), sostenendo che il diritto e le prassi statunitensi (in particolare i programmi di sorveglianza

governativa) non offrissero un livello di protezione equivalente a quello garantito nell'Unione Europea. Il caso, originato da un rinvio pregiudiziale della High Court irlandese, è giunto alla CGUE – Grande Sezione.

La sentenza: Causa **C-311/18**, “Data Protection Commissioner contro Facebook Ireland Limited e Maximillian Schrems”, decisa il **16 luglio 2020**. Il dispositivo della sentenza ha stabilito due principi fondamentali:

1. Ha **dichiarato invalida** la decisione di adeguatezza della Commissione Europea relativa al “Privacy Shield” (lo strumento che fino a quel momento autorizzava il libero trasferimento di dati personali dall'UE agli Stati Uniti), perché il diritto statunitense non garantiva, in materia di sorveglianza da parte delle autorità pubbliche, un livello di protezione sostanzialmente equivalente a quello dell'Unione.
2. Ha invece **confermato la validità in linea di principio** delle Clausole Contrattuali Tipo (Standard Contractual Clauses, SCC) come strumento di trasferimento, ma ha chiarito che il Titolare che le utilizza deve valutare *caso per caso* se le garanzie contrattuali siano effettivamente sufficienti rispetto al contesto giuridico del Paese di destinazione, ed eventualmente adottare misure supplementari.

Perché conta per le aziende: Questa sentenza ha avuto un effetto immediato su ogni azienda europea che usava servizi cloud statunitensi (l'effetto si estende, nel principio, a qualunque Paese terzo con problemi analoghi di sorveglianza). Ha reso necessaria la rinegoziazione delle garanzie contrattuali con i fornitori USA e ha portato, nel 2023, all'adozione del nuovo **Data Privacy Framework** (vedi Capitolo 25) come tentativo di fornire una base più solida ai trasferimenti USA-UE.

Fonte: Corte di Giustizia dell'Unione Europea, Sentenza nella causa C-311/18, 16 luglio 2020 – testo integrale su EUR-Lex; Garante Privacy Italia, pagina “Privacy Shield” – <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/5306161>; Wikipedia (IT), “Sentenze Schrems” – https://it.wikipedia.org/wiki/Sentenze_Schrems

21.8 21.8 Caso 8 – Quando la Sola Violazione del GDPR Non Basta per il Risarcimento (“Österreichische Post”, CGUE 2023)

Il caso: Un cittadino austriaco aveva fatto causa a Österreichische Post AG (il principale operatore postale austriaco), che – nell'ambito della propria attività di marketing – raccoglieva informazioni sulle affinità politiche della popolazione, definendo “indirizzi di gruppi target” tramite un algoritmo basato su criteri sociali e demografici. Il ricorrente, scoprendo che la società gli aveva attribuito una forte affinità con un determinato partito politico senza il suo consenso, ha chiesto un risarcimento per il danno immateriale subito, sostenendo che la sola violazione del GDPR fosse sufficiente a fondare il diritto al risarcimento.

La sentenza: Causa **C-300/21**, decisa il **4 maggio 2023**. La Corte ha chiarito due principi che hanno conseguenze pratiche dirette per ogni azienda che tratta dati personali:

1. Il diritto al risarcimento previsto dall'Art. 82 GDPR **non nasce dalla sola violazione** della normativa: sono necessarie tre condizioni cumulative – una violazione del Regolamento, un danno (materiale o immateriale) effettivamente subito, e un nesso di causalità tra la violazione e il danno. Un'azienda che ha violato una norma GDPR senza che ne sia derivato un danno concreto e provato a uno specifico interessato non è automaticamente esposta a un risarcimento verso quella persona.
2. Al tempo stesso, la Corte ha escluso che esista una **soglia minima di gravità** sotto la quale il danno immateriale non sia risarcibile: anche un danno di lieve entità (un cosiddetto “micro-danno”), se provato e collegato causalmente alla violazione, dà diritto al risarcimento.

Perché conta per le aziende: Questa sentenza disegna un equilibrio che le aziende devono comprendere bene: da un lato, non basta che un dipendente trovi un errore formale nel trattamento dei propri dati per pretendere un risarcimento (deve dimostrare un danno reale, anche minimo); dall'altro, l'azienda non può liquidare come “irrilevanti” le conseguenze pratiche delle proprie violazioni, perché qualsiasi danno provato – per quanto piccolo – è risarcibile. Il principio è stato confermato da pronunce successive della stessa Corte, tra cui la Causa C-340/21 (14 dicembre 2023, su un danno da *timore* dell'uso abusivo futuro dei propri dati dopo un attacco hacker subito da un'amministrazione pubblica) e la Causa C-741/21 (11 aprile 2024, che ribadisce esplicitamente che la violazione di una disposizione del GDPR non è di per sé sufficiente a costituire un danno immateriale, indipendentemente dal suo grado di gravità).

Fonte: Diritto Bancario, “La mera violazione del GDPR non integra diritto al risarcimento del danno” – <https://www.dirittobancario.it/art/la-mera-violazione-del-gdpr-non-integra-diritto-al-risarcimento-del-danno/>; Altalex, “Risarcimento del danno non patrimoniale per violazioni della normativa privacy” – <https://www.altalex.com/documents/news/2023/06/12/risarcimento-danno-non-patrimoniale-violazioni-normativa-privacy>

21.9 21.9 Caso 9 – La Sentenza Fondativa del Diritto all'Oblio (“Google Spain”, CGUE 2014)

Il caso: Un cittadino spagnolo, Mario Costeja González, aveva chiesto a un giornale (e poi a Google) la rimozione di un annuncio del 1998 relativo a un pignoramento immobiliare che lo riguardava, ritenendo l'informazione ormai superata e non più di interesse pubblico. Al rifiuto di Google, l'Agenzia Española de Protección de Datos (AEPD) aveva ordinato comunque la rimozione dei risultati di ricerca, e Google aveva impugnato la decisione sostenendo, tra le altre cose, di non poter essere considerata “responsabile del trattamento” dei dati indicizzati da pagine web altrui.

La sentenza: Causa **C-131/12**, Grande Sezione, decisa il **13 maggio 2014**. La Corte ha stabilito due principi che hanno fondato quello che oggi chiamiamo “diritto all'oblio”:

1. Il gestore di un motore di ricerca è **responsabile del trattamento** dei dati personali che compaiono nei risultati di ricerca generati a partire dal nome di una persona, anche se non ha pubblicato lui stesso quelle informazioni: il fatto di “raccogliere”,

“indicizzare” e “mettere a disposizione” tramite un elenco di risultati costituisce di per sé un trattamento di dati ai sensi della normativa europea.

2. Un interessato può richiedere la deindicizzazione di un risultato anche quando l'informazione originale resta lecitamente pubblicata sulla pagina web di partenza, se **non esiste più una giustificazione attuale** per la sua continua accessibilità tramite ricerca per nome – bilanciando questo diritto con l'interesse pubblico a conoscere l'informazione (rilevante, ad esempio, se il richiedente svolge un ruolo pubblico).

Perché conta per le aziende: Ogni azienda che gestisce un sito web indicizzato da motori di ricerca, o che pubblica contenuti su persone identificabili (articoli, comunicati stampa, recensioni), deve sapere che un interessato può rivolgersi non solo al sito che ha pubblicato l'informazione ma anche direttamente al motore di ricerca per ottenere la deindicizzazione, anche se il contenuto originale non viene rimosso. Una successiva sentenza della Corte (Causa C-136/17, 24 settembre 2019) ha esteso questo principio anche ai dati di categoria particolare (Art. 9, ad esempio dati sanitari o relativi a procedimenti giudiziari), confermando che il gestore del motore di ricerca deve comunque effettuare un bilanciamento caso per caso tra il diritto alla deindicizzazione e l'interesse pubblico all'informazione.

Fonte: EUR-Lex, sintesi della sentenza C-131/12 – https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=LEGISSUM:310401_1; Garante Privacy Italia, pagina “Diritto all’oblio” – <https://www.garanteprivacy.it/i-miei-diritti/diritti/oblio>; Portolano Cavallo, “Motori di ricerca e diritto all’oblio” – <https://portolano.it/en/newsletter/portolano-cavallo-inform-digital-ip/-motori-di-ricerca-e-diritto-alloblio-corte-di-giustizia-nel-caso-google-spain>

22 Capitolo 22: Il Piano d'Implementazione GDPR in 12 Mesi – Roadmap Pratica

Per un'azienda che parte da zero, il raggiungimento della compliance GDPR è un percorso di 6–12 mesi, non di una settimana. La seguente roadmap è realistica e sostenibile per una PMI.

Mese	Attività	Deliverable
1	Assessment iniziale	Report “as is”: mappatura di tutti i trattamenti, sistemi, fornitori, flussi di dati.
2	Nomine e struttura	Nomina del Titolare; valutazione obbligo DPO; nomina dei soggetti autorizzati interni.
3	Registro Art. 30	Primo draft del Registro delle Attività di Trattamento con tutte le voci obbligatorie.
4	Informative	Redazione e distribuzione/pubblicazione di tutte le informative privacy (dipendenti, clienti, sito web, videosorveglianza).
5	DPA con fornitori	Mappatura dei responsabili esterni; firma dei DPA con tutti i fornitori critici.
6	Sicurezza IT base	Implementazione checklist Art. 32: MFA, backup 3-2-1, crittografia laptop, VLAN base, patch management.
7	Policy operative	Redazione e distribuzione di: policy email, BYOD, stampanti, password, clean desk, videosorveglianza.
8	Formazione	Erogazione del piano formativo a tutti i dipendenti; registrazione presenze.
9	Sito web	Audit privacy policy, cookie policy e banner; adeguamento alle Linee Guida Garante 2022.
10	DPIA	Identificare i trattamenti che richiedono DPIA; effettuare almeno la DPIA del trattamento più rischioso.
11	Registro Breach	Data Implementare la procedura di Incident Response; creare e rodare il Registro Data Breach.
12	Audit finale	Audit interno di conformità; gap analysis; pianificazione delle attività di mantenimento annuale.

22.1 22.1 Le Attività di Mantenimento Annuale

Checklist Operativa

Checklist di Mantenimento Annuale:

- ☐ Aggiornare il Registro delle Attività se cambiano i trattamenti, i fornitori o le finalità.
- ☐ Rinnovare/aggiornare le nomine dei soggetti autorizzati.
- ☐ Verificare che tutti i DPA con i fornitori siano aggiornati e firmati.
- ☐ Effettuare audit della privacy policy e cookie policy del sito web.
- ☐ Erogare la formazione periodica al personale (inclusi nuovi assunti all'onboarding).
- ☐ Effettuare un test di ripristino del backup (non basta averlo: deve funzionare).
- ☐ Condurre un penetration test o vulnerability assessment.
- ☐ Verificare che le DPIA esistenti siano ancora attuali o se ne servono di nuove.
- ☐ Simulare una risposta a un data breach (tabletop exercise).
- ☐ Verificare l'allineamento alle nuove linee guida EDPB e alle sentenze del Garante.

22.2 22.2 Il Costo del Non-Adeguamento

Voce di costo	Stima media per una PMI italiana
Sanzione Garante	Da 5.000 a 50.000 euro per PMI; da 100.000 a milioni per aziende medio-grandi.
Ripristino sistemi IT	Da 20.000 a 200.000 euro (tecnici, ore lavoro, hardware).
Riscatto Ransomware (se pagato)	Da 10.000 a 500.000 euro – NON garantisce il recupero dei dati.
Perdita di clienti	Stimata nel 25–40% dei clienti enterprise dopo un data breach pubblicizzato.
Spese legali	Da 10.000 a 100.000 euro per gestire il contenzioso con il Garante.
Costi di notifica agli interessati	Da 5.000 a 50.000 euro (mailing, call center dedicato).
Costo medio totale	Da 100.000 a 1.000.000 di euro (fonte: IBM Cost of a Data Breach Report 2024)

Nota Pratica

Confronto: L'adeguamento GDPR completo per una PMI con 50 dipendenti ha un costo una-tantum di circa 5.000–15.000 euro e un costo annuo di mantenimento di 2.000–5.000 euro. Il rapporto costo/beneficio è inequivocabile.

23 Capitolo 23: Privacy e Intelligenza Artificiale – Il Futuro della Compliance

23.1 23.1 L'AI Act e la sua Interazione con il GDPR

Il **Regolamento (UE) 2024/1689 (AI Act)**, in applicazione graduale dal 2024 al 2027, classifica i sistemi di intelligenza artificiale per livello di rischio e impone obblighi aggiuntivi rispetto al GDPR.

Livello di rischio	Esempi	Obblighi
Inaccettabile (VIETATO)	Riconoscimento biometrico real-time in luoghi pubblici; sistemi di social scoring; manipolazione subliminale.	Vietati dall'agosto 2024.
Alto rischio	AI per reclutamento; credit scoring; AI in dispositivi medici; AI per infrastrutture critiche; AI nel settore giudiziario.	DPIA obbligatoria; registrazione in database UE; supervisione umana obbligatoria.
Rischio limitato	Chatbot; deepfake; generatori di contenuti sintetici.	Obbligo di trasparenza: l'utente deve sapere che sta interagendo con un'AI.
Rischio minimo	Filtri antispam; AI nei videogiochi; sistemi di raccomandazione senza impatto sui diritti.	Nessun obbligo aggiuntivo (solo conformità GDPR).

23.2 23.2 L'Uso di AI Generativa in Azienda: i Rischi Privacy

Rischi principali:

- **Invio di dati personali a server extra-UE:** Quando un dipendente incolla un database clienti in un chatbot AI hosted negli USA, sta effettuando un trasferimento di dati personali fuori dall'UE senza la valutazione delle garanzie.
- **Rischio di training:** Alcuni servizi AI usano le conversazioni per migliorare i modelli. I dati personali inseriti potrebbero entrare nel training set.
- **Confidenzialità non garantita:** Un dipendente che incolla il contratto riservato di un cliente in un chatbot pubblico potrebbe violare la confidenzialità.
- **Decisioni automatizzate non trasparenti:** Un sistema AI che supporta decisioni aziendali (screening CV) deve rispettare l'Art. 22 GDPR.

Policy Uso AI Generativa in Azienda – v1.0**POLICY UTILIZZO STRUMENTI DI INTELLIGENZA ARTIFICIALE GENERATIVA**

1. Strumenti approvati: Solo i seguenti strumenti AI sono autorizzati per uso aziendale: [Lista approvata dall'IT, es. Microsoft Copilot con tenant aziendale].

2. Dati vietati nei prompt: È assolutamente **vietato** inserire nei prompt di strumenti AI:

- Dati personali di clienti, dipendenti o terzi (nomi, email, CF, IBAN).
- Dati sanitari o di categoria particolare (Art. 9).
- Dati aziendali riservati (contratti, brevetti, strategie commerciali non pubblicate).
- Credenziali di accesso o chiavi API.

3. Trasparenza: I contenuti generati da AI e pubblicati o inviati a terzi devono essere identificati come tali (AI Act – rischio limitato).

4. Revisione umana: Nessuna decisione con impatto significativo su persone (assunzioni, rifiuto di credito, valutazioni dei dipendenti) può essere presa *esclusivamente* sulla base dell'output di un sistema AI senza revisione umana (Art. 22 GDPR).

Approvata da: [Titolare] Data:

23.3 I Provider AI come Responsabili del Trattamento

Quando un'azienda usa le API di un provider AI per elaborare dati personali dei propri clienti (es. un chatbot che risponde usando i dati cliente), il provider AI diventa un **Responsabile del Trattamento ex Art. 28** e il **DPA è obbligatorio**.

I principali provider hanno DPA standard disponibili: OpenAI Enterprise, Anthropic (Claude API), Microsoft Azure OpenAI, Google Vertex AI. Verificare sempre che i dati non vengano usati per il training dei modelli nella versione API (a differenza dei prodotti consumer).

24 Capitolo 24: Il Trattamento dei Dati dei Clienti B2B e B2C

24.1 24.1 Dati B2C (Business to Consumer) – Il Regime più Stringente

Il trattamento dei dati dei consumatori finali (persone fisiche) è soggetto al pieno regime GDPR. Il consumatore gode di tutti i diritti degli Artt. 15–22.

Ciclo di vita del dato cliente B2C:

Momento	Dati raccolti	Base giuridica	Retention
Registrazione	Email, nome, password	Contratto (pre-contrattuale)	Durata account
Ordine e-commerce	Indirizzo, CF, metodo pagamento	Contratto	10 anni (fiscale)
Newsletter (opt-in)	Email, nome	Consenso esplicito	24 mesi inattività
Assistenza clienti	Comunicazioni scambiate	Contratto / Legit. Interesse	2 anni post-risoluzione
Programma fedeltà	Acquisti, preferenze, punti	Contratto programma	Durata del programma
Profilazione marketing	Comportamento navigazione	Consenso	Fino a revoca

Attenzione – Violazione Comune

Errore comune negli e-commerce: Molti siti uniscono il consenso all'acquisto con il consenso alla newsletter in un'unica casella. Questo è illegale. Il consenso per la newsletter deve essere separato, specifico e opzionale rispetto all'acquisto.

24.2 24.2 Dati B2B (Business to Business) – Regime Differenziato

Quando il cliente è un'azienda (persona giuridica), il GDPR formalmente non si applica all'entità in quanto tale. **Tuttavia**, i dati di contatto delle persone fisiche all'interno di quell'azienda (es. nome e email del responsabile acquisti) *sono* dati personali e ricadono nel GDPR.

Regole pratiche per il B2B:

- Il contatto aziendale (“mario.rossi@clienteabc.it”) è un dato personale: serve informativa.
- Per il marketing B2B molti Garanti europei applicano un regime più permissivo basato sul legittimo interesse, purché: l’email sia professionale (non gmail personale); vi sia opt-out chiaro; il messaggio sia pertinente all’attività professionale del destinatario.
- I dati B2B devono comunque comparire nel Registro delle Attività di Trattamento.

24.3 24.3 Il CRM e la Governance dei Dati Commerciali

Checklist Operativa

Checklist CRM compliance:

- ☐ Il fornitore CRM (Salesforce, HubSpot, Zoho) ha un DPA firmato? I server sono in UE o c’è SCC per trasferimenti USA?
- ☐ Gli accessi sono basati sui ruoli (RBAC)? Il commerciale di Milano vede solo i clienti della sua area?
- ☐ C’è un log degli accessi al CRM?
- ☐ La retention è configurata? I contatti inattivi da X mesi vengono cancellati automaticamente?
- ☐ I dati sono aggiornati (principio di esattezza)?
- ☐ Le integrazioni (email marketing, helpdesk) sono coperte da DPA?
- ☐ C’è procedura per rispondere a richieste di accesso/cancellazione?

25 Capitolo 25: Trasferimenti di Dati Fuori dall'UE – Le Garanzie Necessarie

Il GDPR vieta in linea di principio il trasferimento di dati personali verso Paesi che non garantiscono un livello di protezione adeguato. Questo ha implicazioni enormi per l'uso di servizi cloud americani.

25.1 25.1 Framework delle Garanzie per i Trasferimenti Extra-UE

Meccanismo	Come funziona	Quando usare
Decisione di adeguatezza (Art. 45)	La Commissione UE ha dichiarato il Paese terzo “adeguato”. Trasferimento libero.	USA (Data Privacy Framework), Giappone, Canada, Svizzera, UK.
Standard Contractual Clauses – SCC (Art. 46)	Clausole contrattuali tipo approvate dalla Commissione UE.	Paesi senza decisione di adeguatezza.
Binding Corporate Rules – BCR (Art. 47)	Regole interne vincolanti per gruppi multinazionali. Approvate dall'Autorità capofila.	Solo grandi gruppi multinazionali.
Deroghe (Art. 49)	Consenso esplicito; necessità contrattuale; interesse pubblico; ecc.	Solo casi eccezionali; non per trasferimenti sistematici.

25.2 25.2 Il Data Privacy Framework USA-UE (2023)

Dopo le sentenze Schrems I (2015) e Schrems II (2020) che avevano invalidato i precedenti accordi USA-UE, la Commissione europea ha adottato il **Data Privacy Framework (DPF)** nel luglio 2023.

Le aziende americane certificate nel DPF (Amazon AWS, Google Cloud, Microsoft Azure, Meta, Oracle, Salesforce, ecc.) possono ricevere dati personali di cittadini europei senza le SCC. Il registro è consultabile su <https://www.dataprivacyframework.gov/list>.

Nota Pratica

Cosa fare in pratica:

1. Verificare che il fornitore cloud USA sia certificato nel DPF.
2. Se non lo è: usare le SCC (Standard Contractual Clauses) disponibili su EUR-Lex.
3. Aggiungere al DPA la clausola che specifica lo strumento di trasferimento

usato.

4. Documentare la scelta nel Registro delle Attività di Trattamento.

25.3 25.3 WhatsApp, Google Drive e i Trasferimenti “Invisibili”

Ogni volta che un dipendente:

- Invia un file con dati di clienti via **WhatsApp** (server Meta, USA);
- Salva un documento con dati personali su **Google Drive personale** (non account aziendale GSuite);
- Usa **Gmail personale** per inviare comunicazioni aziendali con dati clienti;
- Condivide screenshot di sistemi aziendali su **Telegram**;

... sta effettuando un **trasferimento di dati fuori dall'UE non autorizzato** e, contemporaneamente, un **data breach** per violazione della riservatezza. Questi comportamenti devono essere espressamente vietati nelle policy aziendali (vedi Capitolo 10).

26 Capitolo 26: Il DPO – Ruolo, Requisiti e Modalità Operative

26.1 26.1 Chi è il DPO e Cosa Fa

Il DPO (Data Protection Officer), in italiano RPD (Responsabile della Protezione dei Dati), è una figura professionale indipendente con una triplice funzione:

Funzione	Dettaglio
Consulente	Fornisce pareri su DPIA, nuovi trattamenti, policy; forma il personale.
Supervisore	Monitora la conformità interna; effettua audit; segnala criticità al Titolare.
Punto di contatto	Interfaccia ufficiale con il Garante e con gli interessati che esercitano i loro diritti.

26.2 26.2 Requisiti e Incompatibilità

Il DPO deve possedere (Art. 37): competenze specialistiche in diritto e prassi di protezione dei dati; indipendenza (non riceve istruzioni dal Titolare su come svolgere i compiti); assenza di conflitto di interessi.

Ruoli incompatibili con il DPO: CEO, CFO, CTO/Responsabile IT, Responsabile HR, Responsabile Marketing, Responsabile Legale interno (quando il parere DPO potrebbe confliggere con la strategia legale aziendale).

Il DPO può essere:

- Un dipendente con altri ruoli *compatibili*.
- Un consulente esterno (contratto di servizio con persona fisica o studio professionale).
- Condiviso tra più aziende del gruppo o tra PMI associate (Art. 37.3).

26.3 26.3 Come Segnalare il DPO al Garante

Il DPO (quando obbligatorio) deve essere comunicato al Garante tramite il modulo online su <https://www.garanteprivacy.it>. I dati di contatto del DPO devono essere pubblicati sul sito web dell'organizzazione e inseriti nelle informative privacy.

Clausola DPO in Informativa Privacy

Dati di contatto del Responsabile della Protezione dei Dati (DPO/RPD):

Nominativo: [Nome e Cognome]

Email: [dpo@azienda.it]

Indirizzo: [Via, Città]

Il DPO è il punto di contatto per tutte le richieste relative al trattamento dei dati personali e per l'esercizio dei diritti di cui agli Artt. 15–22 del GDPR.

27 Capitolo 27: Privacy in Settori Specifici

27.1 27.1 Privacy nel Settore Sanitario

Il settore sanitario tratta dati di categoria particolare (Art. 9) su larga scala, il che lo rende uno dei contesti più regolamentati.

Peculiarità del settore sanitario:

- Base giuridica principale: Art. 9.2.h (finalità di medicina preventiva, diagnosi, assistenza sanitaria).
- Il **consenso** ex Artt. 6.1.a e 9.2.a è richiesto per trattamenti che vanno oltre la cura (ricerca clinica, marketing sanitario).
- Le strutture sanitarie con più di 9 addetti o che trattano dati sanitari su larga scala devono nominare il **DPO**.
- La **DPIA** è obbligatoria per tutti i sistemi informativi sanitari su larga scala (lista Garante 2018).
- La cartella clinica elettronica richiede MFA e RBAC (medico, infermiere, amministrativo: profili differenziati).
- I **referti via email** non sono conformi se l'email non è cifrata con S/MIME o se il paziente non ha fornito consenso specifico.
- **Retention dei dati sanitari:** cartelle cliniche ospedali pubblici: 30 anni; referti di laboratorio: 10 anni; radiografie: 20 anni.

Attenzione – Violazione Comune

Caso frequente: Un medico di base usa un foglio Excel condiviso su Google Drive per tenere l'elenco dei pazienti con le patologie. Questo è un trattamento di dati sanitari su un server extra-UE (Google, USA) senza DPA adeguato e senza crittografia. È una violazione dell'Art. 9 combinato con l'Art. 32.

27.2 27.2 Privacy nel Settore Scolastico

Le scuole trattano dati di **minori** (categoria vulnerabile) e dati sanitari (DSA, BES, disabilità).

Punti critici:

- **Piattaforme educative cloud:** Google Workspace for Education e Microsoft 365 Education richiedono DPA con il provider e verifica che i dati degli studenti non vengano usati per pubblicità.
- **Fotografie di eventi scolastici:** Le foto di alunni minori richiedono il consenso esplicito dei genitori. La pubblicazione su sito web o social scolastico è consentita solo previo consenso scritto.

- **Registro elettronico:** Accessibile solo a genitori e docenti della classe. Dati DSA/BES visibili solo ai soggetti con necessità operativa.
- **Riprese video per DAD:** La registrazione di lezioni da remoto richiede informativa specifica e limiti di retention (massimo fine anno scolastico, salvo eccezioni motivate).

27.3 Privacy nelle Risorse Umane (HR)

L'ufficio HR è il reparto che tratta il maggior numero di categorie di dati particolari in un'azienda tradizionale: dati anagrafici, bancari, sanitari, sindacali, giudiziari.

Regole critiche per l'HR:

- **Fascicolo del dipendente:** Solo i dati strettamente necessari. I certificati medici e i dati L.104 sono visibili solo al responsabile HR strettamente necessario, non all'intera direzione.
- **Referenze:** Richiedere referenze all'ex datore di lavoro senza il consenso del candidato può violare la privacy.
- **Controllo dei precedenti penali:** Limitato ai casi previsti dalla legge (es. lavoro con minori ex D.Lgs. 39/2014).
- **Test psicologici/attitudinali:** Quando rivelano informazioni sulla personalità e sullo stato psicologico sono dati particolari e richiedono base giuridica specifica.
- **Sistemi di rilevazione presenze biometrici:** DPIA obbligatoria. Il Garante richiede consenso esplicito o norma di legge specifica (specie per lavoratori pubblici).

28 Capitolo 28: Domande Frequenti (FAQ) sul GDPR per le PMI

D: Ho solo 3 dipendenti. Il GDPR si applica a me?

R: Sì. Il GDPR non ha soglie dimensionali. Se tratti dati personali (clienti, dipendenti, fornitori), sei soggetto al GDPR. L'obbligo formale del Registro delle Attività è previsto per chi tratta dati sensibili o rischiosi, ma anche per una micro-impresa un registro semplificato è fortemente consigliato.

D: Ho già una privacy policy sul sito. Sono a norma?

R: No. La privacy policy copre solo i trattamenti online. Il GDPR riguarda *tutti* i trattamenti, inclusi quelli offline (archivi cartacei, telefonate, gestione dipendenti). Serve una compliance complessiva.

D: Ho scaricato un template GDPR da internet. È sufficiente?

R: No. Il Garante ha sanzionato aziende per aver adottato informative standard che non corrispondevano ai trattamenti reali. La compliance GDPR deve fotografare la realtà specifica di quella specifica azienda.

D: Il mio cloud provider è americano. Devo preoccuparmi?

R: Dipende. Se il provider è certificato nel Data Privacy Framework (DPF), il trasferimento è lecito. Verifica su dataprivacyframework.gov. Se non è certificato, servono le SCC.

D: Un dipendente ha perso un laptop aziendale. Cosa faccio?

R: Prima cosa: il laptop era cifrato? Se sì, il rischio è minimo: si registra nell'Internal Log. Se non era cifrato, è quasi certamente un data breach: valuta il rischio per i dati contenuti e, se c'è rischio per gli interessati, notifica il Garante entro 72 ore.

D: Un cliente mi chiede la cancellazione di tutti i suoi dati. Devo farlo?

R: Non sempre. Il diritto alla cancellazione (Art. 17) ha eccezioni: obbligo legale di conservazione (fatture 10 anni), contenzioso in corso, altri motivi legittimi. Se non hai motivi per trattenerli, devi cancellarli e comunicarlo per iscritto.

D: Posso usare i dati dei miei fornitori per fare marketing?

R: I dati dei referenti B2B possono essere usati per comunicazioni pertinenti all'attività professionale in corso, in base al legittimo interesse. Non puoi usarli per campagne non correlate o rivenderli a terzi.

D: Un dipendente ha inviato per errore una email con dati clienti al destinatario sbagliato. È un data breach?

R: Dipende dalla gravità. Se l'email conteneva dati comuni inviata internamente: rischio basso, solo log interno. Se conteneva dati sanitari o bancari inviata a un esterno sconosciuto: data breach con rischio medio-alto, notifica al Garante obbligatoria.

D: Devo nominare un DPO?

R: Dipende dalla tua attività. Il DPO è obbligatorio per enti pubblici e per chi tratta dati sanitari su larga scala. Per la maggior parte delle PMI non è obbligatorio, ma è consigliato nominarsi un consulente privacy esterno.

D: Se mi adeguo al GDPR, sono al sicuro da attacchi informatici?

R: No. L'adeguamento GDPR riduce il rischio di sanzioni in caso di attacco, ma non elimina il rischio di essere attaccati. La cybersecurity riduce la probabilità e l'impatto degli attacchi. GDPR e cybersecurity sono complementari, non sostitutivi.

29 Capitolo 29: Come Affrontare un'Ispezione del Garante o della Guardia di Finanza

29.1 29.1 Come si Svolge un'Ispezione Privacy

Le ispezioni in materia di protezione dei dati personali in Italia sono condotte dal **Nucleo Speciale Privacy e Frodi Tecnologiche della Guardia di Finanza**, su delega del Garante, oppure direttamente dal personale ispettivo del Garante. Possono scattare per tre motivi:

1. **Reclamo di un interessato:** Un cliente o dipendente ha segnalato al Garante una presunta violazione (es. mancata risposta a una richiesta di accesso, ricezione di email di marketing non richieste).
2. **Notifica di Data Breach:** L'azienda stessa ha notificato un incidente, e il Garante apre un'istruttoria per verificare le misure tecniche adottate.
3. **Ispezione a campione/settoriale:** Il Garante conduce verifiche programmate su un settore specifico (es. ispezioni sul settore bancario, sanitario, o sulle aziende che usano sistemi di videosorveglianza con AI).

29.2 29.2 Cosa Viene Richiesto Durante l'Ispezione

Checklist Operativa

Documenti che gli ispettori richiedono tipicamente, in ordine di frequenza:

- ☐ Registro delle Attività di Trattamento (Art. 30) – aggiornato, non un draft vecchio di 2 anni.
- ☐ Nomine dei soggetti autorizzati al trattamento, con relativa formazione documentata.
- ☐ Contratti DPA (Art. 28) con tutti i fornitori che trattano dati per conto dell'azienda.
- ☐ Informative privacy distribuite/pubblicate (dipendenti, clienti, sito web, videosorveglianza).
- ☐ Registro Data Breach interno (anche se vuoto, deve esistere e deve essere coerente nel tempo).
- ☐ Eventuali DPIA effettuate per i trattamenti a rischio.
- ☐ Evidenza delle misure tecniche di sicurezza (es. screenshot della configurazione MFA, policy di backup, log del SIEM).
- ☐ Accordo sindacale o autorizzazione ITL per videosorveglianza e strumenti di controllo.
- ☐ Nomina del DPO (se obbligatorio) e prova della comunicazione al Garante.

29.3 29.3 Cosa Fare e Cosa Non Fare Durante l'Ispezione

Comportamenti corretti:

- Designare un referente unico (es. il responsabile privacy o un consulente esterno) che dialoga con gli ispettori.
- Rispondere in modo veritiero. Dichiarazioni false agli ispettori durante un verbale costituiscono reato penale ai sensi dell'Art. 168 del Codice Privacy.
- Se un documento richiesto non esiste, dichiararlo onestamente. Mentire o inventare una data retroattiva su un documento aggrava sensibilmente la posizione dell'azienda.
- Richiedere tempo per produrre documentazione complessa, se concesso dagli ispettori (spesso è possibile integrare entro alcuni giorni).

Errori da evitare:

- Creare documenti “al volo” durante l'ispezione con data retroattiva: gli ispettori verificano i metadati dei file e le date di creazione/modifica.
- Negare l'accesso ai sistemi informatici senza base legale (gli ispettori della GdF agiscono con potere di polizia giudiziaria delegata).
- Fornire risposte vaghe o contraddittorie tra i vari referenti aziendali intervistati.

29.4 29.4 Dopo l'Ispezione: il Verbale e le Conseguenze

Al termine, viene redatto un **verbale di accertamento** che riporta quanto rilevato. Se emergono violazioni, l'azienda riceve una **contestazione formale** con un termine (tipicamente 30 giorni) per presentare memorie difensive. Solo successivamente il Garante emette il **provvedimento sanzionatorio** definitivo, che può essere impugnato davanti al Tribunale ordinario.

Nota Pratica

Consiglio pratico: Le aziende che, durante l'ispezione, dimostrano un percorso di adeguamento serio e documentato (anche se non perfetto) ottengono quasi sempre sanzioni più contenute rispetto a chi non ha fatto nulla. L'Art. 83.2 GDPR prevede esplicitamente che il Garante tenga conto delle “misure adottate dal titolare per attenuare il danno” nel calcolo della sanzione.

30 Capitolo 30: Videosorveglianza Intelligente, Riconoscimento Facciale e Smart City

30.1 30.1 La Differenza tra Videosorveglianza Tradizionale e Videosorveglianza “Intelligente”

Negli ultimi anni le telecamere si sono evolute da semplici dispositivi di registrazione a veri e propri sistemi di **elaborazione algoritmica delle immagini**. Questo cambia radicalmente l'inquadramento giuridico.

Tipo di sistema	Cosa fa	Inquadramento GDPR
Videosorveglianza tradizionale	Registra immagini per revisione umana successiva	Legittimo interesse; nessuna DPIA salvo casi particolari
Videoanalisi comportamentale	Rileva automaticamente comportamenti anomali (assembramenti, oggetti abbandonati)	DPIA quasi sempre necessaria; valutare se monitoraggio sistematico su larga scala
Riconoscimento facciale	Identifica univocamente le persone tramite biometria del volto	Dato biometrico (Art. 9); DPIA SEMPRE obbligatoria; consenso esplicito quasi sempre necessario
Riconoscimento targhe (OCR)	Legge automaticamente le targhe dei veicoli	Dato personale (la targa è riconducibile al proprietario); base giuridica da valutare caso per caso

30.2 30.2 Il Divieto (con Eccezioni) del Riconoscimento Facciale in Tempo Reale

L'AI Act (Regolamento UE 2024/1689) vieta, salvo eccezioni tassative, l'uso di sistemi di **identificazione biometrica remota “in tempo reale”** in spazi accessibili al pubblico.

Le eccezioni (uso consentito solo alle forze dell'ordine, con autorizzazione giudiziaria):

- Ricerca di vittime specifiche di rapimento, tratta di esseri umani o sfruttamento sessuale.
- Prevenzione di una minaccia specifica, sostanziale e imminente alla vita o all'incolumità fisica, o di un attacco terroristico.
- Localizzazione o identificazione di un sospetto per reati gravi specifici (elenco tassativo nell'allegato dell'AI Act).

Attenzione – Violazione Comune

Per le aziende private: L'installazione di sistemi di riconoscimento facciale per il controllo accessi (es. tornelli aziendali) o per finalità di marketing (es. riconoscere clienti abituali in un negozio) **non rientra** tra le eccezioni e richiede un'analisi giuridica estremamente rigorosa: DPIA obbligatoria, consenso esplicito di ogni singola persona identificata, e in molti casi parere preventivo del Garante (Art. 36).

30.3 30.3 Smart City e Sensori Urbani: il Bilanciamento con la Privacy

I progetti di Smart City (sensori di traffico, illuminazione intelligente, monitoraggio ambientale) spesso integrano telecamere e sensori che, anche se progettati per finalità statistiche, possono raccogliere dati personali se non adeguatamente anonimizzati.

Principio guida (Privacy by Design applicato alla Smart City): I dati devono essere elaborati e aggregati *localmente sul dispositivo (edge computing)*, trasmettendo al server centrale solo statistiche anonime (es. “numero di persone passate in questo incrocio nell'ultima ora”) e mai immagini o flussi video identificabili, salvo finalità di sicurezza esplicitamente autorizzate e con retention minima.

31 Capitolo 31: Esercitazioni Pratiche Guidate

La teoria e gli esempi dei capitoli precedenti servono a capire le regole. Questo capitolo serve a *esercitarsi ad applicarle*. Ogni esercitazione presenta un caso aziendale fittizio (ma realistico) seguito da una domanda esplicita. Si raccomanda allo studente di provare a risolvere autonomamente l'esercizio prima di leggere la soluzione commentata: il valore didattico sta nel tentativo, non nella lettura passiva della risposta.

31.1 31.1 Esercitazione 1 – Compilare il Registro delle Attività di Trattamento

Caso: La “Fenice Arredi S.r.l.”, azienda di arredamento per ufficio con 18 dipendenti, sta avviando il proprio percorso di adeguamento GDPR (siamo al Mese 3 della roadmap del Capitolo 22). L'azienda svolge le seguenti attività, descritte dal titolare in un colloquio iniziale:

“Vendiamo mobili per ufficio a clienti sia privati che ad altre aziende. Per le vendite usiamo un gestionale cloud italiano (TeamSystem) dove inseriamo nome, indirizzo, codice fiscale o P.IVA, e indirizzo email del cliente. Per le consegne ci affidiamo a un padroncino esterno che usa il suo furgone. Una volta al mese mandiamo una newsletter con le offerte a chi si è iscritto dal sito tramite un form con una casella da spuntare. Per la contabilità abbiamo un commercialista esterno che ha accesso diretto al nostro gestionale. Infine, nel magazzino abbiamo 4 telecamere puntate sull'area di carico/scarico merci, installate due anni fa per evitare furti, niente cartelli per ora.”

Domanda: Costruisci una tabella del Registro delle Attività di Trattamento (Art. 30) per i tre trattamenti distinti descritti (vendita, newsletter, videosorveglianza), indicando per ciascuno: finalità, categorie di dati, base giuridica, destinatari/responsabili esterni, e segnala eventuali criticità che noti nella descrizione del titolare.

Soluzione Commentata – Esercitazione 1

Tabella Registro (estratto):

Finalità	Dati	Base giuridica	Retention	Destinatari
Vendita e consegna mobili	Nome, indirizzo, CF/P.IVA, email	Contratto (6.1.b)	10 anni (fiscali)	TeamSystem (DPA da verificare); padroncino (vedi nota)
Newsletter commerciale	Email, nome	Consenso (6.1.a)	24 mesi inattività	Piattaforma email (DPA necessario)
Videosorveglianza magazzino	Immagini (no audio)	Legittimo interesse (6.1.f) – da regolarizzare	72 ore	Nessuno esterno indicato

Criticità individuate (questo è il vero esercizio):

1. **Il padroncino delle consegne:** se gli viene comunicato solo nome e indirizzo del cliente per la consegna, è quasi certamente un Titolare autonomo del trattamento logistico (come il corriere UPS dell'esempio nel Cap. 9), non un responsabile ex Art. 28 – non serve DPA, ma va comunque citato nell'informativa come possibile destinatario.
2. **Il commercialista con accesso diretto al gestionale:** questo è un punto critico. Avere accesso diretto e non solo ricevere estratti contabili lo rende un Responsabile del Trattamento ex Art. 28: serve un DPA, non basta la prassi consolidata della “fiducia professionale”.
3. **Le telecamere senza cartelli, installate da due anni senza accordo sindacale:** questa è la criticità più grave. Per due anni l'azienda ha trattato dati biometrici/immagini dei dipendenti in violazione dell'Art. 4 Statuto Lavoratori. Va aperta immediatamente la procedura con le RSU/RSA o, in assenza, richiesta autorizzazione all'Ispettorato del Lavoro (vedi Cap. 10.3), e vanno installati i cartelli prima di qualsiasi altra azione.
4. **TeamSystem:** prima di scrivere “DPA da verificare” nella tabella definitiva, va richiesto formalmente il contratto di nomina a responsabile del trattamento al fornitore – non si assume che un grande fornitore software lo abbia già pronto senza controllare.

31.2 31.2 Esercitazione 2 – Classificare un Data Breach e Decidere se Notificare

Caso: Sei il referente privacy della “Clinica Dentale Sorriso S.r.l.”. Lunedì mattina ricevi questa segnalazione dalla receptionist:

“Venerdì pomeriggio ho inviato per email l'elenco dei pazienti con appuntamento per la settimana prossima alla nostra igienista dentale, che lavora anche per un altro studio. Ho sbagliato e l'ho inviato a una vecchia collega che non lavora più qui da un anno, il cui indirizzo email era ancora salvato in rubrica. Il file Excel conteneva: nome, cognome, numero di telefono, e tipo di trattamento previsto (es. 'pulizia', 'otturazione', 'estrazione dente del giudizio') per 34 pazienti. La ex collega mi ha risposto stamattina dicendo di aver cancellato il file e di non averlo condiviso con nessuno.”

Domanda: (a) Questo è un data breach? (b) Che tipo di violazione della Triade CIA configura? (c) Va notificato al Garante entro 72 ore? (d) Va comunicato ai 34 pazienti coinvolti?

Soluzione Commentata – Esercitazione 2

(a) È un data breach? Sì. C'è stata una divulgazione non autorizzata di dati personali (e di dati relativi alla salute, categoria particolare ex Art. 9) a un destinatario non autorizzato a riceverli. Il fatto che la ex collega abbia agito in buona fede e cancellato

il file non cambia la natura giuridica dell'evento: il breach è già avvenuto nel momento dell'invio.

(b) Che tipo di violazione? Violazione di **Riservatezza** (Confidentiality): un soggetto non autorizzato ha avuto accesso a dati che non doveva vedere. Non è una violazione di Integrità (i dati non sono stati alterati) né di Disponibilità (l'azienda non ha perso l'accesso ai dati).

(c) Notifica al Garante entro 72 ore? Qui serve applicare la logica del Capitolo 5. Bisogna chiedersi: c'è un rischio per i diritti e le libertà dei 34 pazienti? Elementi a favore di un rischio *contenuto*: la destinataria è una persona identificata e nota (non un estraneo anonimo su internet), ha agito in buona fede, ha confermato la cancellazione, e non ha condiviso il file con terzi. Elementi che pesano nella direzione opposta: i dati includono informazioni sanitarie (categoria particolare, Art. 9) per 34 persone, e l'azienda non ha modo di *verificare* in modo certo che la cancellazione sia avvenuta davvero (è una dichiarazione, non una prova tecnica).

La risposta corretta è: **sì, va notificato**, perché trattandosi di dati sanitari il rischio non può essere escluso solo sulla base di una dichiarazione verbale della destinataria. La notifica può includere, tra le misure di mitigazione adottate, il fatto che la destinataria ha confermato la cancellazione – questo riduce la gravità percepita dal Garante, ma non elimina l'obbligo di notificare l'evento in sé.

(d) Comunicazione ai 34 pazienti? Il rischio non è “elevato” nel senso dell'Art. 34 (non ci sono elementi per ritenere che i dati siano stati usati contro i pazienti, e il volume di dati per persona è limitato a un tipo di trattamento dentale, non un intero fascicolo clinico). La comunicazione diretta ai pazienti non è obbligatoria in questo scenario, ma resta una decisione che il Titolare può comunque valutare per trasparenza, specie se la cultura aziendale privilegia la fiducia del paziente.

La lezione metodologica: l'esercizio mostra che la classificazione del rischio richiede di pesare elementi in entrambe le direzioni, non di applicare una regola meccanica. È esattamente l'errore commesso da Humanitas Mirasole nel Caso 3 del Capitolo 21: sottovalutare il rischio di un dato sanitario solo perché l'evento sembrava “minore”.

31.3 31.3 Esercitazione 3 – Correggere una Policy Aziendale Scritta Male

Caso: Un'azienda manifatturiera ti mostra la bozza della propria “Policy Videosorveglianza”, scritta internamente dall'ufficio HR senza consulenza legale, e ti chiede un parere prima di pubblicarla. Questo è il testo:

“Art. 1: L'azienda si riserva il diritto di installare telecamere ovunque lo ritenga necessario per la sicurezza. Art. 2: Le immagini possono essere visionate da qualsiasi responsabile di reparto in qualsiasi momento. Art. 3: Le immagini vengono conservate per 90 giorni per eventuali necessità disciplinari. Art. 4: Il personale è considerato informato tramite la presente policy, pubblicata sulla intranet aziendale.”

Domanda: Individua almeno quattro problemi giuridici in questo testo e riscrivi una versione corretta.

Soluzione Commentata – Esercitazione 3

Problemi individuati:

1. **Art. 1 – “ovunque lo ritenga necessario”:** Formulazione troppo ampia e priva di finalità specifiche. Viola il principio di limitazione della finalità (Cap. 2.2): la policy deve indicare le finalità precise (tutela del patrimonio, sicurezza) e le aree concrete, non una delega in bianco. Inoltre non è mai citata la necessità dell’accordo sindacale o dell’autorizzazione ITL (Cap. 10.3) – e senza quella procedura, l’intero impianto è illegittimo indipendentemente da come è scritta la policy.
2. **Art. 2 – “qualsiasi responsabile di reparto in qualsiasi momento”:** Viola il principio di minimizzazione (Cap. 2.3) e il criterio di accesso per ruolo specifico richiamato nel PAM (Cap. 18.2). L’accesso alle immagini deve essere limitato a un numero ristretto di soggetti individuati per nome o ruolo specifico (es. “responsabile IT e Titolare”), con log degli accessi, non un accesso diffuso a tutti i responsabili di reparto.
3. **Art. 3 – “90 giorni”:** Eccessivo. Come visto nel Cap. 2.5 e nel Cap. 10.3, la retention standard per la videosorveglianza è 24–72 ore, estendibile a 7 giorni solo per esigenze motivate specifiche (non genericamente “eventuali necessità disciplinari”, che è una finalità diversa da quella dichiarata nell’Art. 1 e quindi viola anche qui la limitazione di finalità).
4. **Art. 4 – “considerato informato”:** L’informativa tramite intranet aziendale può essere un canale valido, ma deve essere affiancata dai cartelli fisici nelle aree riprese (Cap. 10.3) – la sola pubblicazione su intranet non soddisfa il requisito EDPB di informare anche visitatori, fornitori e chiunque accede occasionalmente ai locali, che non hanno accesso alla intranet.

Versione corretta (estratto): “Art. 1: Il sistema di videosorveglianza è installato esclusivamente nelle seguenti aree: [elenco specifico], per le finalità di tutela del patrimonio aziendale e sicurezza delle persone, previo accordo con le rappresentanze sindacali del [data] / autorizzazione dell’Ispettorato del Lavoro n. [riferimento]. Art. 2: L’accesso alle immagini registrate è riservato esclusivamente a: [Responsabile IT, nome], [Titolare]. Ogni accesso è registrato in un log con data, ora e identità dell’operatore. Art. 3: Le immagini sono conservate per 72 ore e cancellate automaticamente, salvo richiesta specifica e motivata dell’autorità giudiziaria. Art. 4: Cartelli informativi conformi alle Linee Guida EDPB 3/2019 sono affissi in ogni area videosorvegliata, prima dell’ingresso nella zona di ripresa.”

31.4 Esercitazione 4 – Valutare il Perimetro NIS 2 e Rispondere a un Incidente

Caso: La “Idrotek Impianti S.p.A.” progetta e gestisce in appalto impianti di trattamento delle acque per conto di diversi Comuni dell’Emilia-Romagna. Ha 85 dipendenti e un fatturato annuo di 18 milioni di euro. Il responsabile IT ti scrive:

“Non penso che la NIS 2 ci riguardi: noi non siamo un gestore di acqua, siamo solo l’azienda che ha progettato e installato gli impianti per conto dei

Comuni, che restano proprietari. Comunque ti scrivo perché ieri alle 22:00 il nostro SCADA di supervisione (quello che monitora da remoto 6 impianti di potabilizzazione) ha iniziato a comportarsi in modo anomalo: alcuni allarmi di livello vasca non arrivavano più alla dashboard, e questa mattina alle 7:00 un tecnico in turno ha notato che il PLC di un impianto stava ricevendo comandi di apertura valvola che nessuno aveva impartito da console. Abbiamo isolato la rete OT di quell'impianto staccando lo switch verso il resto della rete aziendale alle 8:15. Al momento non sappiamo ancora con certezza se è un guasto o un attacco.”

Domanda: (a) Idrotek rientra nel perimetro NIS 2, anche non essendo essa stessa un gestore del servizio idrico? (b) Sulla base della cronologia descritta, quali obblighi temporali si sono già attivati e quali azioni andrebbero verificate per essere certi di rispettarli? (c) Cosa avrebbe dovuto essere diverso, idealmente, nella sequenza di risposta tecnica?

Soluzione Commentata – Esercitazione 4

(a) Perimetro NIS 2: Sì, con alta probabilità Idrotek rientra nel perimetro, anche se non è il gestore finale del servizio. Come visto nel Cap. 13.2, la Direttiva NIS 2 non si limita ai gestori diretti dei servizi essenziali (qui, il settore “Acqua potabile”): include anche i fornitori critici della filiera che, se compromessi, possono mettere a rischio la continuità del servizio stesso. Un’azienda che progetta, installa e soprattutto *gestisce in supervisione remota* gli impianti SCADA/PLC di un servizio idrico pubblico è esattamente il tipo di fornitore che la norma vuole includere, indipendentemente dalla proprietà formale degli impianti. La dimensione (85 dipendenti, 18 milioni di fatturato) supera comunque le soglie minime previste per le “medie imprese” nei settori critici.

(b) Obblighi temporali già attivati: Qui il punto centrale dell’esercizio è la *cronologia*. Il comportamento anomalo è iniziato alle 22:00, ma è stato identificato con chiarezza come potenziale incidente di sicurezza solo alle 7:00-8:15 del giorno dopo, quando il tecnico ha notato i comandi non autorizzati e la rete è stata isolata. Come visto nel Cap. 13.4, la NIS 2 impone un **Early Warning al CSIRT nazionale entro 24 ore** dal momento in cui l’azienda è consapevole dell’incidente – non dal momento in cui l’incidente è effettivamente iniziato. Il punto di partenza del conteggio è quindi, con buona difesa, le 7:00-8:15 di oggi (quando l’anomalia è stata riconosciuta come potenzialmente dolosa, non solo come guasto), il che lascia tempo fino a stasera per il primo avviso. **Ma attenzione:** se nelle prossime ore emergono elementi che indicano che l’azienda avrebbe potuto/dovuto riconoscere l’anomalia delle 22:00 come un incidente di sicurezza fin da subito (ad esempio se i log mostrano segnali chiari già a quell’ora), il termine delle 24 ore potrebbe essere calcolato a ritroso da lì, e si sarebbe già vicini alla scadenza. La prima azione pratica da consigliare è: verificare immediatamente i log del SIEM/IDS delle ore notturne per stabilire con certezza quando l’anomalia era riconoscibile, perché questo determina se si è ancora in tempo o già in ritardo.

(c) Cosa sarebbe dovuto essere diverso: Idealmente, la decisione di isolare la rete OT non sarebbe dovuta aspettare la scoperta del tecnico alle 7:00, ma essere innescata dagli allarmi stessi: il fatto che gli “allarmi di livello vasca non arrivassero più alla dashboard” a partire dalle 22:00 è già, di per sé, un segnale di anomalia nella disponibilità dei dati di sicurezza (vedi Triade CIA, Cap. 4) che avrebbe dovuto attivare una verifica immediata, non attendere il turno successivo. Questo è esattamente il tipo di gap che un piano di Incident Response strutturato (Cap. 18.4) con turni di monitoraggio H24 e soglie di

allarme automatiche avrebbe dovuto prevenire.

32 Capitolo 32: Il Procedimento Sanzionatorio del Garante e il Diritto di Opposizione

Il Capitolo 29 ha descritto cosa succede durante un'ispezione. Questo capitolo va oltre: spiega come funziona, passo per passo, il procedimento che porta a una sanzione, quali sono i diritti di difesa dell'azienda durante quel procedimento, e come si può fare opposizione davanti a un giudice se si ritiene la sanzione ingiusta o il procedimento irregolare.

32.1 32.1 Le Due Fasi del Procedimento: Istruttoria e Sanzionatoria

La giurisprudenza più recente (vedi 32.4) ha chiarito che il procedimento davanti al Garante si articola in due fasi distinte, sia logicamente che cronologicamente, ed è essenziale per un'azienda capire in quale fase si trova in un dato momento, perché le garanzie procedurali sono diverse.

Fase	Cosa succede
1. Istruttoria (o preistruttoria)	Il Garante acquisisce elementi: richieste di informazioni ex Art. 157 del Codice Privacy, eventuali ispezioni, audizioni informali. Può durare a lungo, specie per istruttorie complesse, e in questa fase non esiste ancora un termine perentorio stringente per il Garante.
2. Sanzionatoria in senso stretto	Si apre solo con la notifica formale della contestazione di violazione, ai sensi dell'Art. 166, comma 5, del Codice Privacy. È questo l'atto che fa scattare il contraddittorio e le garanzie difensive dell'azienda, ed è soggetto a termini perentori (vedi 32.4).

32.2 32.2 La Contestazione e i Diritti di Difesa: i 30 Giorni

Una volta ricevuta la notifica formale della contestazione, l'azienda (Titolare o Responsabile del trattamento) ha **30 giorni** dalla notifica per:

- presentare **scritti difensivi e documenti** al Garante;
- chiedere di essere **sentita in audizione** dall'Autorità.

Se l'azienda ritiene di avere bisogno di più tempo (ad esempio per ricostruire una vicenda complessa o raccogliere documentazione tecnica), può presentare un'**istanza di proroga motivata**: la proroga concessa normalmente non supera i 15 giorni aggiuntivi, e viene valutata anche in base alle caratteristiche dimensionali e operative dell'azienda richiedente.

Attenzione – Violazione Comune

Conseguenza del silenzio: Se l'azienda non presenta memorie difensive né chiede l'audizione entro il termine (né un'eventuale proroga), il Garante procede comunque alla decisione sulla base degli elementi in suo possesso. Il silenzio non equivale a un'ammissione di colpa, ma priva l'azienda della possibilità concreta di influenzare l'esito o l'entità della sanzione: nella prassi, le aziende che non si difendono affatto ricevono quasi sempre il provvedimento più severo possibile sulla base dei soli elementi raccolti dall'Ufficio.

32.3 Il Provvedimento Finale e l'Opposizione al Tribunale Ordinario

Esaurita la fase di contraddittorio, il Garante emette il **provvedimento finale**, che può: archiviare il caso, irrogare una sanzione pecuniaria, imporre misure correttive (ordini di conformità, divieti di trattamento), o una combinazione di queste.

Se l'azienda ritiene il provvedimento illegittimo (per ragioni di merito o per vizi procedurali), può proporre **opposizione all'autorità giudiziaria ordinaria**. Il quadro normativo di riferimento, richiamato esplicitamente in ogni provvedimento del Garante, è il seguente:

- **Art. 78 del GDPR:** stabilisce il diritto a un ricorso giurisdizionale effettivo contro una decisione giuridicamente vincolante di un'Autorità di controllo.
- **Art. 152 del Codice Privacy (D.Lgs. 196/2003):** individua il **Tribunale ordinario** (non il TAR, né altro giudice amministrativo) come giudice competente, specificando il criterio per individuare la sede territorialmente competente (in generale, il tribunale del luogo ove ha sede il Titolare del trattamento che propone opposizione).
- **Art. 10 del D.Lgs. 150/2011:** disciplina il rito processuale applicabile (rito sommario di cognizione).

Termine per l'opposizione: il ricorso va depositato presso il Tribunale ordinario competente entro **30 giorni** dalla notifica del provvedimento (60 giorni se il ricorrente risiede all'estero). Questo termine è perentorio: superarlo senza presentare opposizione rende il provvedimento definitivo e non più contestabile, come confermato anche da pronunce della Cassazione su casi in cui l'azienda aveva lasciato decorrere inutilmente il termine.

Nota Pratica

Natura del giudizio: La giurisprudenza ha chiarito che l'opposizione davanti al Tribunale non è un semplice "appello" a cognizione limitata, ma un *novum iudicium*: il giudice riesamina per intero il rapporto sottostante, non solo le questioni procedurali sollevate dal ricorrente. Questo significa che, in sede di opposizione, possono essere reconsiderati sia i profili di merito (l'azienda ha effettivamente violato il GDPR?) sia quelli procedurali (il Garante ha rispettato i propri termini e le garanzie di difesa?).

32.4 32.4 La Giurisprudenza Recente sui Termini Perentori: i Casi RAI ed Enel Energia

Negli ultimi anni la Cassazione è intervenuta più volte su un tema cruciale per le aziende: **quanto tempo ha il Garante** per notificare la contestazione dopo aver concluso l'istruttoria? Se questo termine viene superato, la sanzione può essere annullata indipendentemente dal merito della violazione.

Il caso RAI (Cassazione, sentenza n. 759/2025, 16 dicembre 2025): Il Garante aveva avviato una preistruttoria nei confronti di RAI nell'aprile 2021, ma aveva notificato formalmente l'avvio del procedimento sanzionatorio solo nell'agosto 2021, per poi emettere il provvedimento conclusivo solo nel luglio 2023 – quasi due anni dopo l'avvio della preistruttoria. Il Tribunale di Roma aveva annullato la sanzione (relativa a una vicenda legata al programma “Report”), ritenendo che il termine di **120 giorni** previsto dal Regolamento del Garante n. 2/2019 per la notifica della contestazione, decorrente dalla conclusione della fase istruttoria, avesse natura **perentoria**. La Cassazione ha confermato questo principio, respingendo sia il ricorso del Garante sia quello della controparte, e ha chiarito che il termine di 120 giorni (esteso a 360 giorni per i soggetti residenti all'estero) decorre dal momento in cui la violazione può dirsi accertata, cioè dalla conclusione della fase istruttoria – non da fasi precedenti e più informali dello scambio con l'Autorità.

Il caso Enel Energia (Cassazione, Sez. I Civile, sentenza n. 18583, 8 luglio 2025): Il Garante aveva contestato a Enel Energia S.p.A. quindici violazioni del GDPR legate al cosiddetto “telemarketing selvaggio”, con una sanzione di oltre 26 milioni di euro. Il Tribunale di Roma, in primo grado, aveva annullato l'intero provvedimento ritenendo tardiva la notifica della contestazione. La Cassazione, accogliendo il ricorso del Garante, ha però chiarito un punto tecnico importante: nelle istruttorie complesse e articolate in più fasi (ad esempio quando l'Ufficio invia richieste di informazioni cumulative e suddivide la contestazione in più atti), il termine di 120 giorni va calcolato con attenzione al momento esatto in cui ciascun profilo di violazione può dirsi autonomamente accertato, non necessariamente dal primissimo contatto con l'azienda.

La lezione per le aziende: Questi due casi, decisi a pochi mesi di distanza l'uno dall'altro nel 2025, mostrano che il tema dei termini procedurali non è un dettaglio tecnico per soli avvocati: può determinare l'annullamento integrale di una sanzione, anche di importo molto elevato, indipendentemente da quanto fondata fosse la violazione contestata nel merito. Un'azienda che riceve una contestazione dovrebbe sempre far verificare, insieme al proprio consulente legale, la cronologia esatta del procedimento – non solo preparare una difesa sul merito della violazione.

Fonte: Il Sole 24 Ore – NT+ Diritto, “Sanzioni privacy senza attese infinite: la Cassazione mette un limite ai tempi del Garante” – <https://ntplusdiritto.ilsole24ore.com/art/sanzioni-privacy-senza-attese-infinite-cassazione-mette-limite-tempi-garante-AIUqmHu>; Federprivacy, “La Cassazione dà ragione a Report” – <https://www.federprivacy.org/informazione/societa/la-cassazione-da-ragione-a-report-il-garante-della-privacy-non-puo-esercitare-il-suo-potere-senza-limiti-di-tempo>; Studio Legale Stefanelli, “Sanzione oppure no? La Cassazione chiarisce i termini del Garante Privacy” – <https://www.studiolegalestefanelli.it/it/>

[approfondimenti/sanzione-oppure-no-la-cassazione-chiarisce-i-termini-del-garante-privacy/](#)

32.5 32.5 Strumenti Alternativi al Contenzioso: Ravvedimento e Riduzione della Sanzione

Prima di arrivare al contenzioso giudiziario, esistono strumenti che un'azienda può valutare per limitare i danni economici e reputazionali:

- **Pagamento in misura ridotta:** in alcuni regimi transitori e per specifiche categorie di violazioni meno gravi, la legge ha previsto la possibilità di pagare una sanzione ridotta entro un termine breve, rinunciando però alla possibilità di contestare successivamente il merito.
- **Collaborazione attiva durante l'istruttoria:** come visto nel Capitolo 29, dimostrare un percorso di adeguamento serio, anche se non perfetto, e fornire riscontro tempestivo e collaborativo alle richieste del Garante è un elemento che l'Art. 83.2 GDPR impone di considerare nella determinazione dell'importo della sanzione.
- **Impegni e misure correttive proposte spontaneamente:** in alcuni casi, proporre spontaneamente all'Autorità un piano di remediation prima della conclusione dell'istruttoria può influenzare positivamente l'esito, anche se non esiste una garanzia procedurale di questo tipo paragonabile ad altri ordinamenti.

Nota Pratica

Quando conviene fare opposizione, in sintesi: Vale la pena valutare il ricorso al Tribunale quando: (a) ci sono evidenti vizi procedurali nella cronologia del procedimento del Garante (termini non rispettati, come nei casi RAI ed Enel); (b) la violazione contestata nel merito è discutibile o l'importo della sanzione appare manifestamente sproporzionato rispetto alla gravità; (c) l'azienda ha elementi difensivi solidi che non sono stati adeguatamente considerati nella fase amministrativa. Conviene invece valutare di non opporsi, e concentrarsi sulla remediation, quando la violazione è incontestabile nel merito e i vizi procedurali sono assenti o marginali: il contenzioso ha costi (legali, di tempo, e di esposizione mediatica) che vanno sempre confrontati con le reali probabilità di successo.

33 Capitolo 33: Secondo Test di Verifica – Capitoli 17–32 (30 Domande)

Il test del Capitolo 15 copriva i Capitoli 1–14. Questo secondo test copre tutto il resto del manuale: glossario e normativa NIS 2 di base, cybersecurity avanzata, dipendenti, sito web, casi reali e giurisprudenza, roadmap, AI Act, settori specifici, DPO, trasferimenti extra-UE, ispezioni, videosorveglianza intelligente, esercitazioni pratiche e procedimento sanzionatorio. Soltanto UNA delle quattro opzioni è corretta. Le soluzioni si trovano nel Capitolo 34.

Domanda 1. Una Regolamento (UE) e una Direttiva (UE) si distinguono perché:

- A Il Regolamento richiede sempre una legge nazionale di recepimento, la Direttiva no.
- B Sono sinonimi nel linguaggio giuridico europeo.
- C Il Regolamento è direttamente applicabile in tutti gli Stati membri senza recepimento; la Direttiva fissa un obiettivo che ogni Stato deve recepire con una propria legge.
- D La Direttiva si applica solo alle aziende pubbliche.

Domanda 2. Una VLAN dedicata ai PLC e ai robot di un impianto industriale (vedi Cap. 18.1) dovrebbe essere configurata, per ridurre il rischio cyber, in modo che:

- A Sia raggiungibile da internet per la teleassistenza del fornitore, sempre attiva.
- B Sia isolata, senza accesso diretto a internet, con traffico verso le altre VLAN limitato e autorizzato solo per le esigenze operative strettamente necessarie.
- C Condividi lo stesso segmento di rete degli uffici per semplicità di gestione IT.
- D Non richieda alcuna segmentazione se l'azienda ha meno di 50 dipendenti.

Domanda 3. Il Privileged Access Management (PAM, Cap. 18.2) raccomanda che un amministratore di sistema:

- A Usi sempre lo stesso account, sia per email personale che per attività di amministrazione, per comodità.
- B Condividi la password di amministratore con tutto il team IT su un foglio condiviso.
- C Abbia un account standard separato da un account privilegiato, usato solo per le attività di amministrazione e soggetto ad audit.
- D Non abbia bisogno di MFA se lavora sempre dall'ufficio.

Domanda 4. Durante la risposta a un attacco Ransomware (Cap. 18.4), la prima regola da seguire è:

- A Riavviare immediatamente tutti i server per liberare la memoria.
- B Pagare subito il riscatto per recuperare i dati nel minor tempo possibile.

- C Non riavviare i sistemi compromessi (si perdono prove in memoria volatile) e isolare la rete.
- D Attendere il lunedì successivo per non interrompere la produzione del weekend.

Domanda 5. Il Medico Competente (Cap. 19.2) che effettua la sorveglianza sanitaria dei lavoratori comunica al datore di lavoro:

- A La diagnosi medica completa del lavoratore.
- B Solo il giudizio di idoneità (idoneo / idoneo con limitazioni / non idoneo), non la diagnosi.
- C Nulla; il datore di lavoro non ha diritto a sapere nulla sull'esito della visita.
- D La cartella clinica integrale su richiesta scritta del datore di lavoro.

Domanda 6. Quale delle seguenti attività di controllo sul lavoratore richiede SEMPRE accordo sindacale o autorizzazione dell'Ispettorato del Lavoro (Cap. 19.3)?

- A Il log di accesso al PC aziendale per finalità di sicurezza IT, con informativa chiara.
- B La geolocalizzazione GPS dei dipendenti per controllo disciplinare.
- C La videosorveglianza di un magazzino automatizzato senza presenza stabile di lavoratori.
- D L'informativa privacy pubblicata sulla intranet aziendale.

Domanda 7. Secondo le Linee Guida Cookie del Garante (Cap. 20.2), un banner cookie conforme deve avere:

- A Solo il pulsante "Accetta Tutti", ben visibile.
- B Un pulsante "Accetta Tutti" e un pulsante "Rifiuta Tutti" di uguale evidenza grafica, senza depositare cookie non tecnici prima della scelta dell'utente.
- C Il pulsante di rifiuto nascosto in un menu secondario per non scoraggiare l'accettazione.
- D Nessun obbligo di registrare la scelta dell'utente.

Domanda 8. Nel caso H&M (Cap. 21.2, Provvedimento n. 9880398 del 2 marzo 2023), la sanzione di 50.000 euro è stata motivata principalmente da:

- A Mancanza di un'assicurazione cyber.
- B Videosorveglianza attiva 24/7 in aree riservate ai lavoratori, senza accordo sindacale né autorizzazione ITL, con conservazione delle immagini oltre i limiti previsti.
- C Uso di un algoritmo di hashing obsoleto per le password dei clienti.
- D Mancata nomina del DPO.

Domanda 9. Nel caso Ambrosetti (Cap. 21.4, Provvedimento n. 280/2026), una delle violazioni accertate riguardava:

- A L'uso del Wi-Fi pubblico da parte dei dipendenti.

- B La conservazione di circa 36.000 password in chiaro e di altre 98.000 con hashing MD5 obsoleto.
- C La mancata installazione dell'antivirus sui PC aziendali.
- D Un consenso al marketing raccolto in modo non specifico.

Domanda 10. Secondo la sentenza CGUE “Österreichische Post” (Cap. 21.8, Causa C-300/21), il diritto al risarcimento ex Art. 82 GDPR:

- A Nasce automaticamente dalla sola violazione del GDPR, senza bisogno di provare alcun danno.
- B Richiede tre condizioni cumulative (violazione, danno, nesso causale), ma non esiste una soglia minima di gravità del danno per poterlo richiedere.
- C È riconosciuto solo per danni superiori a 10.000 euro.
- D Non è mai applicabile ai danni immateriali.

Domanda 11. La sentenza “Google Spain” (Cap. 21.9, Causa C-131/12, 2014) ha stabilito che:

- A I motori di ricerca non sono mai responsabili dei dati personali che indicizzano.
- B Il gestore di un motore di ricerca è responsabile del trattamento dei dati che appaiono nei risultati di ricerca e può essere obbligato a deindicizzarli, anche se l'informazione originale resta lecita altrove.
- C Il diritto all'oblio si applica solo ai minori.
- D Solo l'autore originale del contenuto può essere obbligato a rimuoverlo.

Domanda 12. Nella roadmap di adeguamento in 12 mesi (Cap. 22), in quale fase è collocata la sicurezza IT di base (MFA, backup 3-2-1, crittografia, VLAN, patch management)?

- A Al Mese 12, come ultimissima attività.
- B Al Mese 6, dopo Registro, informative e DPA con i fornitori, e prima delle policy operative di dettaglio.
- C Al Mese 1, prima di qualsiasi altra attività documentale.
- D Non è prevista nella roadmap: va gestita separatamente dal reparto IT, fuori da ogni pianificazione.

Domanda 13. Secondo l'AI Act (Cap. 23.1), un sistema di intelligenza artificiale usato per lo screening dei CV nei processi di reclutamento è classificato come:

- A Rischio minimo, nessun obbligo aggiuntivo.
- B Rischio inaccettabile, vietato in assoluto.
- C Alto rischio: richiede DPIA obbligatoria, registrazione in database UE e supervisione umana obbligatoria.

D Rischio limitato, basta un avviso di trasparenza.

Domanda 14. Inserire dati personali di clienti in un prompt di un chatbot AI pubblico, hosted negli Stati Uniti (Cap. 23.2), comporta il rischio di:

- A Nessun rischio, perché l'AI è un semplice strumento di produttività.
- B Un trasferimento di dati personali extra-UE non valutato, e possibile utilizzo dei dati per il training del modello.
- C Rischio solo se i dati riguardano minori.
- D Rischio solo se il chatbot è gratuito.

Domanda 15. Nel trattamento dei dati B2B (Cap. 24.2), rispetto al trattamento B2C:

- A Non si applica mai il GDPR.
- B Si applica lo stesso regime pieno del B2C in ogni caso.
- C Il GDPR si applica solo alla persona fisica di riferimento (es. il referente aziendale), non alla società in quanto tale.
- D Il consenso non serve mai, nemmeno per il marketing diretto al referente aziendale.

Domanda 16. Dopo la sentenza Schrems II (Cap. 21.7 e Cap. 25), un trasferimento di dati personali verso un fornitore cloud USA che si basa su Clausole Contrattuali Tipo (SCC) richiede:

- A Nessuna valutazione aggiuntiva: le SCC bastano sempre da sole.
- B Una valutazione caso per caso se le garanzie contrattuali siano effettivamente sufficienti rispetto al contesto giuridico del Paese di destinazione, con eventuali misure supplementari.
- C L'autorizzazione preventiva del Parlamento Europeo per ogni singolo trasferimento.
- D È sempre illegale trasferire dati verso gli USA, senza eccezioni.

Domanda 17. Il DPO (Data Protection Officer, Cap. 26) non può, per evitare un conflitto di interessi:

- A Fornire pareri tecnici sulla conformità dei trattamenti.
- B Essere anche il soggetto che decide mezzi e finalità del trattamento (es. il direttore IT con potere decisionale sui sistemi), né gestire il relativo budget.
- C Riferire direttamente al vertice dell'organizzazione.
- D Essere un consulente esterno.

Domanda 18. Nel settore sanitario (Cap. 27), l'accesso al fascicolo sanitario elettronico di un paziente da parte di un dipendente amministrativo non coinvolto nella sua cura, per pura curiosità, costituisce:

- A Una prassi tollerata se il dipendente non diffonde l'informazione a terzi.

- B Un trattamento di dati sanitari (categoria particolare, Art. 9) privo di base giuridica, sanzionabile indipendentemente dalla diffusione a terzi.
- C Un comportamento lecito se l'azienda ha un legittimo interesse generico alla trasparenza interna.
- D Un'attività che richiede solo una nota informale al dipendente.

Domanda 19. Una PMI che riceve una richiesta di accesso ai dati (Art. 15) da un ex cliente (Cap. 28, FAQ) deve rispondere, di norma:

- A Mai, se il rapporto contrattuale è terminato.
- B Entro un mese dalla richiesta, salvo proroga motivata per richieste complesse.
- C Entro un anno, senza eccezioni.
- D Solo se il cliente paga una tariffa per l'estrazione dei dati.

Domanda 20. Durante un'ispezione del Nucleo Speciale Privacy e Frodi Tecnologiche della Guardia di Finanza (Cap. 29), creare un documento con data retroattiva per "coprire" una lacuna di compliance è:

- A Una pratica accettabile se il documento riflette comunque la realtà operativa.
- B Una pratica gravemente rischiosa: gli ispettori verificano i metadati dei file, e la condotta aggrava sensibilmente la posizione dell'azienda.
- C Consigliata dal Garante stesso come misura di buona fede.
- D Irrilevante, perché gli ispettori non hanno strumenti per verificare le date dei file.

Domanda 21. Un sistema di riconoscimento facciale installato da un'azienda privata per il controllo accessi ai tornelli (Cap. 30.2):

- A Rientra automaticamente tra le eccezioni dell'AI Act riservate alle forze dell'ordine.
- B Non rientra tra le eccezioni dell'AI Act: richiede DPIA obbligatoria, consenso esplicito di ogni persona identificata, e spesso parere preventivo del Garante.
- C È sempre vietato in assoluto, senza eccezioni di alcun tipo.
- D Non richiede alcuna valutazione, essendo un dato biometrico equiparato a una password.

Domanda 22. Nell'Esercitazione 1 del Cap. 31 (Registro Art. 30), la criticità più grave individuata nel caso "Fenice Arredi" riguardava:

- A L'uso di un gestionale cloud italiano per la vendita.
- B Le telecamere nel magazzino installate da due anni senza accordo sindacale né cartelli informativi.
- C L'invio della newsletter mensile.
- D L'indirizzo email raccolto per la consegna.

Domanda 23. Nell'Esercitazione 2 del Cap. 31 (data breach in uno studio dentistico), l'invio per errore dell'elenco pazienti a un'ex collega che dichiara di averlo cancellato:

- A Non è un data breach, perché l'errore è stato in buona fede.
- B È un data breach (violazione di Riservatezza) che va comunque notificato al Garante, perché trattandosi di dati sanitari il rischio non può essere escluso solo sulla base di una dichiarazione verbale.
- C Va notificato solo se la destinataria avesse effettivamente diffuso il file a terzi.
- D Richiede solo una nota interna, senza alcun obbligo verso il Garante.

Domanda 24. Nell'Esercitazione 4 del Cap. 31 (impianto SCADA del settore idrico), Idrotek rientra nel perimetro NIS 2 anche se non gestisce direttamente il servizio idrico, perché:

- A La Direttiva NIS 2 si applica solo ai gestori finali del servizio, quindi Idrotek non rientra mai nel perimetro.
- B La NIS 2 include anche i fornitori critici della filiera (qui, chi gestisce in supervisione remota gli impianti) che, se compromessi, possono mettere a rischio la continuità del servizio essenziale.
- C Solo le aziende con più di 250 dipendenti rientrano nel perimetro NIS 2.
- D Il perimetro NIS 2 dipende esclusivamente dalla proprietà formale degli impianti.

Domanda 25. Nel procedimento sanzionatorio del Garante (Cap. 32.1), la fase "sanzionatoria in senso stretto" si apre formalmente con:

- A La prima richiesta informale di informazioni durante l'istruttoria.
- B La notifica formale della contestazione di violazione ex Art. 166, comma 5, del Codice Privacy.
- C L'ispezione della Guardia di Finanza, sempre e comunque.
- D Il pagamento della sanzione da parte dell'azienda.

Domanda 26. Una volta ricevuta la contestazione formale, l'azienda ha (Cap. 32.2):

- A 7 giorni per presentare memorie difensive, senza possibilità di proroga.
- B 30 giorni per presentare scritti difensivi o chiedere l'audizione, con possibilità di proroga motivata (di norma non superiore a 15 giorni).
- C Nessun termine: può rispondere quando vuole.
- D 6 mesi, equiparati al termine di prescrizione civile.

Domanda 27. L'opposizione contro un provvedimento sanzionatorio del Garante (Cap. 32.3) va presentata:

- A Al TAR (Tribunale Amministrativo Regionale).

- B Al Tribunale ordinario competente, entro 30 giorni dalla notifica (60 se il ricorrente risiede all'estero).
- C Direttamente alla Corte di Giustizia dell'Unione Europea.
- D Non è previsto alcun rimedio giurisdizionale contro le sanzioni del Garante.

Domanda 28. Secondo la giurisprudenza recente sui termini perentori (Cap. 32.4, casi RAI ed Enel Energia), se il Garante non rispetta il termine di 120 giorni per notificare la contestazione dopo la conclusione dell'istruttoria:

- A Non succede nulla: il termine è solo indicativo.
- B La sanzione può essere annullata dal giudice per vizio procedurale, indipendentemente da quanto fondata fosse la violazione nel merito.
- C L'azienda deve comunque pagare, ma con uno sconto del 50%.
- D Il Garante può semplicemente notificare in ritardo senza alcuna conseguenza giuridica.

Domanda 29. Secondo la giurisprudenza CGUE (Cap. 21.8 e Cap. 21.9), quale affermazione è corretta?

- A Qualsiasi violazione del GDPR genera automaticamente sia un risarcimento sia un obbligo di deindicizzazione.
- B Il risarcimento ex Art. 82 richiede danno provato e nesso causale (Österreichische Post); il diritto all'oblio (Google Spain) richiede invece un bilanciamento tra il diritto alla deindicizzazione e l'interesse pubblico all'informazione – sono due test giuridici distinti, non intercambiabili.
- C Le sentenze della CGUE non sono vincolanti per i giudici nazionali degli Stati membri.
- D Google Spain e Österreichische Post riguardano lo stesso identico principio giuridico.

Domanda 30. In generale, quando un'azienda dovrebbe valutare seriamente di NON fare opposizione contro una sanzione del Garante e concentrarsi invece sulla remediation (Cap. 32.5)?

- A Sempre, in ogni caso, perché il contenzioso è sempre la scelta peggiore.
- B Quando la violazione è incontestabile nel merito e non ci sono vizi procedurali significativi nella cronologia del procedimento.
- C Solo se l'importo della sanzione è inferiore a 1.000 euro.
- D Mai: bisogna sempre opporsi per principio, indipendentemente dal merito.

34 Capitolo 34: Soluzioni del Secondo Test (Per il Docente)

- **D1:** [C] – Il Regolamento (es. GDPR, AI Act) è direttamente applicabile; la Direttiva (es. NIS 2) richiede una legge nazionale di recepimento.
- **D2:** [B] – La VLAN industriale va isolata da internet e dal resto della rete, con traffico autorizzato solo per le esigenze operative.
- **D3:** [C] – Il PAM richiede la separazione tra account standard e account privilegiato, con audit degli accessi.
- **D4:** [C] – Non riavviare i sistemi compromessi (si perdono prove in RAM) e isolare la rete è la prima regola dell'Incident Response.
- **D5:** [B] – Il Medico Competente comunica solo il giudizio di idoneità, non la diagnosi, al datore di lavoro.
- **D6:** [B] – La geolocalizzazione GPS per controllo disciplinare richiede sempre accordo sindacale o autorizzazione ITL.
- **D7:** [B] – Parità di evidenza grafica tra Accetta e Rifiuta, nessun cookie non tecnico prima della scelta: è il requisito centrale delle Linee Guida Garante 2021.
- **D8:** [B] – Videosorveglianza 24/7 senza accordo sindacale e con conservazione eccessiva: questo ha motivato la sanzione H&M.
- **D9:** [B] – Password in chiaro e hashing MD5 obsoleto sono le violazioni centrali del caso Ambrosetti (Provv. n. 280/2026).
- **D10:** [B] – Tre condizioni cumulative ma nessuna soglia minima di gravità: è il principio della sentenza Österreichische Post (C-300/21).
- **D11:** [B] – Google Spain (C-131/12) rende il motore di ricerca responsabile del trattamento e consente la deindicizzazione anche se il contenuto originale resta lecito.
- **D12:** [B] – Nella roadmap del Cap. 22, la sicurezza IT di base è collocata al Mese 6, dopo la fase documentale iniziale (Registro, informative, DPA) e prima delle policy operative di dettaglio del Mese 7.
- **D13:** [C] – Lo screening CV con AI è alto rischio: DPIA, registrazione UE, supervisione umana obbligatoria.
- **D14:** [B] – Trasferimento extra-UE non valutato e possibile uso per training: i due rischi principali dell'uso di AI generativa pubblica con dati di clienti.
- **D15:** [C] – Nel B2B il GDPR si applica alla persona fisica di riferimento, non alla società come soggetto giuridico.
- **D16:** [B] – Dopo Schrems II, le SCC restano valide ma richiedono valutazione caso per caso ed eventuali misure supplementari.

- **D17:** [B] – Il DPO non può avere potere decisionale su mezzi/finalità né gestire il budget IT: conflitto di interessi ex Art. 38.6.
- **D18:** [B] – L’accesso senza base giuridica a dati sanitari per curiosità è di per sé sanzionabile, indipendentemente dalla diffusione a terzi.
- **D19:** [B] – Il termine standard di risposta alle richieste Art. 15 è un mese, prorogabile per richieste complesse.
- **D20:** [B] – Creare documenti con data retroattiva è rilevabile dai metadati e aggrava la posizione dell’azienda durante un’ispezione.
- **D21:** [B] – Il riconoscimento facciale per controllo accessi privato non rientra nelle eccezioni AI Act riservate alle forze dell’ordine: richiede DPIA e consenso esplicito.
- **D22:** [B] – Le telecamere senza accordo sindacale per due anni erano la criticità più grave dell’Esercitazione 1.
- **D23:** [B] – Il rischio sui dati sanitari non si esclude solo per la buona fede dichiarata dalla destinataria: va comunque notificato.
- **D24:** [B] – Il perimetro NIS 2 include i fornitori critici della filiera, non solo i gestori finali del servizio essenziale.
- **D25:** [B] – La notifica formale della contestazione ex Art. 166 comma 5 del Codice apre la fase sanzionatoria in senso stretto.
- **D26:** [B] – 30 giorni per memorie/audizione, prorogabili di norma fino a 15 giorni su istanza motivata.
- **D27:** [B] – L’opposizione va al Tribunale ordinario, entro 30 giorni (60 se residente all’estero) ex Art. 78 GDPR e Art. 152 Codice Privacy.
- **D28:** [B] – Il superamento del termine perentorio di 120 giorni può portare all’annullamento della sanzione per vizio procedurale, come nei casi RAI ed Enel Energia.
- **D29:** [B] – Risarcimento (Art. 82) e diritto all’oblio (Art. 17) sono basati su test giuridici distinti: il primo su danno e nesso causale, il secondo su un bilanciamento di interessi.
- **D30:** [B] – Conviene concentrarsi sulla remediation quando la violazione è incontestabile e non ci sono vizi procedurali significativi da far valere.

35 Capitolo 35: Checklist Finale – Concetti Chiave per l’Esame

Questo capitolo non sostituisce lo studio dei singoli capitoli: è una mappa di richiamo rapido, da consultare nei giorni prima dell’esame per verificare di non avere lacune evidenti. Per ogni capitolo sono elencati 2–3 concetti che, con alta probabilità, l’esame chiederà di saper spiegare o applicare. Se uno di questi punti non è chiaro, è il segnale per tornare a ripassare quel capitolo specifico prima di proseguire.

- Cap. 1** Evoluzione storica della privacy (da diritto individuale a diritto collettivo); differenza tra Regolamento e Direttiva UE.
- Cap. 2** I 7 principi dell’Art. 5 (liceità, minimizzazione, esattezza, limitazione conservazione, ecc.) e il principio di Accountability come obbligo di *dimostrare*, non solo rispettare.
- Cap. 3** Le 6 basi giuridiche dell’Art. 6 e quando si applica ciascuna; differenza tra consenso e legittimo interesse; basi giuridiche aggiuntive per i dati particolari (Art. 9).
- Cap. 4** La Triade CIA (Confidenzialità, Integrità, Disponibilità) e come l’Art. 32 la traduce in misure tecniche concrete (VLAN, hashing, backup 3-2-1).
- Cap. 5** Il termine delle 72 ore per la notifica al Garante e da quale momento decorre esattamente (“ragionevole certezza”, non l’inizio dell’attacco).
- Cap. 6** Struttura del Registro Data Breach interno e perché va tenuto anche per incidenti non notificati al Garante.
- Cap. 7** Le 4 fasi della roadmap di adeguamento iniziale (nomina titolare, documentazione, sicurezza tecnica, formazione) e il loro ordine logico.
- Cap. 8** I documenti obbligatori minimi: Registro Art. 30, informative Art. 13/14, nomine dei soggetti autorizzati Art. 29.
- Cap. 9** Le 8 clausole obbligatorie del DPA (Art. 28.3) e quando un fornitore è Responsabile del trattamento invece che Titolare autonomo.
- Cap. 10** Le policy operative principali (BYOD, stampanti, videosorveglianza, email, password, clean desk) e perché sono misure organizzative ex Art. 32.
- Cap. 11** Quando una DPIA è obbligatoria (Art. 35) e la struttura minima di una DPIA (descrizione, necessità/proporzionalità, rischi, misure).
- Cap. 12** I diritti degli interessati (Artt. 15–22) e i termini di risposta; eccezioni al diritto di cancellazione (es. difesa in giudizio).
- Cap. 13** Differenza tra perimetro GDPR e perimetro NIS 2; chi rientra nella NIS 2 (inclusi i fornitori critici della filiera); responsabilità personale dei dirigenti.
- Cap. 14** Perché la formazione è considerata una misura di sicurezza tecnica/organizzativa a tutti gli effetti, non solo un adempimento burocratico.

- Cap. 17** Saper distinguere correttamente i termini base del glossario tecnico-legale (Titolare/Responsabile/Autorizzato; Provvedimento/Sentenza).
- Cap. 18** Segmentazione VLAN per ambienti OT/industriali; le 6 fasi dell'Incident Response (NIST SP 800-61); i 7 segnali di un'email di phishing.
- Cap. 19** Cosa può comunicare il Medico Competente al datore di lavoro (solo idoneità, non diagnosi); quali controlli a distanza richiedono SEMPRE accordo sindacale o autorizzazione ITL.
- Cap. 20** Requisiti del banner cookie conforme (parità Accetta/Rifiuta, nessun cookie prima della scelta).
- Cap. 21** Per ciascuno dei 9 casi: nome del caso, importo/esito, e *perché* è stato sanzionato (il principio normativo violato, non solo il fatto).
- Cap. 22** La sequenza dei 12 mesi della roadmap completa e cosa NON va saltato (es. la sicurezza IT di base al Mese 6).
- Cap. 23** I 4 livelli di rischio dell'AI Act (inaccettabile, alto, limitato, minimo) con un esempio per ciascuno.
- Cap. 24** Perché nel B2B il GDPR si applica alla persona fisica di riferimento, non alla società.
- Cap. 25** Cosa ha stabilito Schrems II sul Privacy Shield e sulle SCC; cos'è il Data Privacy Framework.
- Cap. 26** Le incompatibilità del ruolo di DPO (conflitto di interessi con potere decisionale o gestione budget).
- Cap. 27** Le specificità del trattamento dati in almeno un settore (sanitario, scuola, o HR) trattato nel capitolo.
- Cap. 28** I termini di risposta standard alle richieste più comuni delle PMI (accesso, cancellazione).
- Cap. 29** Comportamenti corretti e errori da evitare durante un'ispezione (mai creare documenti con data retroattiva).
- Cap. 30** Perché il riconoscimento facciale per finalità private non rientra nelle eccezioni dell'AI Act.
- Cap. 31** Saper rifare autonomamente almeno una delle 4 esercitazioni senza guardare la soluzione, individuando le criticità da zero.
- Cap. 32** Le due fasi del procedimento (istruttoria/sanzionatoria), i termini di 30 e 120 giorni, e dove si presenta l'opposizione (Tribunale ordinario, non TAR).
- Cap. 33–34** Rivedere gli errori commessi nel secondo test, non solo le risposte corrette: capire *perché* un'opzione era sbagliata è più utile che sapere solo qual era quella giusta.

Nota Pratica

Come usare questa checklist: Un metodo efficace è coprire la colonna delle risposte (in questo caso, il contenuto dopo ogni voce) e provare a spiegare ad alta voce, con parole proprie, cosa significa ciascun punto, come se lo si stesse spiegando a un collega che non conosce la materia. Se per un punto specifico la spiegazione risulta vaga o incerta, è il segnale chiaro che quel capitolo richiede un altro passaggio di studio, non solo una rilettura veloce.

Appendice A: Schema Riassuntivo – I 7 Principi dell'Art. 5 in una Pagina

#	Principio	Significato	Come si viola
1	Liceità, Correttezza, Trasparenza	Serve base giuridica; niente inganni; info chiare	Trattamento senza base; dark pattern; informativa illeggibile
2	Limitazione della Finalità	Solo per lo scopo dichiarato	Riutilizzare dati raccolti per finalità A in finalità B non comunicata
3	Minimizzazione	Solo i dati strettamente necessari	Raccogliere campi non necessari nei form
4	Esattezza	Dati corretti e aggiornati	Database clienti con indirizzi obsoleti
5	Limitazione Conservazione	Cancellare o anonimizzare dopo il periodo previsto	Conservare dati di 10 anni fa senza motivo
6	Integrità e Riservatezza	Proteggere da accessi non autorizzati, alterazioni, distruzione	Nessun firewall; password in chiaro; no backup
7	Accountability	Dimostrare proattivamente la compliance	Non avere il Registro; non avere le nomine; non avere i DPA

Appendice B: Le 6 Basi Giuridiche dell'Art. 6 – Tabella Decisionale

Art.	Base	Quando usarla	Attenzione
6.1.a	Consenso	Marketing; profilazione; cookie non tecnici	Revocabile; non obbligatorio per il servizio
6.1.b	Contratto	Esecuzione o pre-contrattuale	Solo per dati necessari al contratto
6.1.c	Obbligo legale	Fatture; INPS; conservazione obbligatoria	Non serve consenso
6.1.d	Interessi vitali	Emergenza medica; pericolo di vita	Residuale; solo se impossibile usare altro
6.1.e	Interesse pubblico	PA; università; enti pubblici	Solo per funzioni istituzionali
6.1.f	Legittimo interesse	Videosorveglianza; sicurezza IT; soft-spam B2B	Richiede LIA documentata

Appendice C: Contatti Utili per la Compliance

Garante Privacy Italia <https://www.garanteprivacy.it> – Tel. 06/69677.1

Portale Notifica Data Breach <https://www.garanteprivacy.it> (sezione “Notifica violazione dati”)

ACN – Agenzia Cybersicurezza Nazionale <https://www.acn.gov.it> – email: acn@acn.gov.it

CSIRT Italia <https://www.csirt.gov.it> – Notifica incidenti NIS 2

Ispettorato Nazionale del Lavoro (ITL) <https://www.ispettorato.gov.it> – Autorizzazioni videosorveglianza e GPS

EDPB – Comitato Europeo <https://edpb.europa.eu> – Linee guida e decisioni vincolanti

EUR-Lex – Testi normativi UE <https://eur-lex.europa.eu> – GDPR, NIS 2, AI Act, SCC

Data Privacy Framework <https://www.dataprivacyframework.gov/list> – Verifica certificazione USA

Appendice D: Fonti e Riferimenti Consultati

Questo manuale è stato redatto sulla base del testo normativo ufficiale (GDPR, NIS 2, AI Act, Statuto dei Lavoratori, Codice Privacy) e di ricerche su fonti giuridiche e specialistiche aggiornate al momento della stesura. Di seguito l'elenco completo delle fonti consultate, organizzate per area tematica.

D.1 Normativa Primaria

- Regolamento (UE) 2016/679 (GDPR) – <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- Direttiva (UE) 2022/2555 (NIS 2) – <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32022L2555>
- Regolamento (UE) 2024/1689 (AI Act) – <https://eur-lex.europa.eu/legal-content/IT/TXT/?uri=CELEX:32024R1689>
- Legge 20 maggio 1970, n. 300 (Statuto dei Lavoratori), Art. 4
- D.Lgs. 30 giugno 2003, n. 196 (Codice Privacy) e successive modifiche
- D.Lgs. 10 agosto 2018, n. 101 (Adeguamento Codice Privacy al GDPR)
- D.Lgs. 9 aprile 2008, n. 81 (Testo Unico Sicurezza sul Lavoro)

D.2 Registro delle Attività di Trattamento e Documenti Obbligatori

- SupportHost – “GDPR, registro dei trattamenti” – <https://supporthost.com/it/gdpr-registro-dei-trattamenti/>
- LDG Service – “Privacy: Aggiornamenti sulla Protezione Dati dal 2022 al 14 Marzo 2025” – <https://www.ldgservice.it/privacy-aggiornamenti-sulla-protezione-dati-dal-2022-al-14-marzo-2025/>
- MediaLaws – “Il registro delle attività di trattamento previsto dal GDPR” – <https://www.medialaws.eu/il-registro-delle-attivita-di-trattamento-previsto-dal-gdpr-piu-di-uno-strumento-di-mera-compliance/>
- Legalblink – “Adeguamento aziendale al GDPR: guida privacy per imprese” – <https://legalblink.it/post/adeguamento-gdpr-impresa-.html>
- Agenda Digitale – “Redazione registro del trattamento GDPR: guida pratica per le aziende” – <https://www.agendadigitale.eu/sicurezza/privacy/redazione-registro-del-trattamento-gdpr-guida-pratica-per-le-aziende/>
- Studio Legale Calvello – “Privacy aziendale: quali documenti sono obbligatori per essere in regola” – <https://www.studiolegalecalvello.it/documenti-obbligatori-privacy-aziendale/>
- Studio Legale Calvello – “Adeguamento privacy per aziende con meno di 50 dipendenti” – <https://www.studiolegalecalvello.it/adeguamento-gdpr-pmi-cosa-serve-davvero/>

D.3 Policy Operative – BYOD, Videosorveglianza, Stampanti

- Elle Di Ufficio – “Videosorveglianza aziendale: normativa GDPR e soluzioni IP” – <https://www.ellediufficio.it/videosorveglianza-aziendale>
- Federprivacy – “BYOD e app di monitoraggio in azienda: rischi e misure organizzative” – <https://www.federprivacy.org/informazione/primo-piano/byod-e-app-di-monitoraggio-in-azienda-rischi-e-misure-organizzative>
- Veesion – “Modello di lettera ai dipendenti sull’impianto di videosorveglianza” – <https://veesion.io/it/informare-i-dipendenti-sul-sistema-di-videosorveglianza-raccomandazioni-e-modello-di-lettera/>
- SINE Sicurezza – “Videosorveglianza aziendale: cosa dice la normativa privacy” – <https://sicurezza.sine.it/news-sicurezza-lavoro/videosorveglianza-aziendale-cosa-dice-la-normativa-privacy/>
- Cyber Security 360 – “BYOD e GDPR, regole di conformità per un corretto trattamento dei dati personali” – <https://www.cybersecurity360.it/legal/privacy-dati-personali/byod-e-gdpr-regole-di-conformita-per-un-corretto-trattamento-dei-dati-personali/>
- Fluida – “BYOD in azienda: rischi, privacy e policy” – <https://www.fluida.io/blog/byod-in-azienda-rischi-privacy-e-linee-guida-per-una-policy-conforme>
- EDPB – Linee Guida 3/2019 sul trattamento dei dati personali attraverso dispositivi video – https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-32019-processing-personal-data-through-video_it

D.4 Il DPA e l’Art. 28 GDPR

- Iubenda – “Contratto di nomina a responsabile del trattamento (DPA) – template GDPR” – <https://www.iubenda.com/it/blog/contratto-di-nomina-a-responsabile-del-trattamento-dpa-template-gdpr/>
- PrivacyLab – “Gestione del responsabile esterno e GDPR” – <https://www.privacylab.it/IT/1044/gestione-del-responsabile-esterno/>
- GestionaleAuto.com – “Accordo ex art. 28 GDPR (DPA)” – <https://www.gestionaleauto.com/accordoart28gdpr/>
- Altalex – “Art. 28 GDPR – Responsabile del trattamento” – <https://www.altalex.com/documents/news/2018/04/12/articolo-28-gdpr-responsabile-del-trattamento>
- Frareg – “Clausole contrattuali standard e Responsabili esterni del trattamento” – <https://www.frareg.com/it/legge-sulla-privacy/clausole-contrattuali-standard-e-responsabili-esterni-del-trattamento-la-commissione-europea-pubblica-il-proprio-modello/>
- Bollettino ADAPT – “Come redigere un atto di nomina a Responsabile del trattamento” – <https://www.bollettinoadapt.it/come-redigere-un-atto-di-nomina-a-responsabile-del-trattamento-dei-dati-personali-ex-art-28-del-regolamento-ue-2016-679/>

- Federprivacy – “Clausole contrattuali tipo da usare per la nomina del Responsabile del trattamento” – <https://www.federprivacy.org/informazione/primo-piano/clausole-contrattuali-tipo-da-usare-per-la-nomina-del-responsabile-del-trattamento>
- AvvocatiTech – “Nomina a responsabile del trattamento e Data Processing Agreement (DPA)” – <https://www.avvocatitech.com/nomina-responsabile-trattamento-data-processing-agreement-gdpr/>

D.5 DPIA – Valutazione d’Impatto

- Garante Privacy – Infografica “Valutazione d’impatto sulla protezione dei dati (DPIA)” – <https://www.garanteprivacy.it/documents/10160/0/Infografica++Valutazione+d+impatto+sulla+protezione+dei+dati++DPIA.pdf>
- Mondo Privacy – “Valutazione d’impatto privacy DPIA: quando è obbligatoria?” – <https://mondoprivacy.it/blog/legge-privacy/valutazione-dimpatto-privacy-dpia-quando-e-obbligatoria/>
- Protezione Dati Personali – “Valutazione di impatto (DPIA) e rischio del trattamento” – <https://protezionedatipersonali.it/valutazione-impatto-e-rischio-trattamento>
- Garante Privacy – “Valutazione d’impatto della protezione dei dati (DPIA)” – <https://www.garanteprivacy.it/valutazione-d-impatto-della-protezione-dei-dati-dpia->
- Cyber Security 360 – “Valutazione d’impatto sulla protezione dei dati: quando e come realizzare una DPIA” – <https://www.cybersecurity360.it/legal/privacy-dati-personali/valutazione-dimpatto-sulla-protezione-dei-dati-quando-e-come-realizzare-una-dpia/>
- PrivacyLab – “Valutazione d’Impatto Protezione Dati: Quando è Obbligatoria?” – <https://www.privacylab.it/IT/458/DPIA-quando-Á-obbligatoria%3F/>
- Ailance – “Quando deve essere effettuata una valutazione d’impatto sulla protezione dei dati?” – <https://2b-advice.com/it/2025/05/06/quando-deve-essere-effettuata-una-valutazione-dimpatto-sulla-protezione-dei-dati/>
- Garante Privacy – Provvedimento 11 ottobre 2018, Elenco delle tipologie di trattamenti soggetti a DPIA – <https://www.garanteprivacy.it/documents/10160/0/Provvedimento+n.+467+dell%2711+ottobre+2018.pdf>
- Gruppo di Lavoro Art. 29 – Linee Guida WP248 sulla DPIA – https://edpb.europa.eu/our-work-tools/our-documents/wp29-guidelines/guidelines-privacy-impact-assessment_it

D.6 Standard Tecnici e Cybersecurity

- NIST Special Publication 800-63B – Digital Identity Guidelines (Authentication and Lifecycle Management) – <https://pages.nist.gov/800-63-4/>
- NIST Special Publication 800-61 – Computer Security Incident Handling Guide
- ENISA – Agenzia dell’Unione Europea per la Cybersicurezza – <https://www.enisa.europa.eu>

D.7 Casi Reali e Provvedimenti Sanzionatori (Capitolo 21)

A differenza delle versioni precedenti di questo materiale, ognuno dei 9 casi del Capitolo 21 (6 provvedimenti amministrativi e 3 sentenze della Corte di Giustizia dell'Unione Europea) è stato verificato individualmente contro fonti giornalistiche o professionali specializzate che riportano il numero di provvedimento o il numero di causa e la data esatta. La fonte specifica per ciascun caso è citata in coda al caso stesso, nel Capitolo 21. Per la consultazione del testo integrale di un provvedimento o di una sentenza, le sezioni ufficiali delle rispettive Autorità sono:

- Garante Privacy Italia – Sezione Provvedimenti – <https://www.garanteprivacy.it/home/provvedimenti>
- CNIL (Francia) – Sanctions – <https://www.cnil.fr/fr/sanctions>
- AEPD (Spagna) – Resoluciones – <https://www.aepd.es/es/documento/resoluciones>
- Corte di Giustizia dell'Unione Europea – Curia (motore di ricerca sentenze) – <https://curia.europa.eu>
- EUR-Lex – Sintesi e testo delle sentenze CGUE – <https://eur-lex.europa.eu>

Attenzione – Violazione Comune

Nota metodologica: I provvedimenti amministrativi possono essere oggetto di ricorso e di successiva revisione o annullamento da parte del giudice ordinario. L'importo e le circostanze riportate nel Capitolo 21 si riferiscono allo stato del provvedimento risultante dalle fonti citate al momento della stesura di questo manuale (giugno 2026); si raccomanda di verificare, per un uso professionale, se siano intervenute decisioni successive.

D.8 Il Procedimento Sanzionatorio e il Diritto di Opposizione (Capitolo 32)

I contenuti del Capitolo 32 sono stati verificati contro il quadro normativo (Art. 78 GDPR; Artt. 152, 157 e 166 del Codice Privacy; Art. 10 D.Lgs. 150/2011; Regolamento del Garante n. 1/2019 e n. 2/2019) e contro la giurisprudenza più recente della Corte di Cassazione in materia di termini procedurali:

- Garante Privacy Italia, Provvedimento del 18 luglio 2023 [doc. web n. 9929053] (citato come esempio di clausola di opposizione standard) – <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/9929053>
- Agenda Digitale, “Procedimento istruttorio del Garante privacy per sanzioni Gdpr, come funziona” – <https://www.agendadigitale.eu/sicurezza/privacy/procedimento-istruttorio-del-garante-privacy-per-sanzioni-gdpr-come-funziona/>
- Il Sole 24 Ore – NT+ Diritto, “Sanzioni privacy senza attese infinite: la Cassazione mette un limite ai tempi del Garante” (Cassazione, sentenza n. 759/2025) – <https://ntplusdiritto.ilsole24ore.com/art/sanzioni-privacy-senza-attese-infinite-cassazione-mette-limite-tempi-garante-AIUqmHu>

- Studio Legale Stefanelli & Stefanelli, “Sanzione oppure no? La Cassazione chiarisce i termini del Garante Privacy” (Cassazione, Sez. I Civile, sentenza n. 18583/2025, caso Enel Energia) – <https://www.studiolegalestefanelli.it/it/approfondimenti/sanzione-oppure-no-la-cassazione-chiarisce-i-termini-del-garante-privacy/>
- Federprivacy, “La Cassazione dà ragione a Report: il Garante della Privacy non può esercitare il suo potere senza limiti di tempo” – <https://www.federprivacy.org/informazione/societa/la-cassazione-da-ragione-a-report-il-garante-della-privacy-non-puo-esercitare-il-suo-potere-senza-limiti-di-tempo>
- Giustizia Insieme, “Sanzioni privacy e poteri del giudice: i principi affermati dalla Corte di cassazione” – <https://www.giustiziainsieme.it/it/diritto-civile/2945-sanzioni-privacy-e-poteri-del-giudice-i-principi-affermati-dalla-corte-di-cassazione>

D.9 Riferimenti Istituzionali Generali

L’elenco dei portali istituzionali di consultazione corrente (Garante Privacy, ACN, CSIRT, ED-PB, EUR-Lex, Ispettorato del Lavoro, Data Privacy Framework) è riportato nel Capitolo 17 (Webgrafia) e nell’Appendice C (Contatti Utili).

Appendice E: Glossario per lo Studente – Termini di Base

Il Capitolo 17 contiene un glossario tecnico-normativo per chi ha già familiarità con il linguaggio giuridico. Questa appendice è pensata per chi parte davvero da zero: spiega con parole semplici, ed esempi quotidiani, anche i concetti più elementari che il resto del manuale presuppone già acquisiti. Si raccomanda di leggerla *prima* del Capitolo 1, non come riferimento successivo.

Dato personale	Qualunque informazione che permette di identificare una persona, direttamente (il nome) o indirettamente (un numero di targa, un indirizzo IP, una foto del viso). Non serve che l'informazione sia "segreta": anche il colore degli occhi di una persona nominata è un dato personale.
Interessato	La persona fisica a cui si riferisce il dato personale. Se un'azienda conserva l'indirizzo email di Mario, Mario è l'"interessato" di quel trattamento. Non è un termine che indica curiosità o coinvolgimento: è un ruolo giuridico preciso.
Trattamento	Qualsiasi operazione compiuta su un dato personale: raccoglierlo, salvarlo, consultarlo, modificarlo, condividerlo, persino cancellarlo. Anche scrivere un nome su un foglio di carta è, tecnicamente, un "trattamento".
 Titolare del trattamento	Chi decide <i>perché</i> e <i>come</i> un dato viene trattato. Tipicamente è l'azienda stessa (la persona giuridica), rappresentata legalmente dal suo amministratore o legale rappresentante. È la figura che ha la responsabilità principale.
Responsabile del trattamento	Un soggetto esterno (spesso un fornitore) che tratta dati <i>per conto</i> del Titolare, seguendo le sue istruzioni. Esempio: un'azienda di email marketing che invia newsletter per conto di un negozio online è il Responsabile; il negozio è il Titolare.
Soggetto autorizzato (o "incaricato")	Una persona fisica, tipicamente un dipendente, che tratta dati personali nell'ambito del proprio lavoro, sotto l'autorità del Titolare. Un commesso che inserisce gli ordini dei clienti nel gestionale è un soggetto autorizzato.
Base giuridica	La ragione legale che permette di trattare un dato. Senza una base giuridica valida (vedi Capitolo 3), qualsiasi trattamento è illegale, anche se fatto in buona fede.
Consenso	Una delle basi giuridiche possibili: l'interessato accetta liberamente, in modo specifico e informato, che i suoi dati vengano trattati per uno scopo preciso. Non è l'unica base giuridica esistente, e non è sempre quella più adatta (vedi Capitolo 3.1).
Informativa privacy	Il documento (spesso una pagina web o un foglio cartaceo) con cui un'azienda spiega all'interessato, <i>prima</i> di raccogliere i suoi dati, chi è, cosa farà con quei dati, per quanto tempo li terrà e quali diritti l'interessato ha. Non è facoltativa: è obbligatoria quasi sempre.

Data breach (violazione dei dati)	Un incidente che compromette la sicurezza dei dati personali: un furto, una perdita, un accesso non autorizzato, o anche solo l'invio per errore di un'email alla persona sbagliata. Non richiede necessariamente un hacker: un errore umano basta.
Sanzione amministrativa	La multa che un'Autorità di controllo (in Italia, il Garante) può imporre a un'azienda che viola il GDPR. È distinta da un'eventuale responsabilità penale, che in Italia esiste solo per condotte particolarmente gravi (vedi Capitolo 17, voce "Codice Privacy").
Autorità di controllo ("il Garante")	L'ente pubblico indipendente che vigila sull'applicazione del GDPR in un Paese. In Italia si chiama "Garante per la Protezione dei Dati Personali"; in Francia è la CNIL; in Spagna l'AEPD. Ogni Paese UE ne ha una.
Provvedimento	L'atto formale con cui un'Autorità di controllo conclude un'istruttoria, esprimendo una decisione (es. una sanzione, un ordine di correzione, o l'archiviazione del caso). Ogni provvedimento ha un numero identificativo univoco.
Sentenza	La decisione di un giudice (un Tribunale, o la Corte di Giustizia dell'Unione Europea per le questioni di diritto UE) su una controversia giuridica. È diversa da un provvedimento amministrativo: nasce da un processo giudiziario, non da un'istruttoria di un'Autorità di controllo.
Articolo (di una legge)	Le leggi sono divise in articoli numerati, spesso a loro volta divisi in "paragrafi" o "commi". Quando questo manuale scrive "Art. 5" si intende l'Articolo numero 5 del Regolamento GDPR. La sigla "Art. 6.1.a" significa: Articolo 6, paragrafo 1, lettera a.
Regolamento (UE)	Una legge europea che si applica automaticamente e direttamente in tutti i Paesi membri, senza bisogno che ogni parlamento nazionale la approvi separatamente. Il GDPR è un Regolamento (vedi Capitolo 1.3 per il confronto con le Direttive).
Direttiva (UE)	Una legge europea che stabilisce un obiettivo, ma lascia a ogni Paese membro il compito di scrivere una propria legge nazionale per raggiungerlo. La NIS 2 è una Direttiva.
Crittografia / Cifratura	Una tecnica matematica che trasforma un dato leggibile in una sequenza illeggibile, decifrabile solo con una chiave segreta. Serve a proteggere i dati anche se vengono rubati: senza la chiave, restano incomprensibili.
Hash (funzione di)	Una tecnica matematica diversa dalla crittografia: trasforma un dato in una sequenza di lunghezza fissa che <i>non si può invertire</i> per tornare al dato originale. Si usa tipicamente per le password: il sistema non salva la password ma il suo "hash", e verifica gli accessi confrontando hash, non password in chiaro (vedi Capitolo 4.2).
Pseudonimizzazione	Sostituire un dato identificativo (es. il nome) con un codice (es. "Utente_4521"), mantenendo da qualche parte una tabella segreta che permette di tornare indietro. Diversa dall'anonimizzazione, che è irreversibile.

- VPN** Virtual Private Network: una tecnologia che crea un collegamento cifrato e protetto tra un dispositivo (es. il laptop di un dipendente da casa) e la rete aziendale, impedendo che terzi intercettino il traffico.
- MFA / Autenticazione a due fattori** Un sistema di accesso che richiede non solo la password, ma anche una seconda prova di identità (un codice ricevuto via app o SMS, un'impronta digitale). Rende molto più difficile l'accesso non autorizzato anche se la password viene scoperta.

Indice Analitico

Accountability, [10](#)
AI Act, [74](#)

Backup 3-2-1, [16](#)
BYOD, [32](#)

Consenso, [12](#)
Cookie, [62](#)
Crittografia, [15](#)

Dark Pattern, [8](#)
Data Breach, [19](#)
Data Retention, [9](#)
Diritti degli interessati, [40](#)
Diritto all'oblio, [69](#)
DPA (Data Processing Agreement), [29](#)
DPIA, [38](#)
DPO (Data Protection Officer), [80](#)

Google Spain (sentenza CGUE), [69](#)

Hashing, [17](#)

Incident Response, [57](#)
Ispezione del Garante, [86](#)

Legittimo interesse, [13](#)

MFA, [16](#)
Minimizzazione dei dati, [9](#)

NIS 2, [42](#)

Opposizione (ricorso al Tribunale), [97](#)

PAM (Privileged Access Management), [56](#)
Phishing, [59](#)
Procedimento sanzionatorio, [96](#)

Registro delle Attività di Trattamento, [26](#)
Riconoscimento facciale, [88](#)
Risarcimento danni (Art. 82), [68](#)

SCC (Standard Contractual Clauses), [78](#)
Schrems II (sentenza CGUE), [67](#)

Trasferimenti extra-UE, [78](#)
Triade CIA, [15](#)

Videosorveglianza, [34](#)
VLAN, [56](#)

Österreichische Post (sentenza CGUE), [68](#)

0THack1A

Corso Master Aziendale: Privacy, GDPR, NIS 2 e Cybersecurity

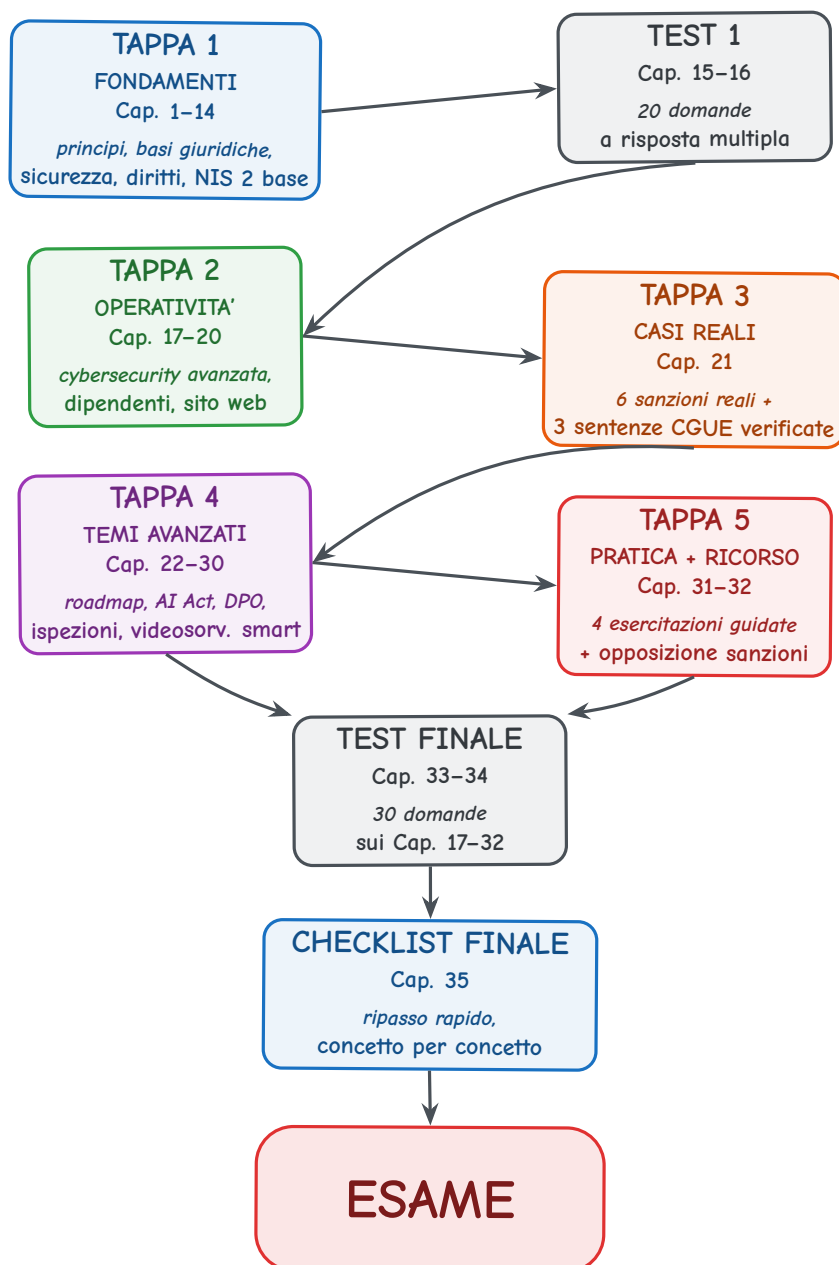
Giugno 2026 – Edizione Aggiornata

Questo documento è rilasciato per uso didattico non commerciale. Non costituisce consulenza legale.

Per situazioni specifiche consultare un professionista qualificato.

La Mappa di Studio del Corso

dai fondamenti all'esame, in 5 tappe



Consiglio: non saltare le tappe – ogni area costruisce sulla precedente.